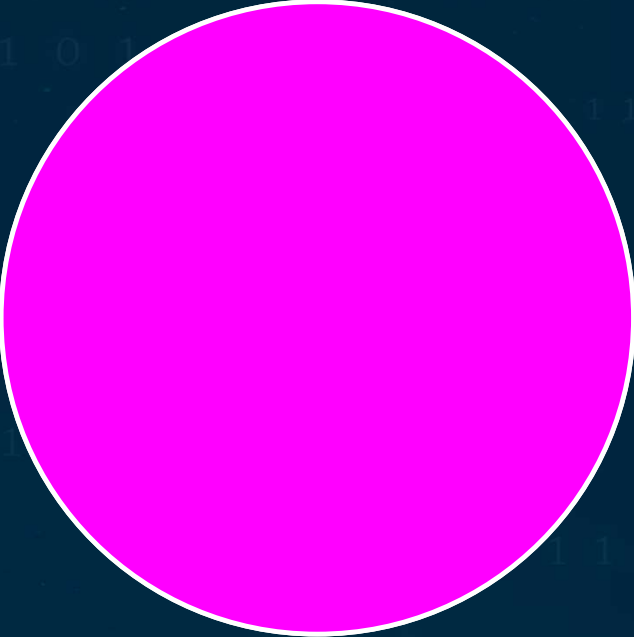


Incident Classification & Severity

Chapter 04 · Episode 1 — Dr. Michael Solomon





What This Episode Covers

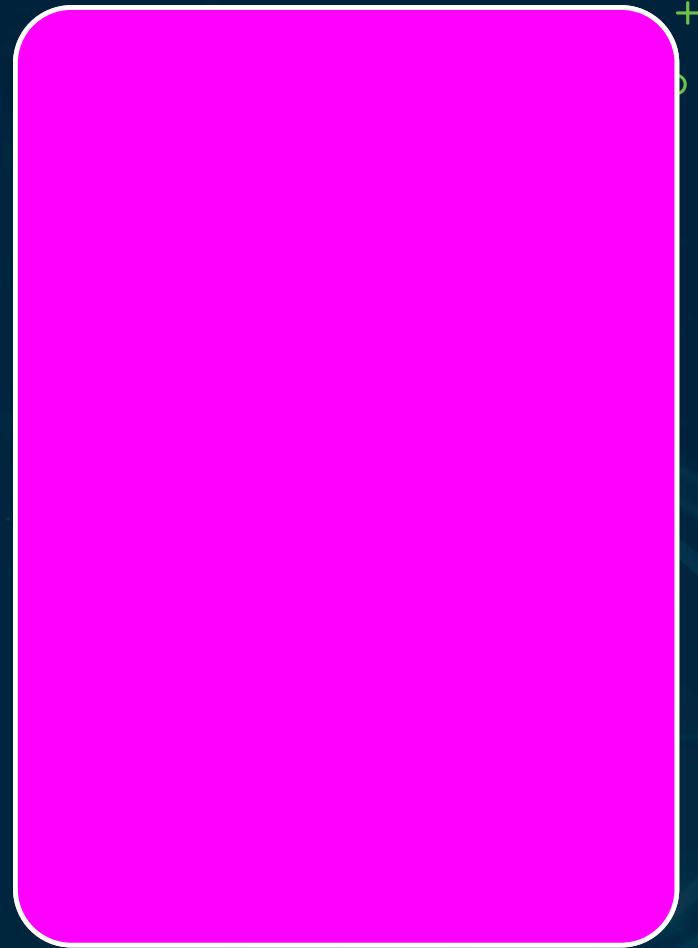
1. Classification vs. severity
2. Six-category taxonomy
3. Five-dimension severity scoring
4. Response matrix (category × severity)
5. Mid-incident reclassification
6. Classification decision record
7. Four exam failure patterns

Classification Is the Foundation

Determines escalation, SLA, notification, resources

Misclassification = governance failure

Must be documented at detection



Six Incident Categories (A–D)



A

Model integrity —
highest impact, persists
until remediated

B

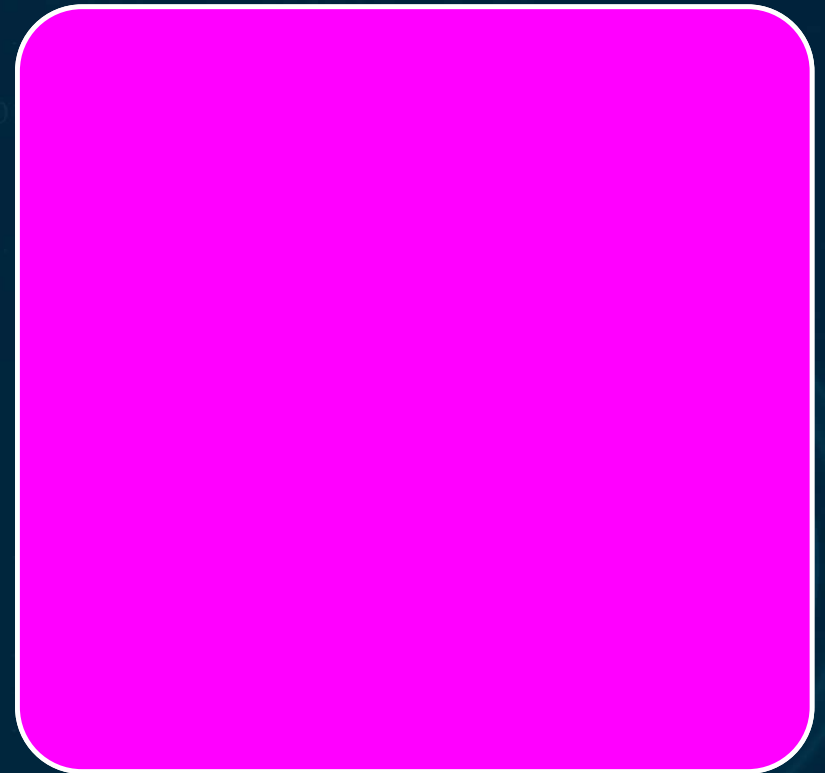
Data breach — GDPR 72-
hr + EU AI Act
notification

C

Service disruption

D

Privacy

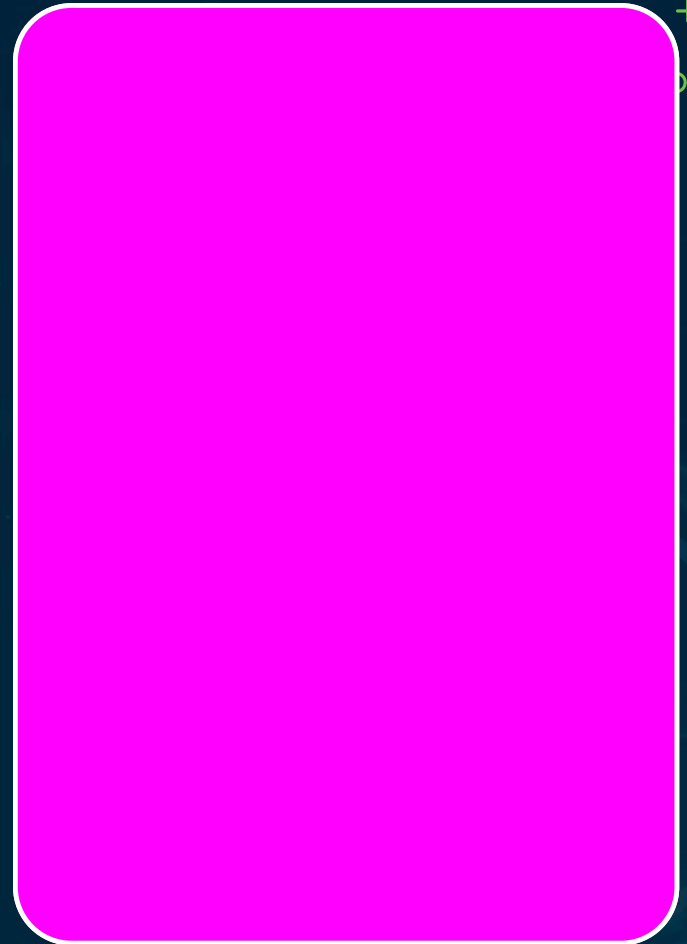


Categories E–F + Exam Note

E Compliance · F Reputational

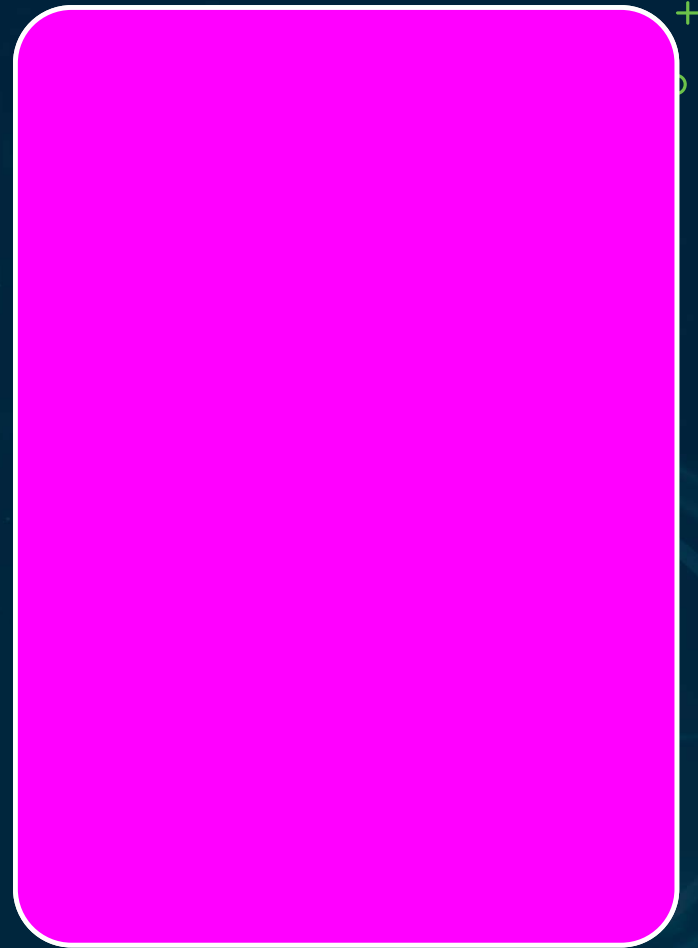
Category A persists until remediated; Category B triggers GDPR 72-hr + EU AI Act

Know all six categories + one example each — directly testable



Five-Dimension Severity Scoring

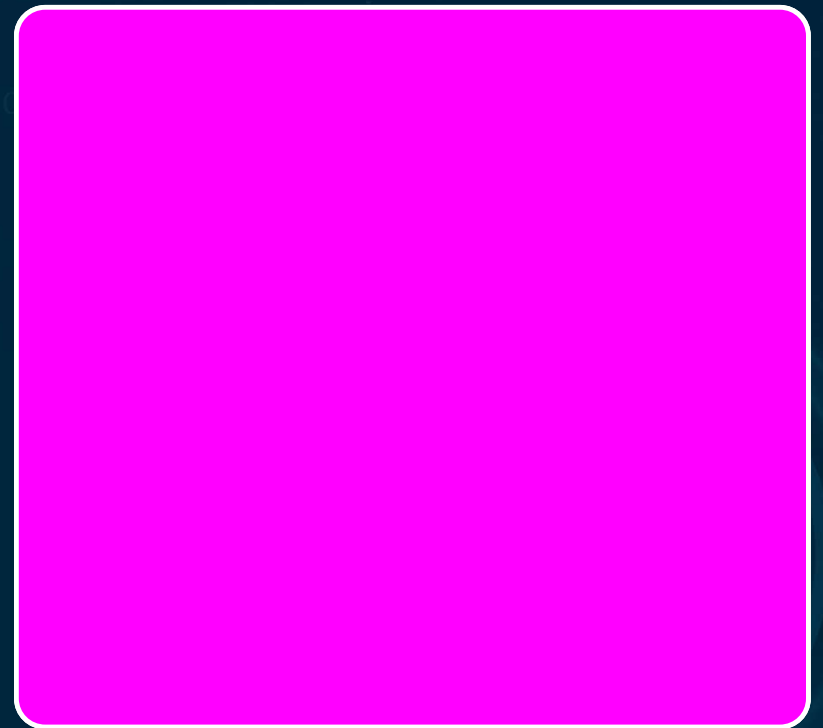
Data sensitivity · User impact · Operational impact
Regulatory exposure · Reputational impact
Each scored 1–5 → aggregate = Low / Medium /
High / Critical



SEVERITY LEVELS

Critical → immediate CSO + board notification, BCP activation assessment

High → AI security lead within 1 hr, steering committee at next meeting



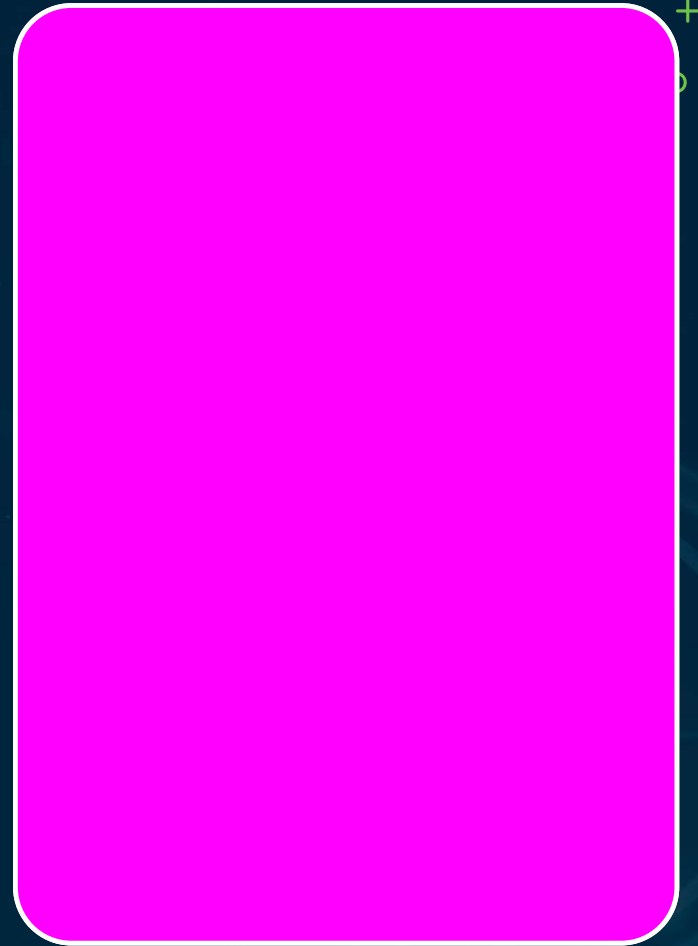
Procedure Integration

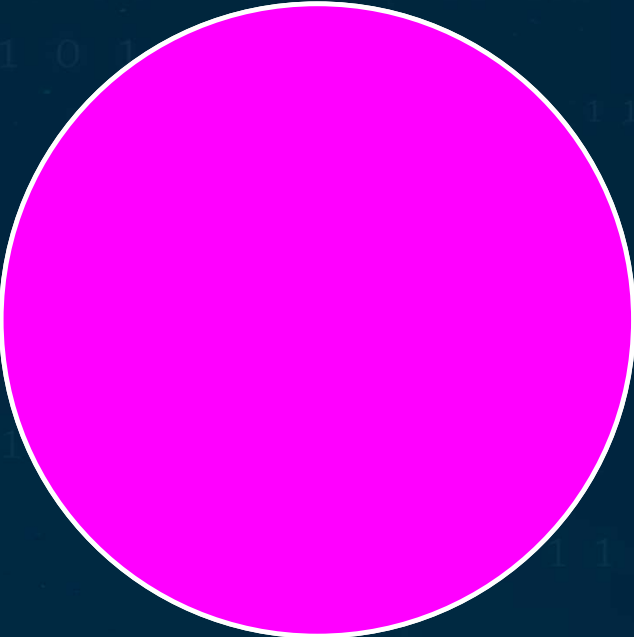
Category A → red-button assessment

Category B → GDPR/DPO notification, 72-hr clock

Category C → BCP activation assessment

Connects every incident to the right procedure — automatically





Decision Record — 7 Fields

1. Incident ID
 2. Initial classification
 3. Classification rationale
 4. Reclassification log
 5. Regulatory trigger assessment
 6. Classification authority
 7. Closed classification
- 

Fields 1–4

1

Incident ID — unique,
cross-referenced to asset
inventory

2

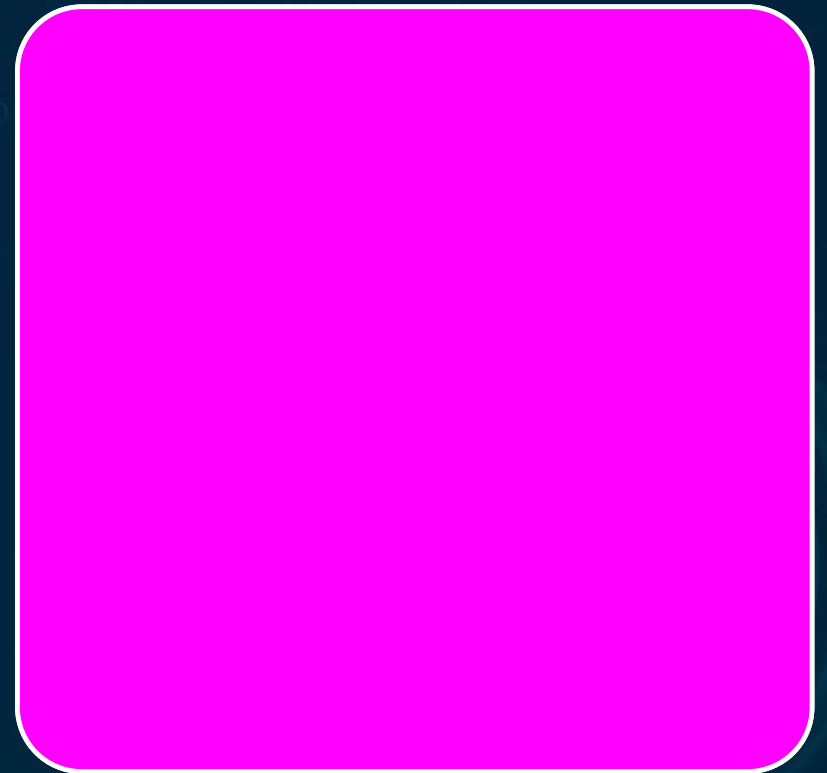
Initial classification —
category, severity,
date/time, officer

3

Classification rationale —
evidence, indicators,
dimension scores

4

Reclassification log —
trigger, evidence,
approver, timestamp



Fields 5–7

5

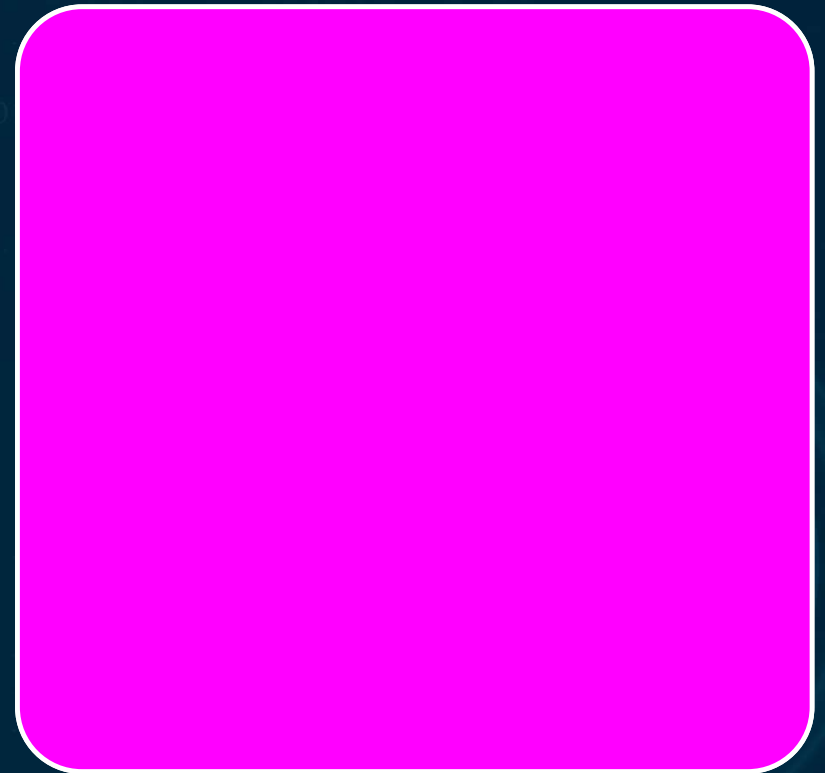
Regulatory trigger assessment — obligations, determination, clock position

6

Classification authority — cannot delegate below AI security lead (tier 1/2)

7

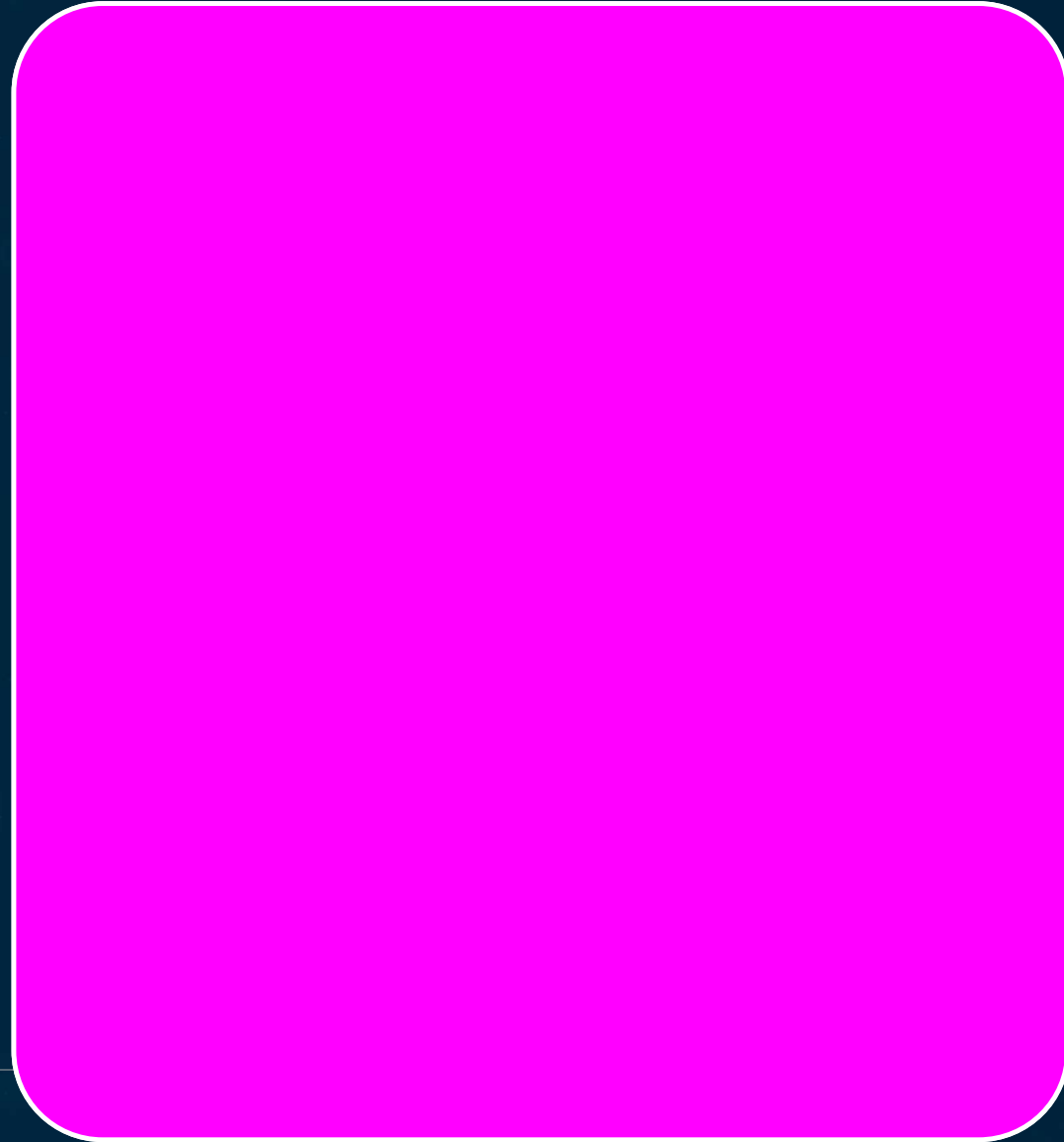
Closed classification — final category/severity for annual stats & reporting



Closing the Record

Closed classification may differ
from initial

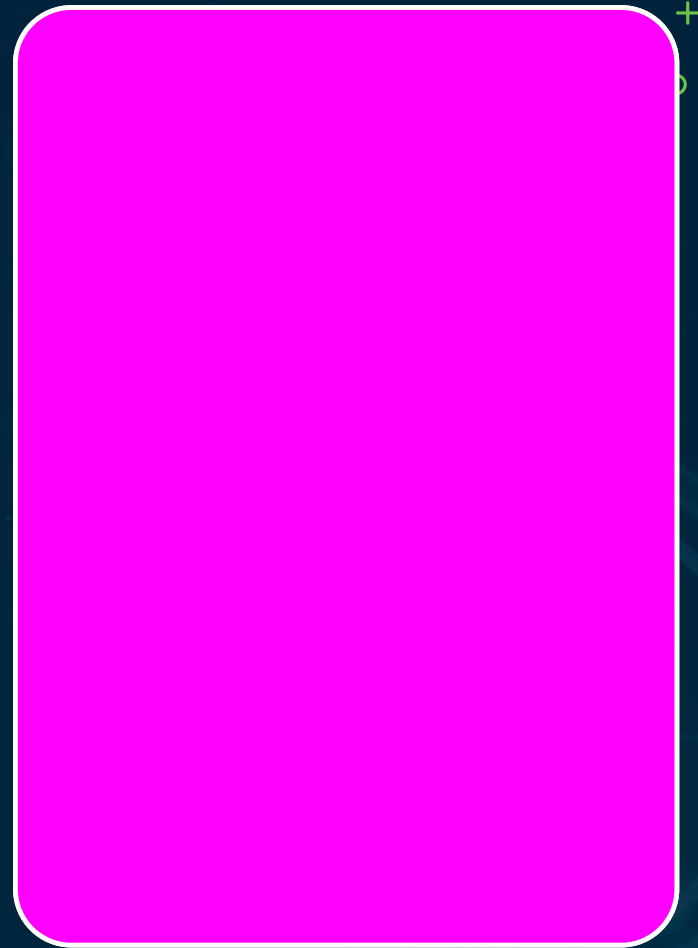
Regulatory trigger assessment must
document the clock position



Exam Failure Patterns

1 Misclassification at detection — e.g., discriminatory output miscalled Category C

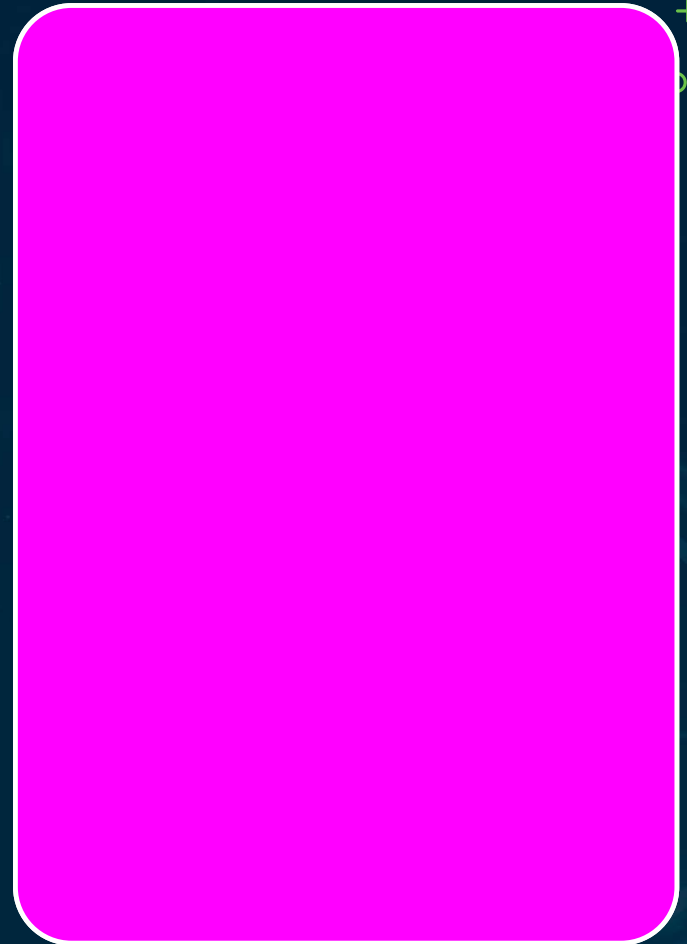
Actually Category A + D → wrong SLA, escalation, notification



Failures 2–3

2 Severity underscored to dodge escalation — score to the 5-dimension framework, not to avoid consequences

3 Not updated as investigation reveals more — GDPR clock runs from detection, not reclassification



Recap · Module Close

Six categories, one example each

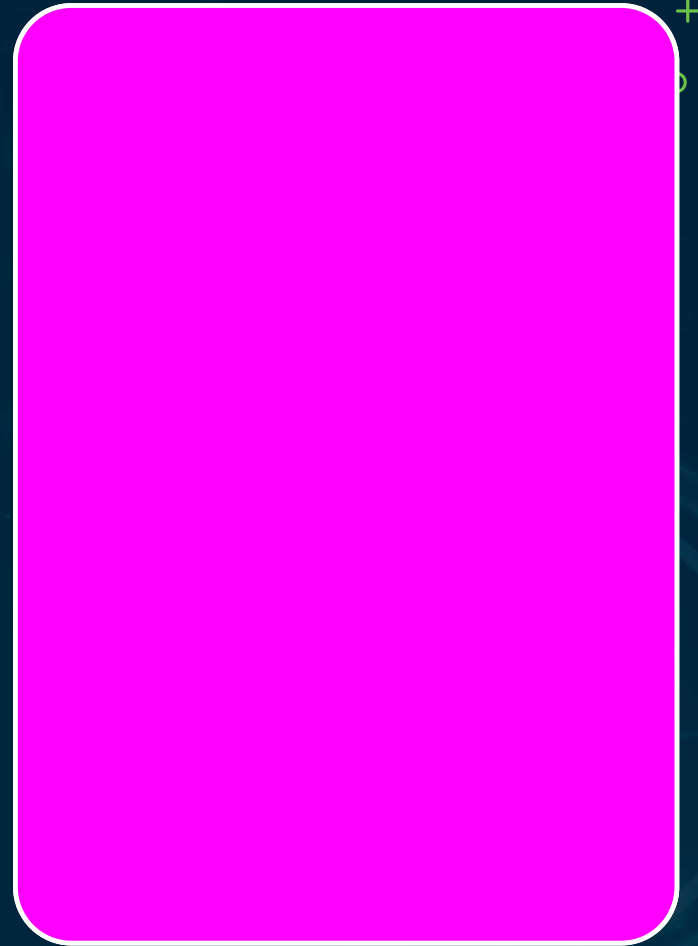
Five severity dimensions

Classification at detection, updated as investigation proceeds

Procedure integration (A/B/C triggers)

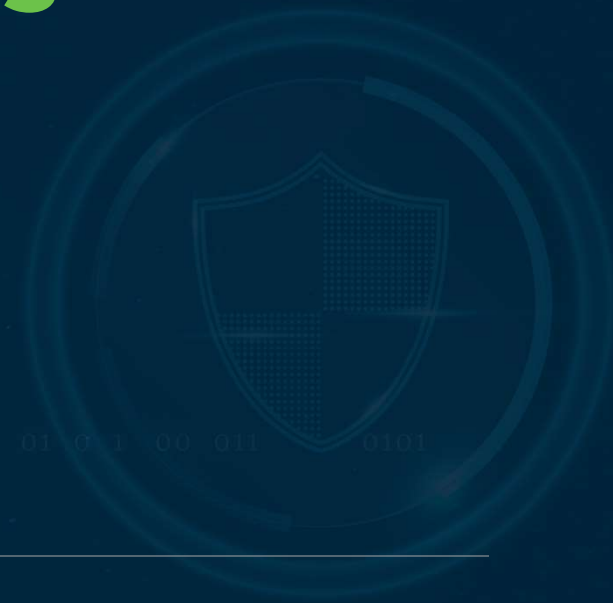
Four failure patterns

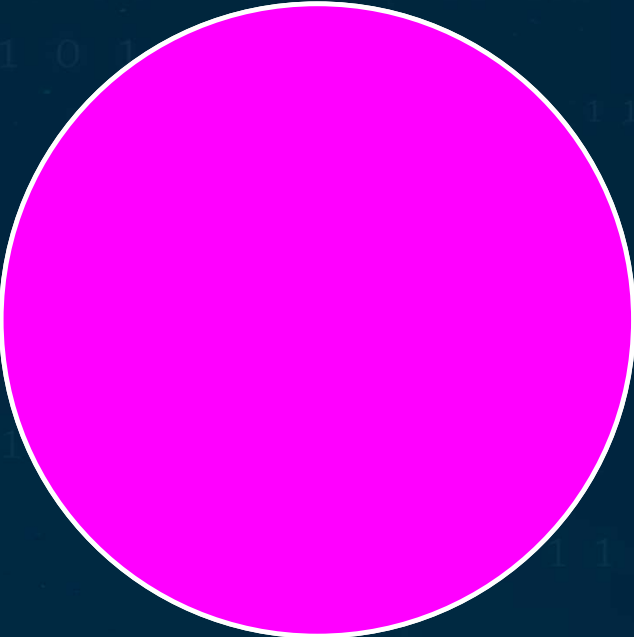
GDPR clock starts at awareness



AI Resiliency & Business Continuity Planning

Chapter 04 · Episode 2 — Dr. Michael Solomon





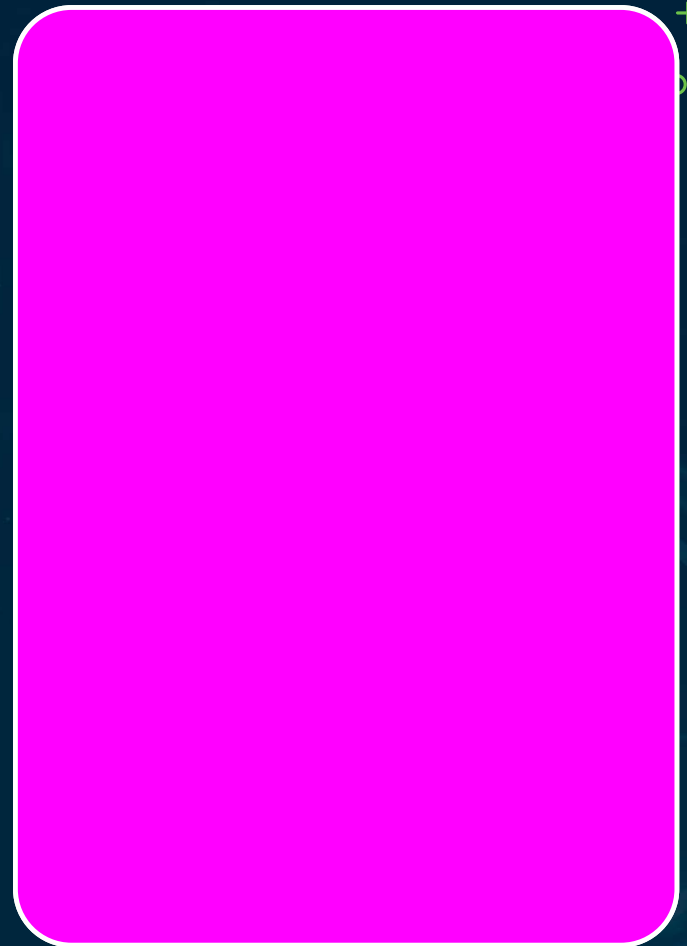
What This Episode Covers

1. AI resiliency's three pillars
2. Four AI asset layers
3. RTO/RPO per system
4. Three recovery paths
5. Five required BCP sections
6. Three BCP test types
7. Four BCP failure patterns

Standard IT BCP Isn't Enough

Standard IT BCP covers infrastructure only

AI BCP must also cover model artifacts, training data, inference capability



Four AI Asset Layers

1

Training data stores

2

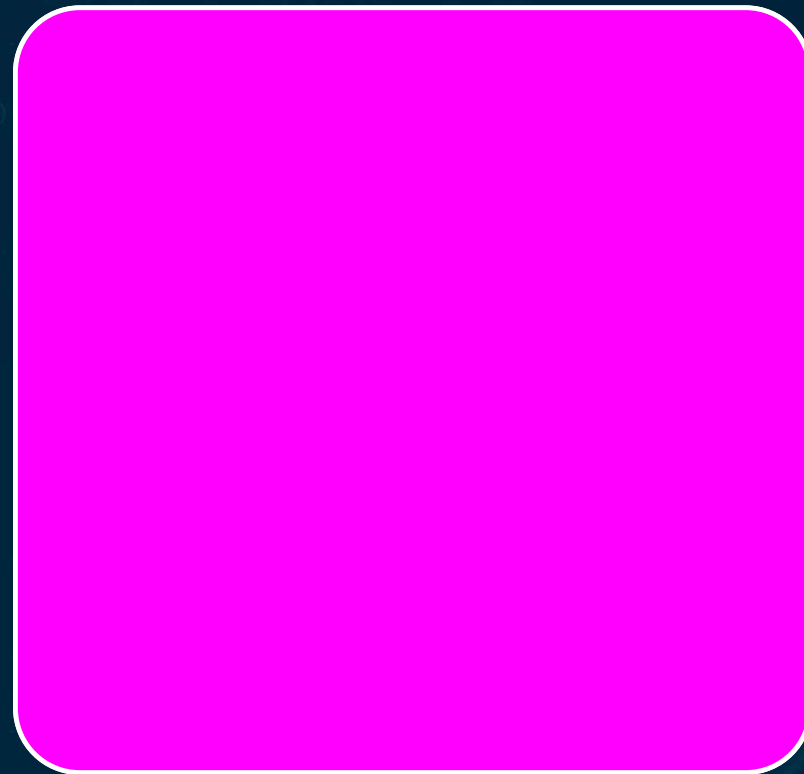
Model registry & artifacts

3

Inference infrastructure

4

Governance & monitoring — each layer needs its own BCP provisions

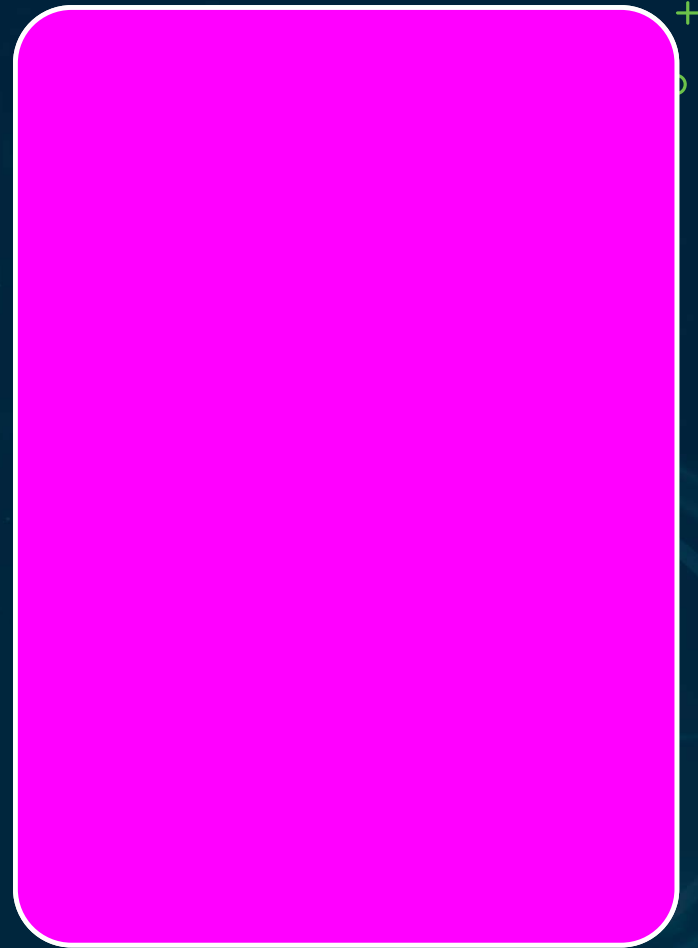


Five Required BCP Sections

Risk assessment · Recovery objectives · Recovery procedures

Testing · Maintenance

RTO/RPO defined per system & per layer — not program-wide



Three Recovery Path

Rollback

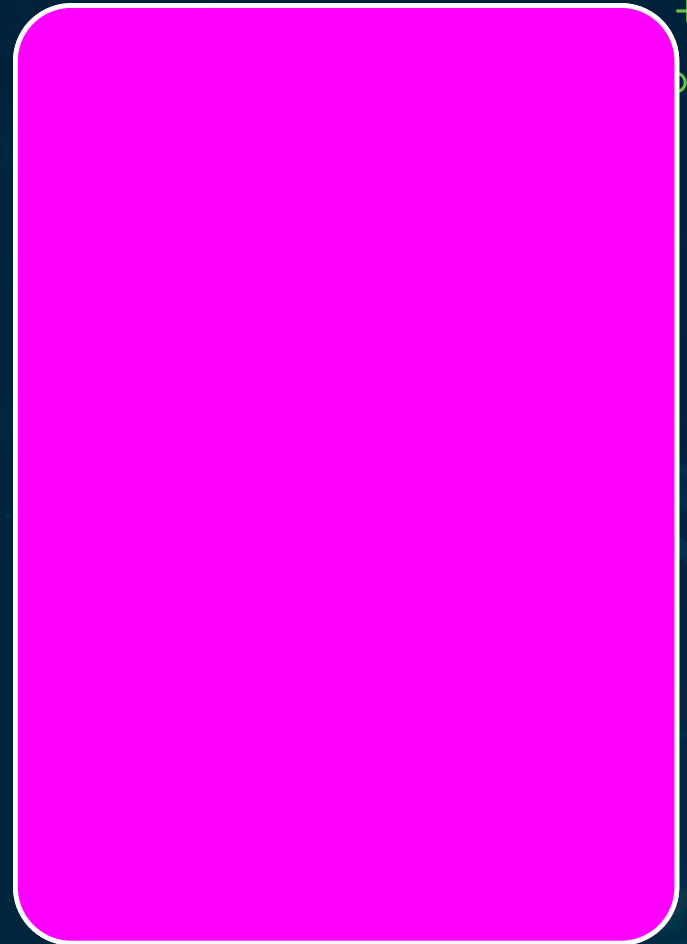
Fastest — needs a verified clean pre-disruption model version

Retraining

Slowest — required when training data integrity is unconfirmed

Manual substitution

Used when recovery isn't possible within RTO — highest operational cost



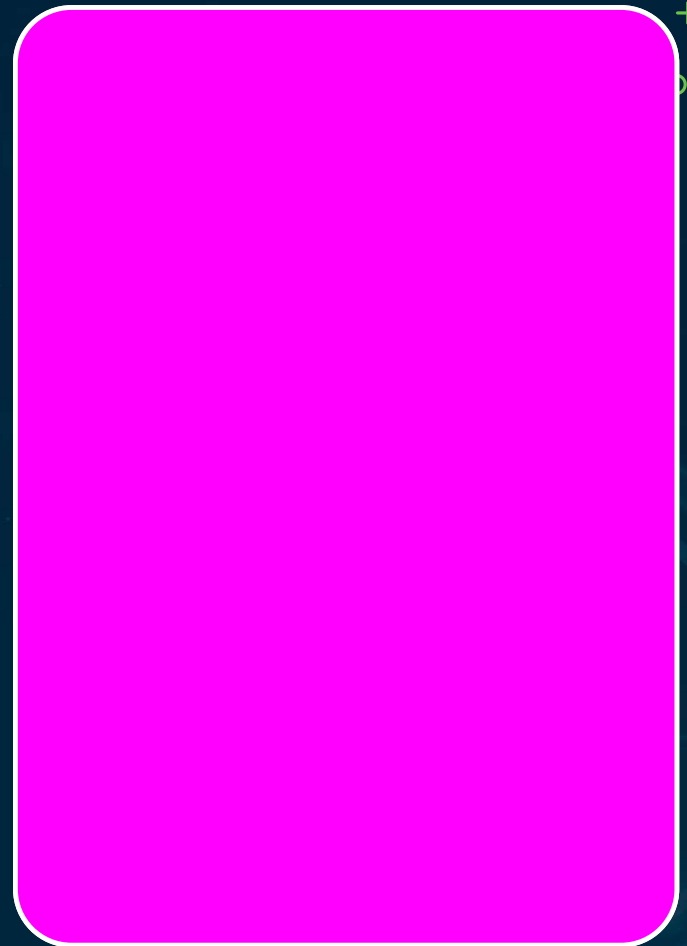
Testing Cadence & Evidence

Tabletop minimum; full failover for tier-1 systems

Annual (tier 1) / biennial (tier 2–3)

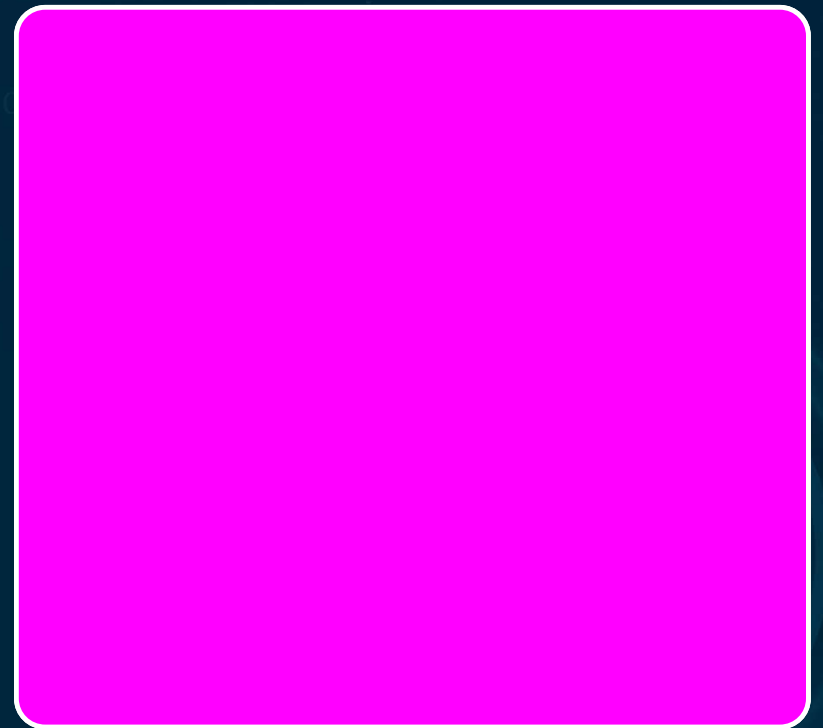
Gaps → BCP update obligations

Test records = regulatory evidence for auditors



VENDOR RISK

One tier-1 AI vendor lost → BCP must cover simultaneous loss of every system built on it
Connects to the concentration-risk framework



Three BCP Test Levels

Tabletop

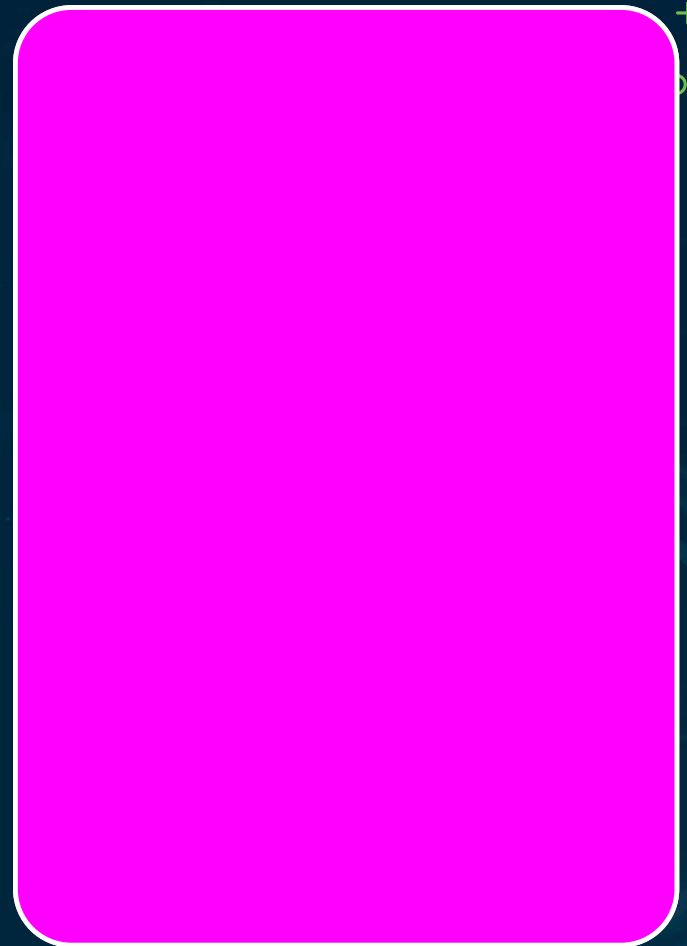
Discuss the scenario — no systems involved

Simulation

Procedures activated — production unaffected

Full failover

Actual cutover — required annually for tier-1

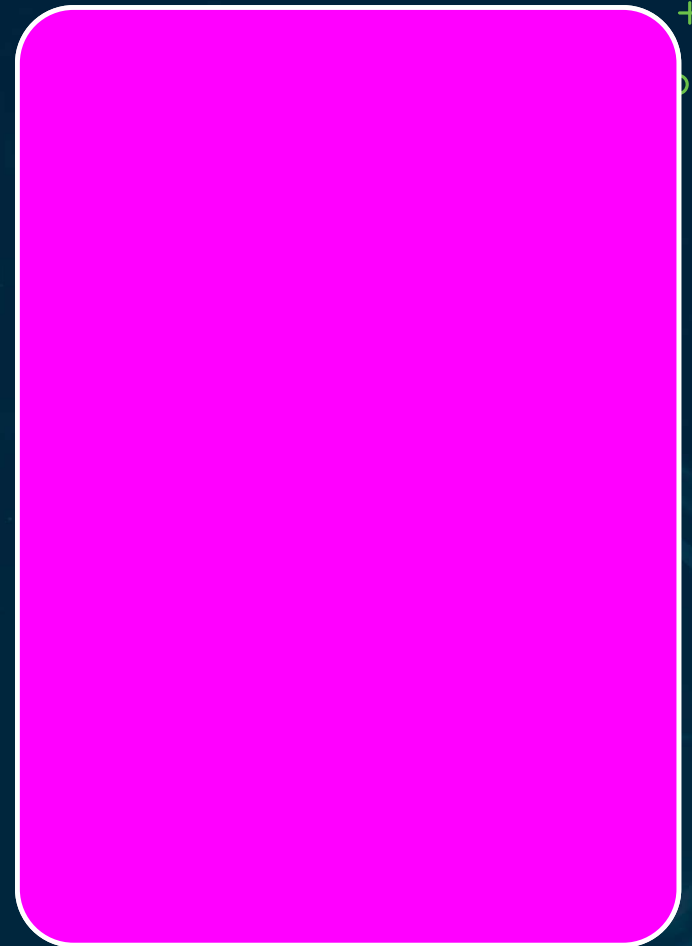


Testing Must Cover All Four Layers

Infra-only tests don't validate model-artifact recovery or the vendor gate

Document expected vs. actual RTO/RPO per layer

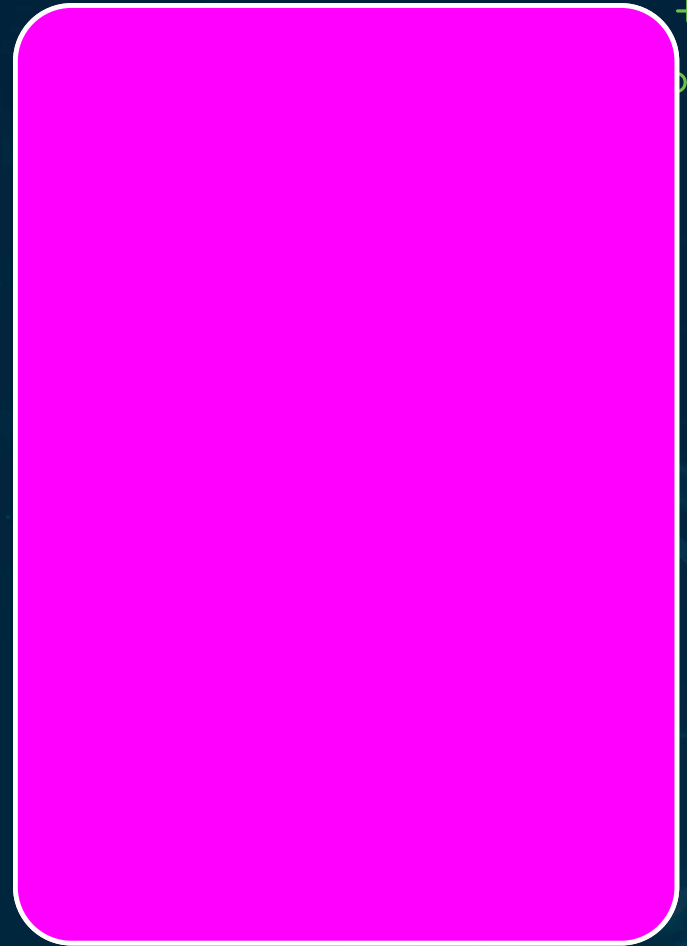
Any gap = a BCP update obligation



Four BCP Failure Patterns

1 Covers infrastructure only — e.g., tested data-center recovery

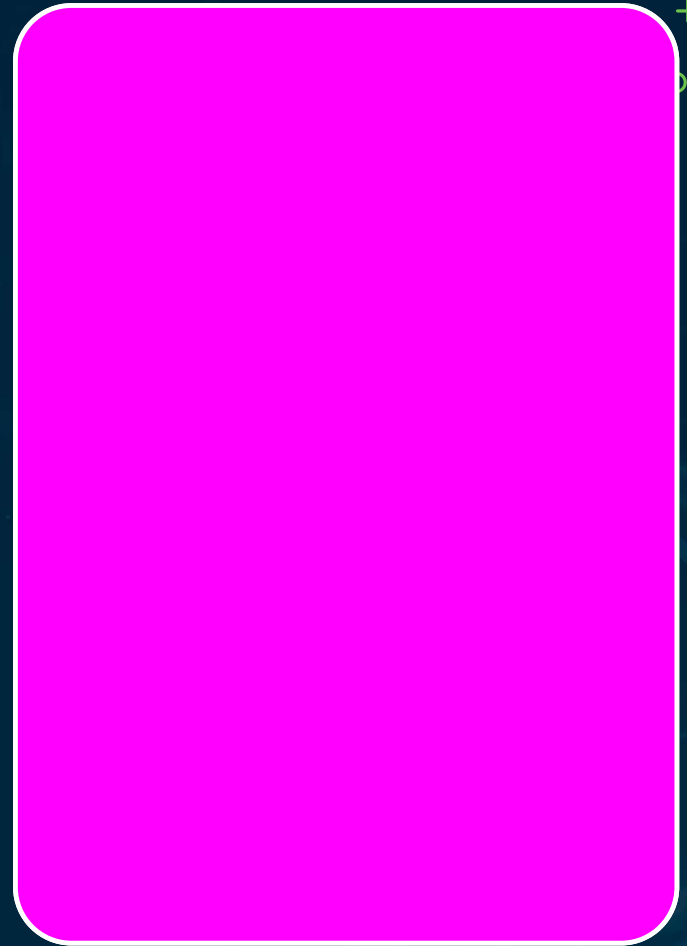
But not model-artifact recovery, training-data restoration, or pre-production V&V — 3 of 4 layers unprotected



Failure 2

RTO not defined per AI system — e.g., same 4-hr RTO for a consumer-credit model and an internal tool

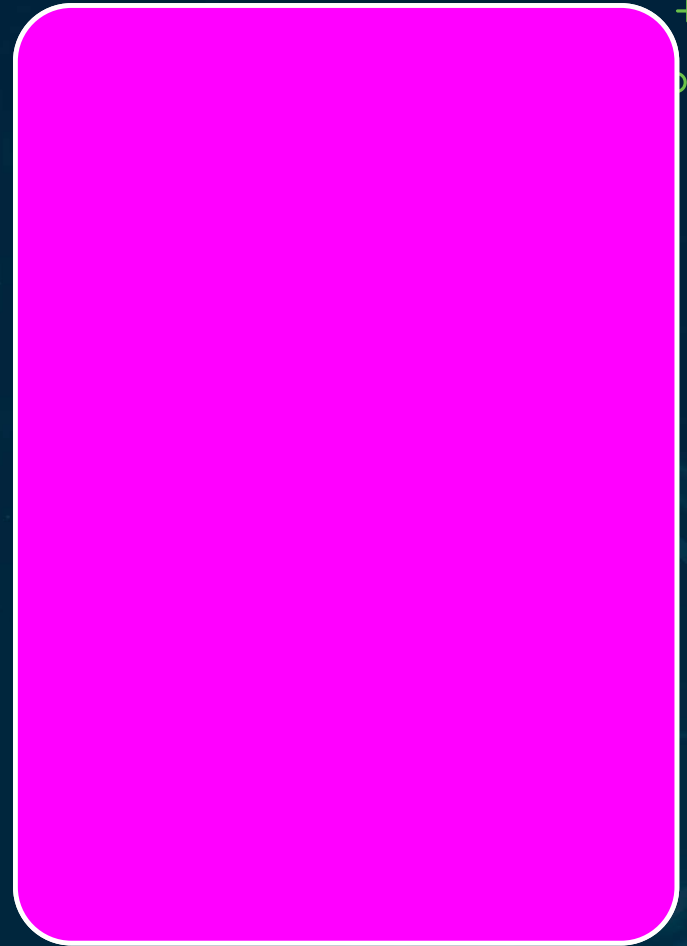
No proportionality — regulators focus on the high-risk system



Failure 3

Recovery procedure never tested — e.g., rollback exists on paper only

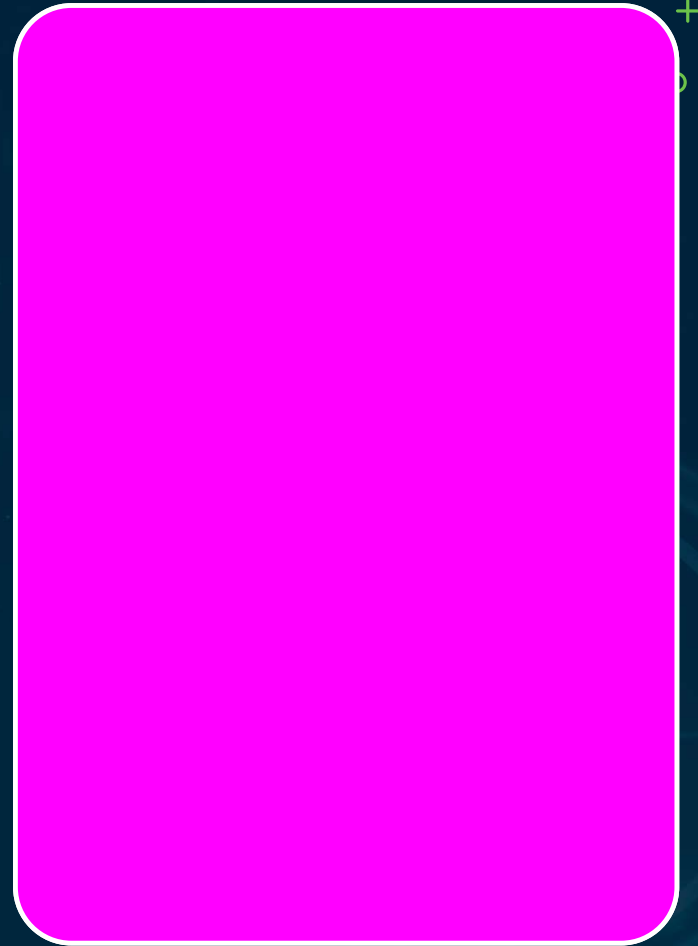
During a real incident, it referenced a model-registry process changed 6 months earlier



Failure 4 + The Fix

Retraining path not documented — rollback alone
can't fix a training-data compromise

Fix: cover all 4 layers · RTO/RPO per system & layer ·
test annually · document the retraining path

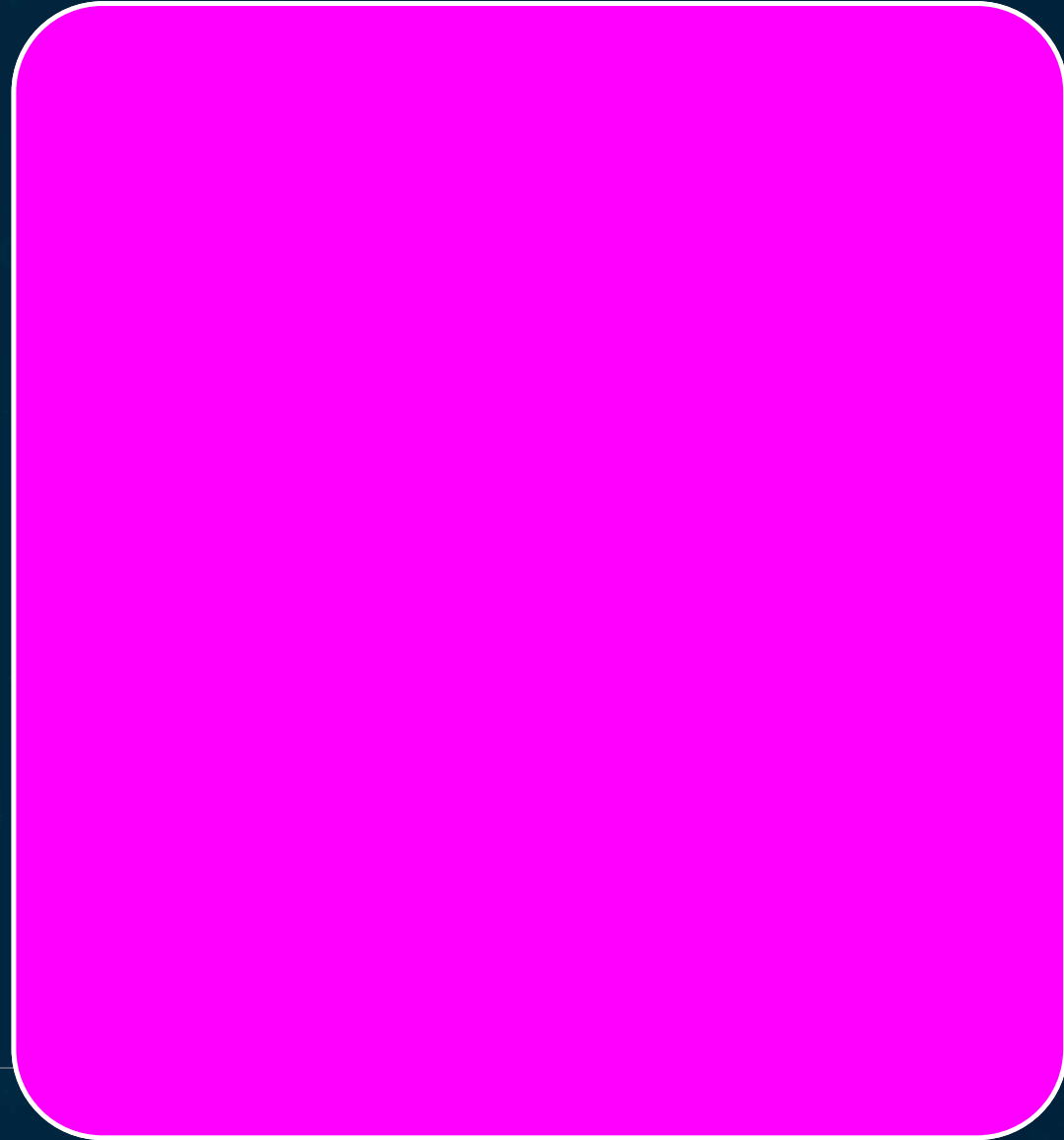


Know Cold for the Exam

4 layers · 3 recovery paths

Retraining required when data integrity is unconfirmed

BCP must be tested, not just documented



Recap · Module Close

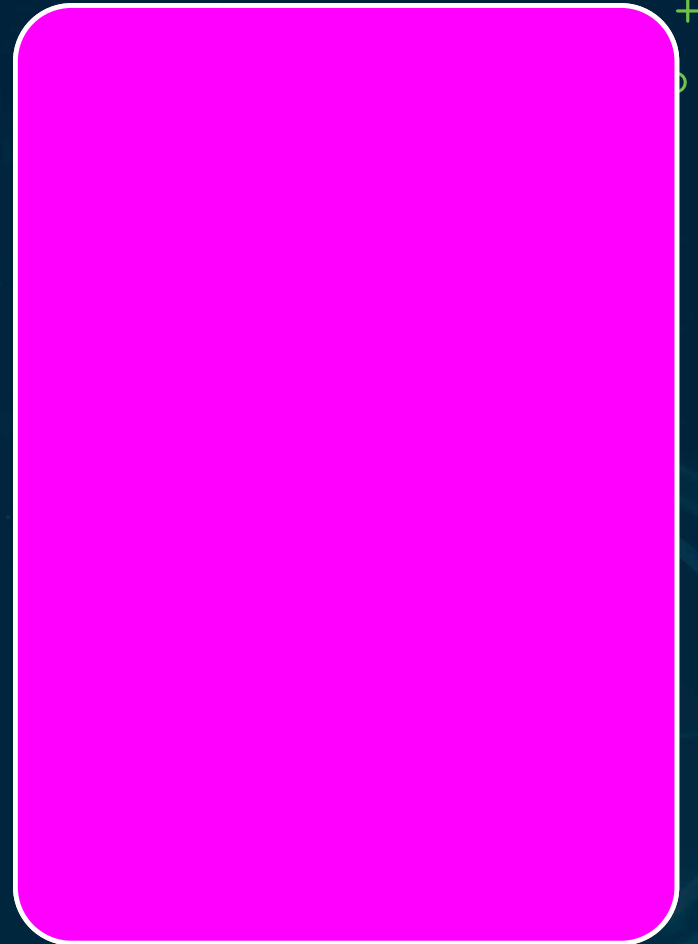
Four AI asset layers

Five BCP sections

Three recovery paths

Testing obligations & vendor concentration

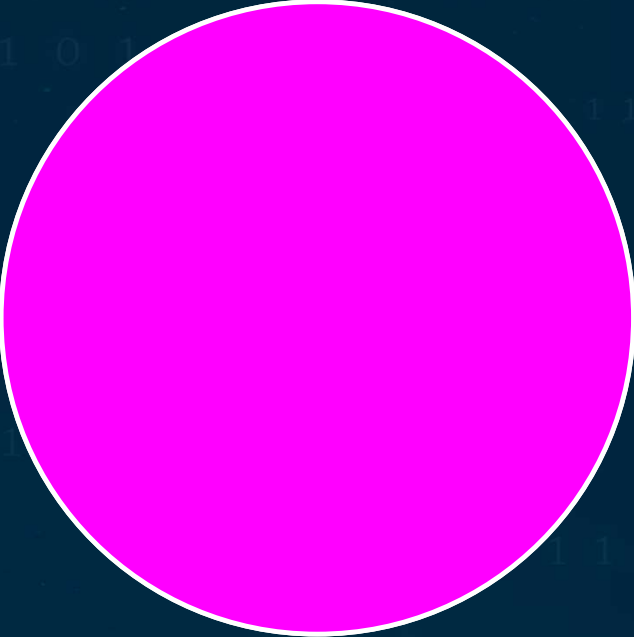
Four failure patterns



Red Button & Break Glass Controls

Chapter 04 · Episode 3 — Dr. Michael Solomon





What This Episode Covers

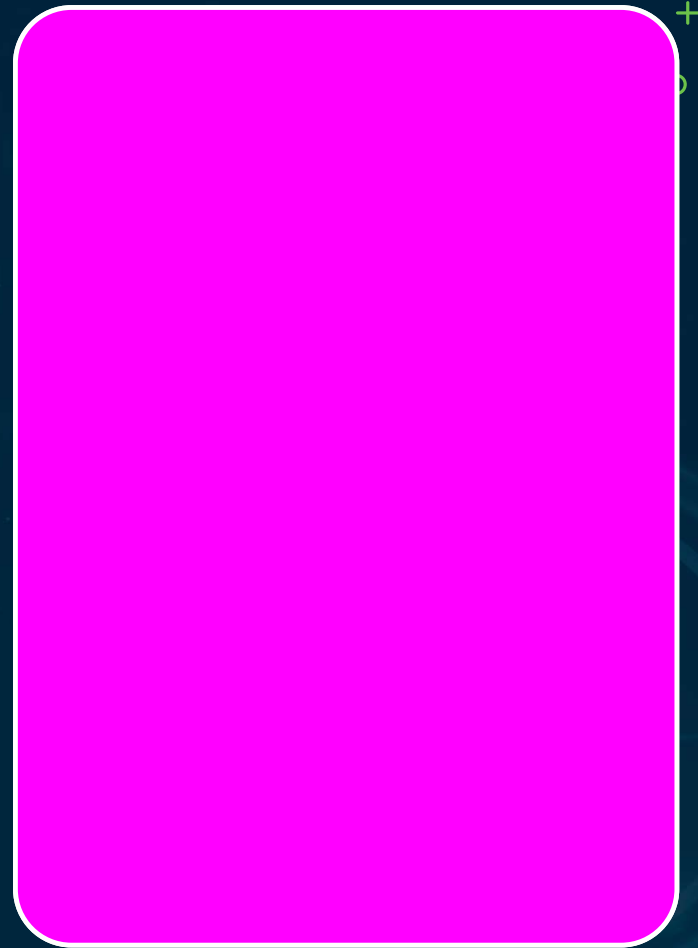
1. Red button vs. break glass distinction
2. Red button trigger categories
3. 7-step activation procedure
4. 7 break-glass design requirements
5. 3-category recovery gate
6. Documentation for both controls
7. 4 exam failure patterns

The Core Distinction

Red button → suspends AI operation (restriction)

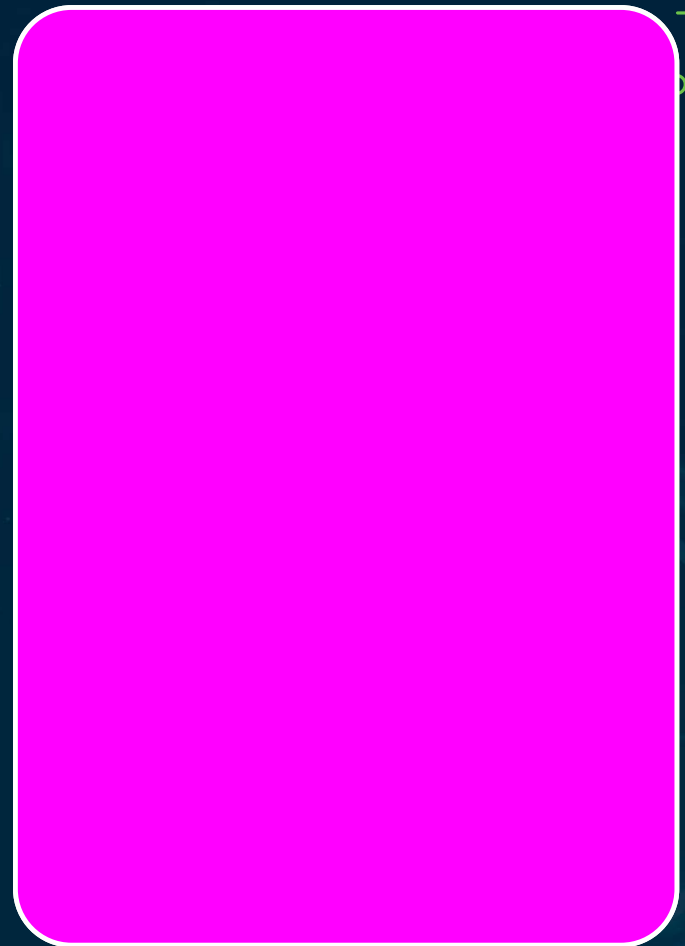
Break glass → grants emergency access (permission)

Both are pre-designed, not ad hoc



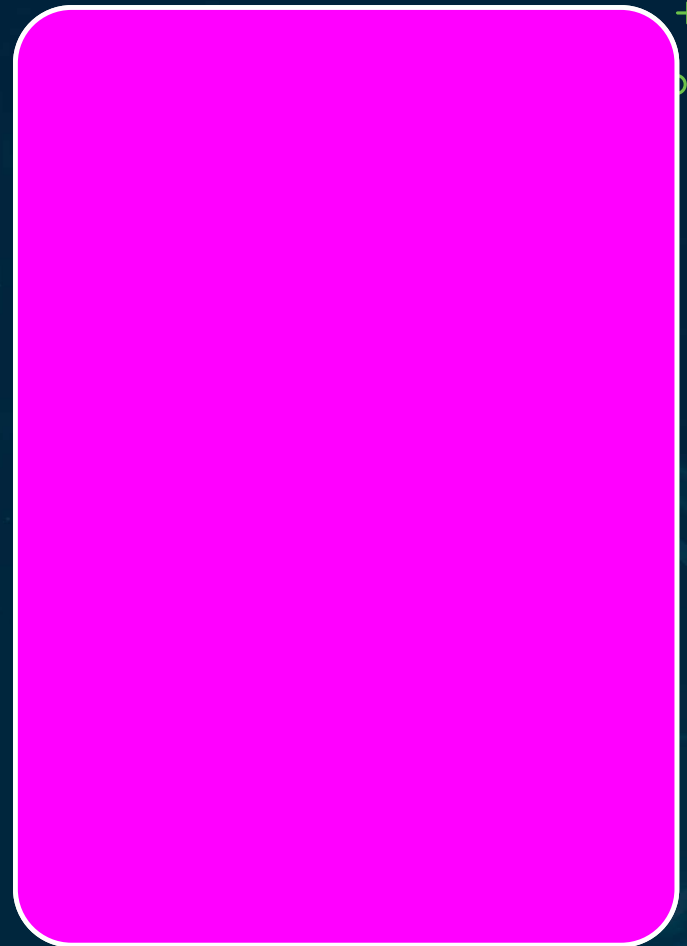
Red Button Trigger Conditions

1. Confirmed model compromise
2. Data poisoning
3. Regulatory directive
4. Critical safety failure



Design Requirements

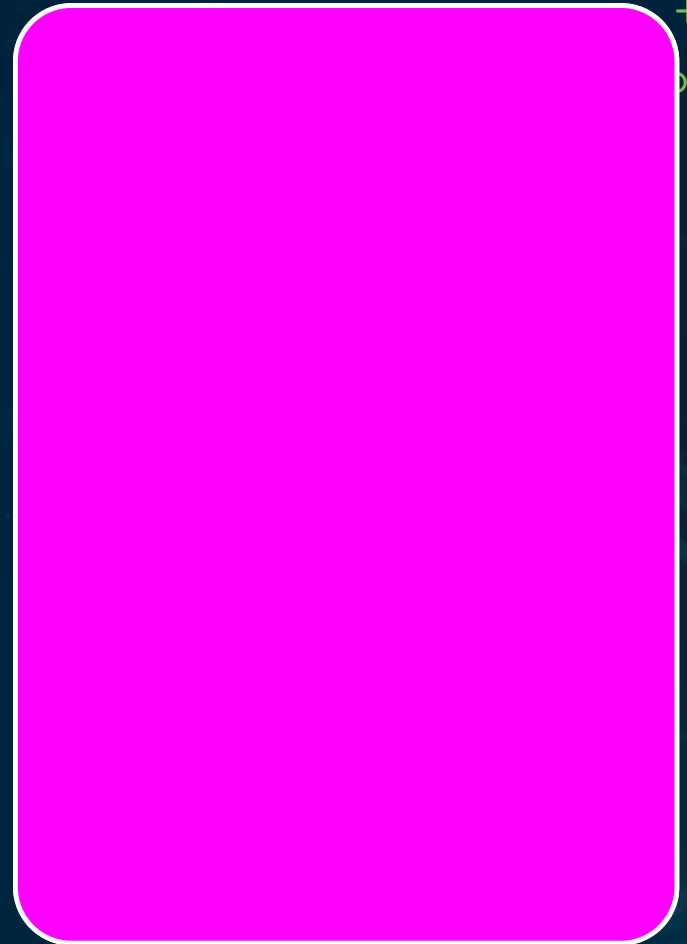
1. Documented triggers
2. Named activation authority
3. Defined scope
4. Suspension procedure
5. Communication plan
6. Evidence preservation — before suspension begins
7. Recovery criteria



The Break-Glass Procedure

Justification documented → verbal approval →
access granted → action logged → post-use review

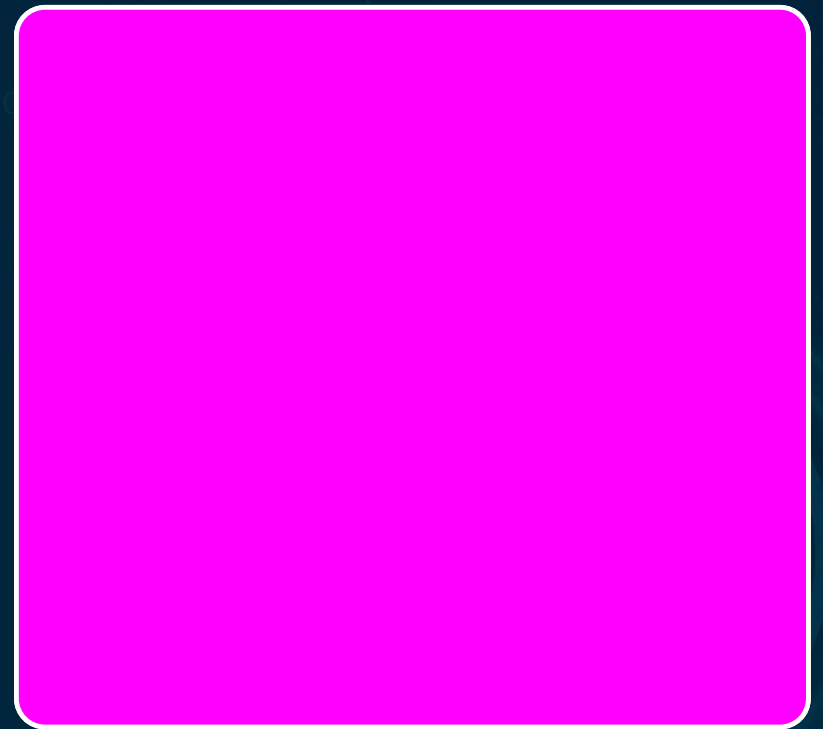
Access log is immutable evidence



POST-USE REVIEW

Occurs within 48 hours — review all actions taken

High break-glass frequency = bottleneck signal

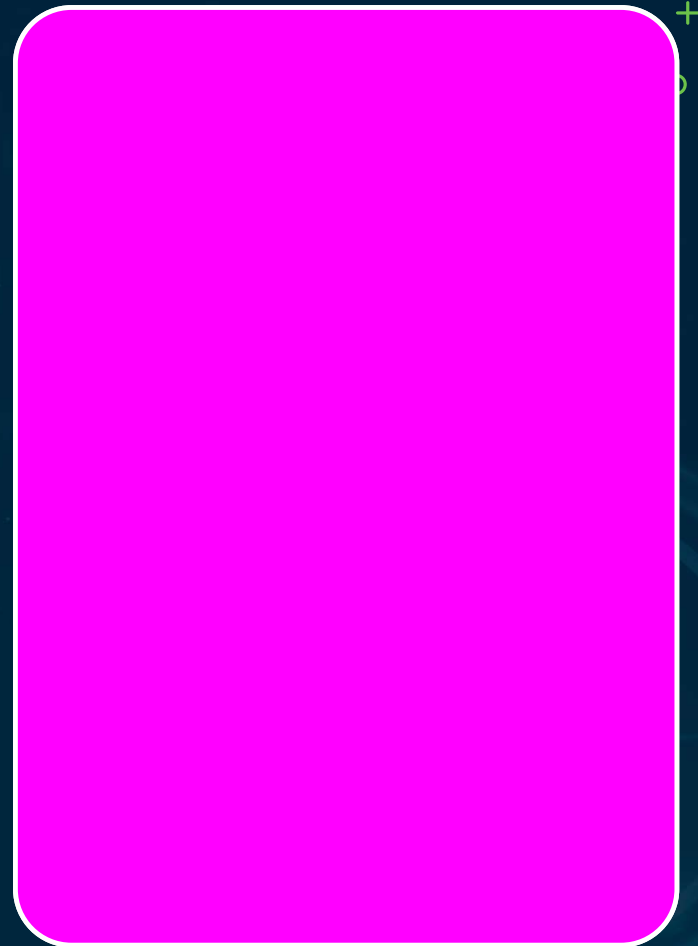


Connects to Incident Response

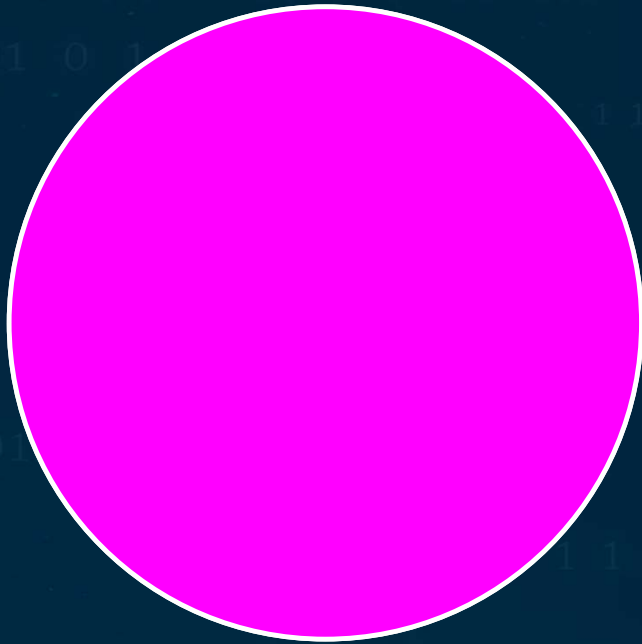
Category A incidents trigger red-button assessment

Suspension doesn't end the incident —
investigation/recovery run in parallel

Every event needs a governance record



Red Button Record



1. Incident ID
2. Trigger condition met
3. Activation timestamp
4. Activating officer
5. Scope of suspension
6. Evidence preserved before activation
7. Notifications sent (DPO/CSO/Steering)



Break-Glass Record Fields



1

Justification, documented
before access

2

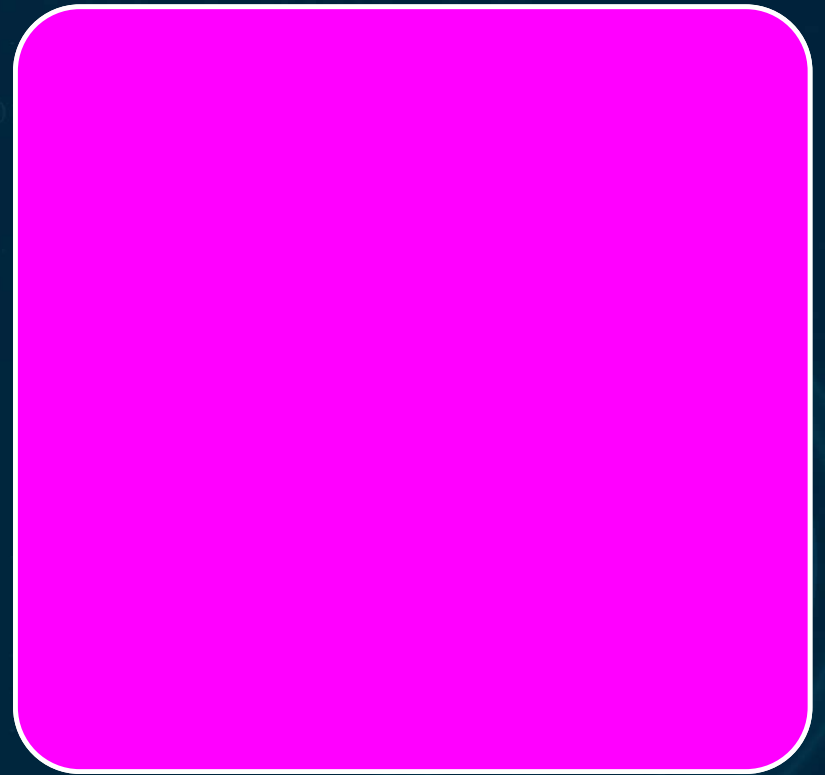
Verbal approval authority
+ timestamp

3

Access timestamp +
immutable action log

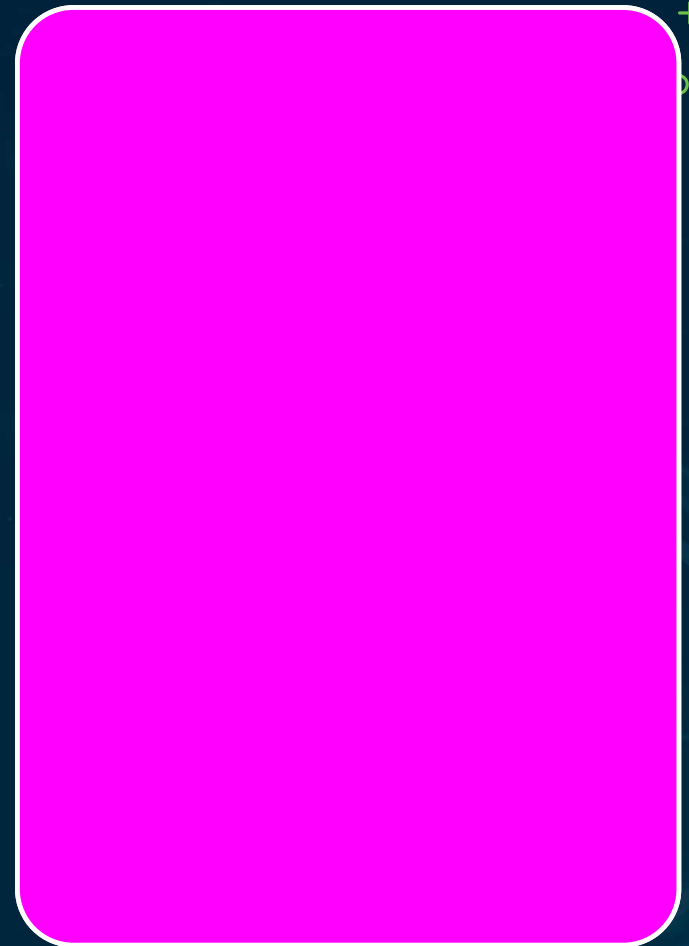
4

Post-use review date +
findings



Both Are Governance Evidence

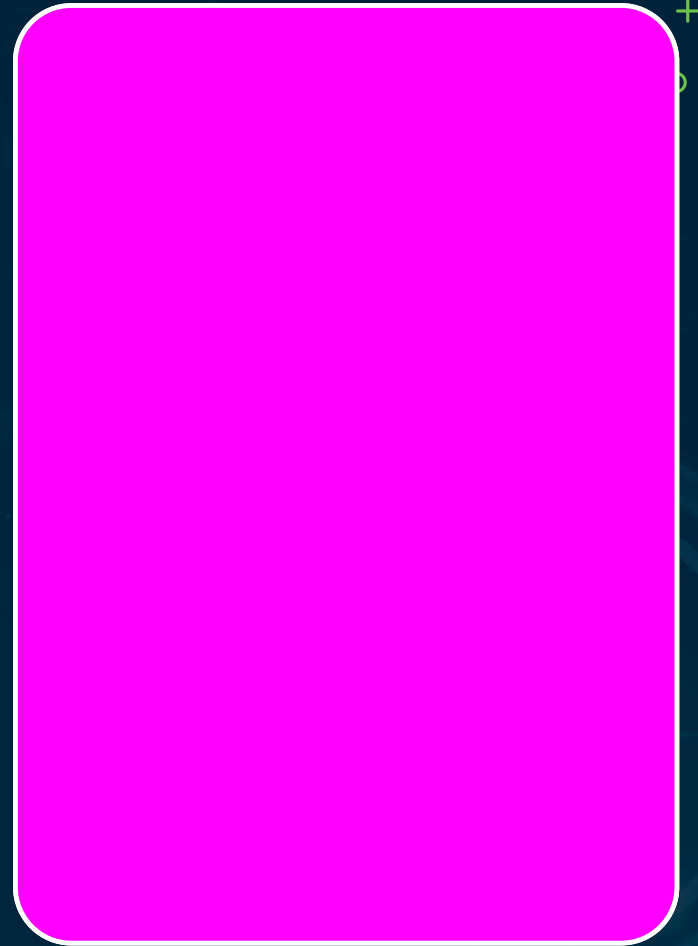
- Provided to regulators/auditors on request
- Retained for the same period as incident records
- High frequency = program health signal



Exam Failure Patterns

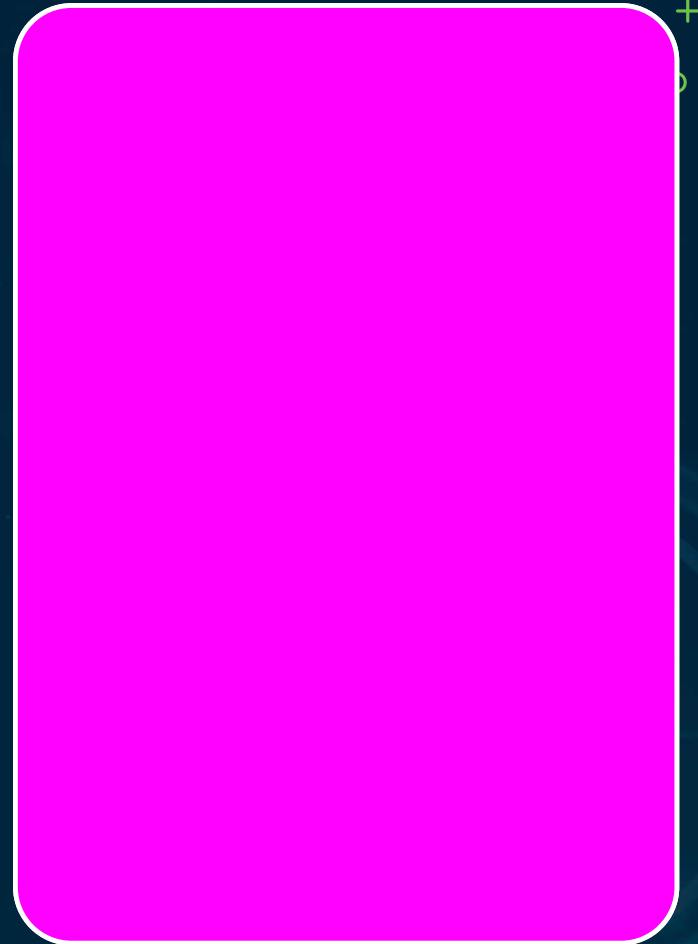
1 Red button triggered without predefined criteria

Defensible decision, but undocumented —
governance record incomplete



Exam Failure Patterns

2. Evidence not preserved before suspension — forensic evidence destroyed
3. Break-glass not reviewed post-use — actions never audited



Recap · Module Close

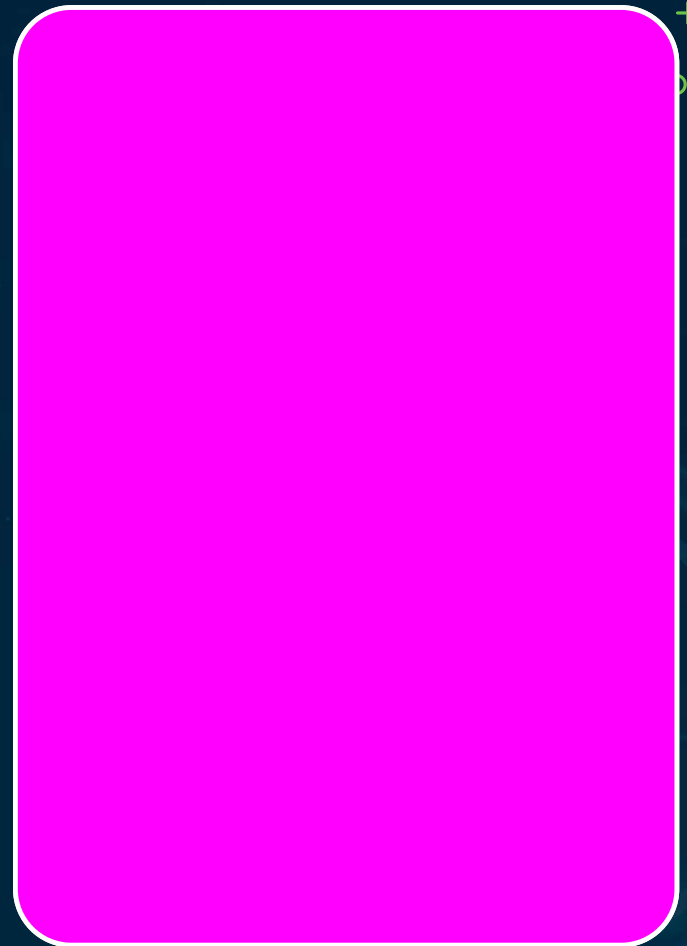
Restriction vs. permission

7 design requirements

Evidence preservation is step zero

Break-glass review within 48 hrs

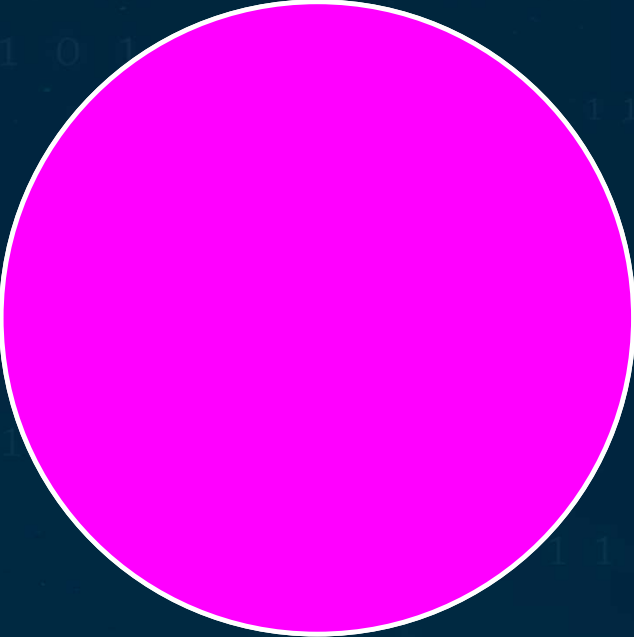
Integration with classification



Disaster Recovery for AI Systems

Chapter 04 · Episode 4 — Dr. Michael Solomon





What This Episode Covers

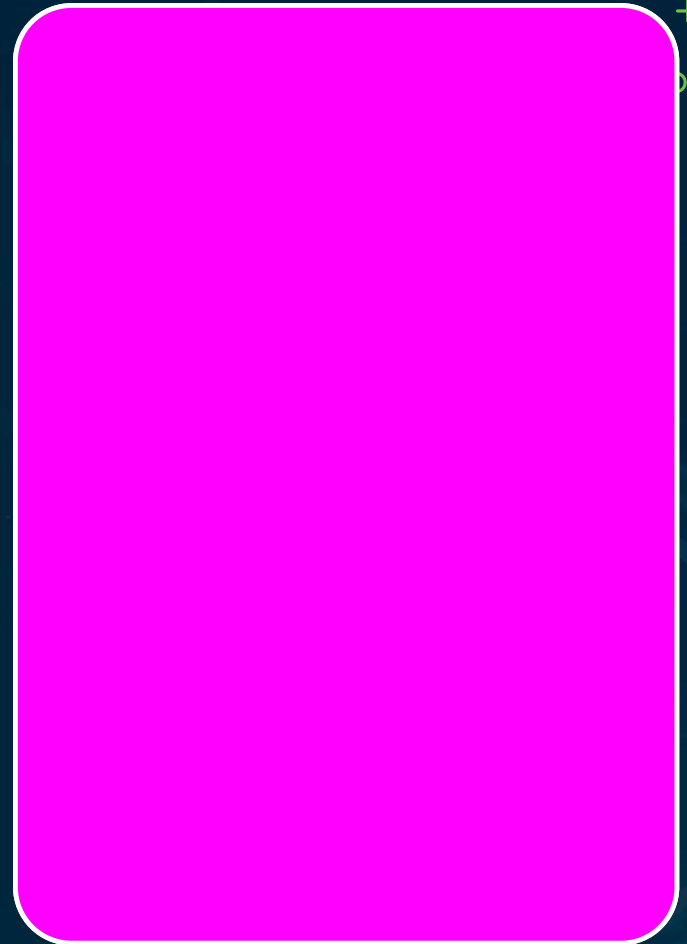
1. BCP-DR relationship
 2. Deriving RTO/RPO from business impact
 3. 3 DR architecture tiers
 4. 5-section DR runbook
 5. 5 AI-specific DR challenges
 6. 4-level DR test framework
 7. 4 failure patterns
- 

BCP vs. DR

BCP → continuity during disruption (organizational)

DR → restoration after catastrophic failure (technical)

DR must cover all 4 AI asset layers



Three DR Architecture Tiers



Warm standby

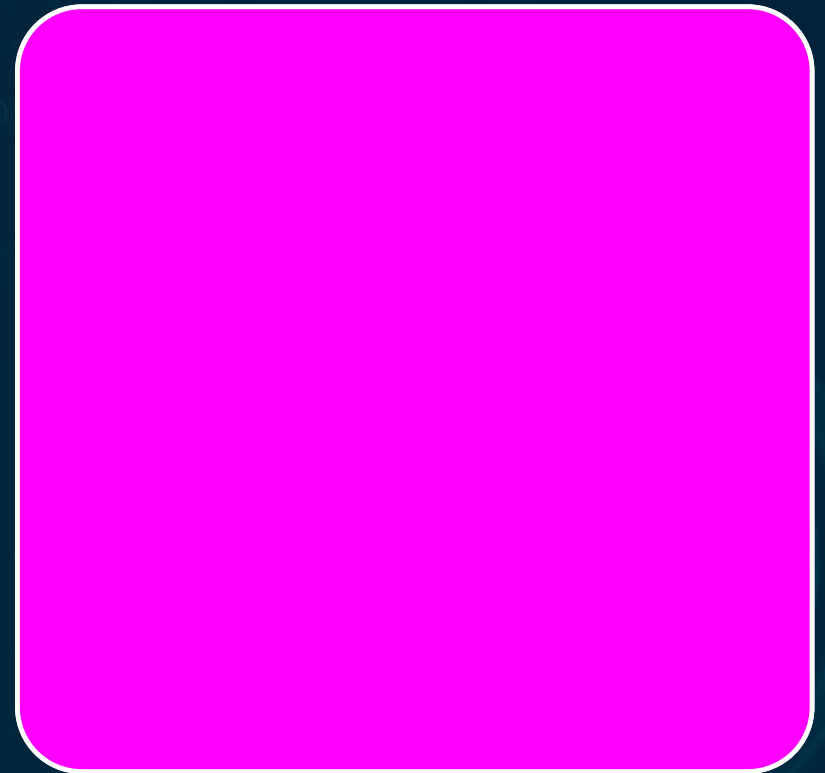
Parallel environment maintained — fastest, highest cost

Cold standby

Backup artifacts maintained, not running — moderate recovery

Rebuild from source

Only source data/procedures retained — slowest, lowest cost

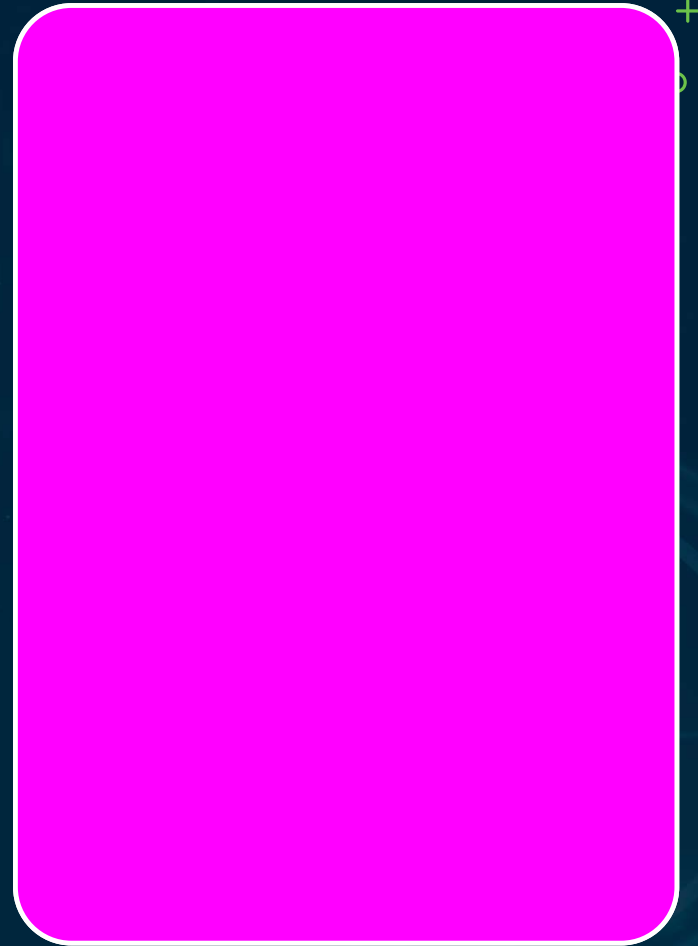


Tier Assignment Must Match

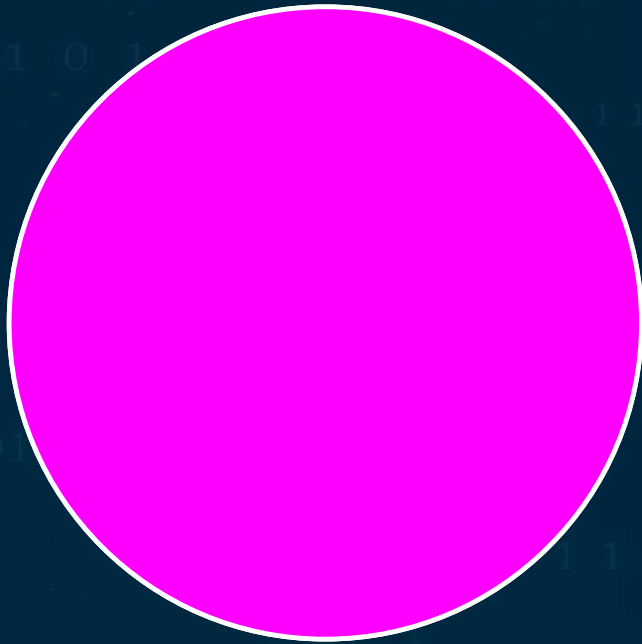
Architecture tier should match the system's RTO tier

Tier-1 AI systems require warm or cold standby

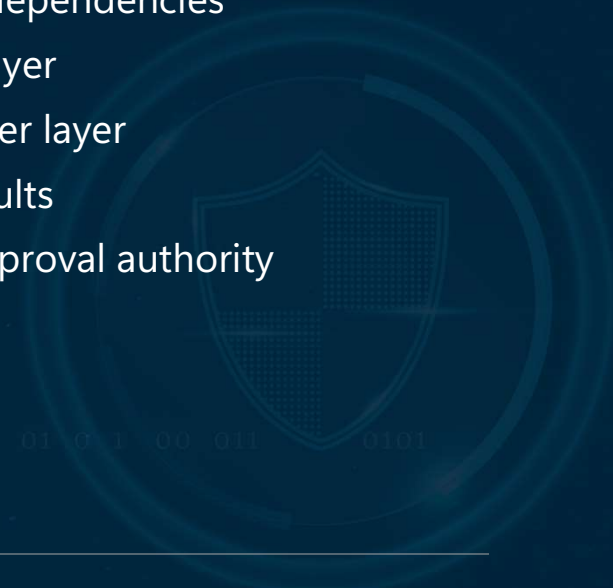
A DR runbook is required for every tier-1 system



The DR Runbook



1. System description & dependencies
2. RTO/RPO targets per layer
3. Recovery procedures per layer
4. Testing schedule & results
5. Owner, review date, approval authority

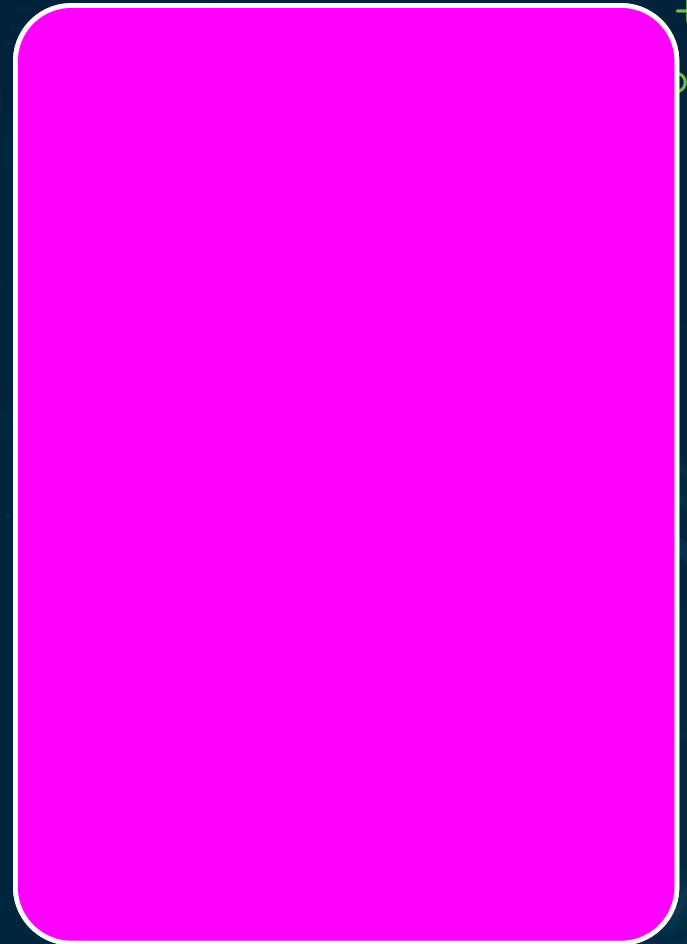


Testing Cadence & Evidence

Annual full DR test for tier-1; tabletop minimum for tier 2/3

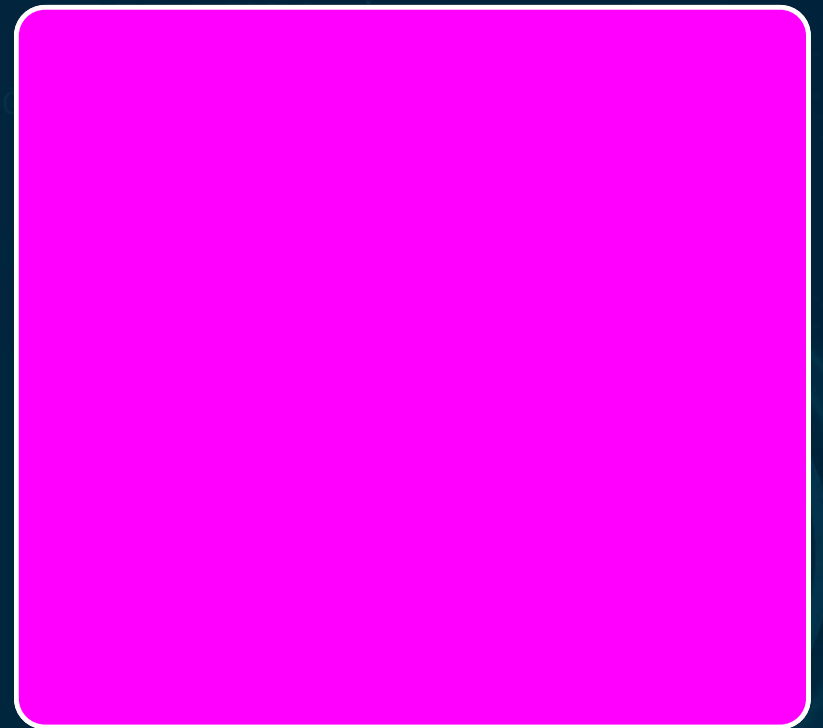
Must cover all 4 asset layers

Gaps → runbook update obligations



V&V GATE

V&V report required on the recovered system
DR recovery does not bypass the architecture
review checklist



Three DR Test Levels

Walkthrough

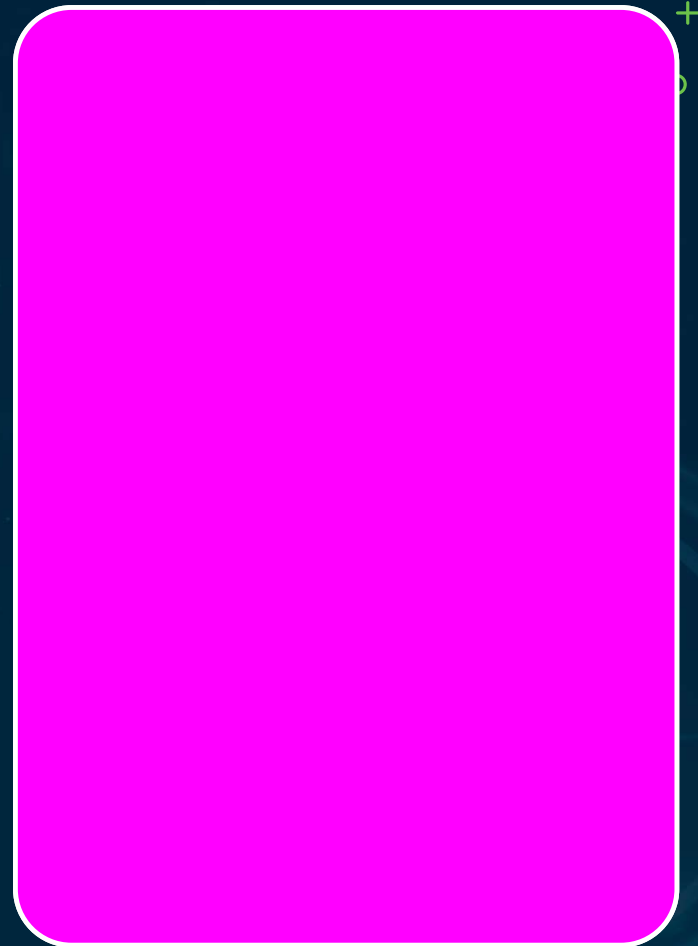
Review the runbook for accuracy and completeness

Component test

Test individual recovery steps — no full cutover

Full DR test

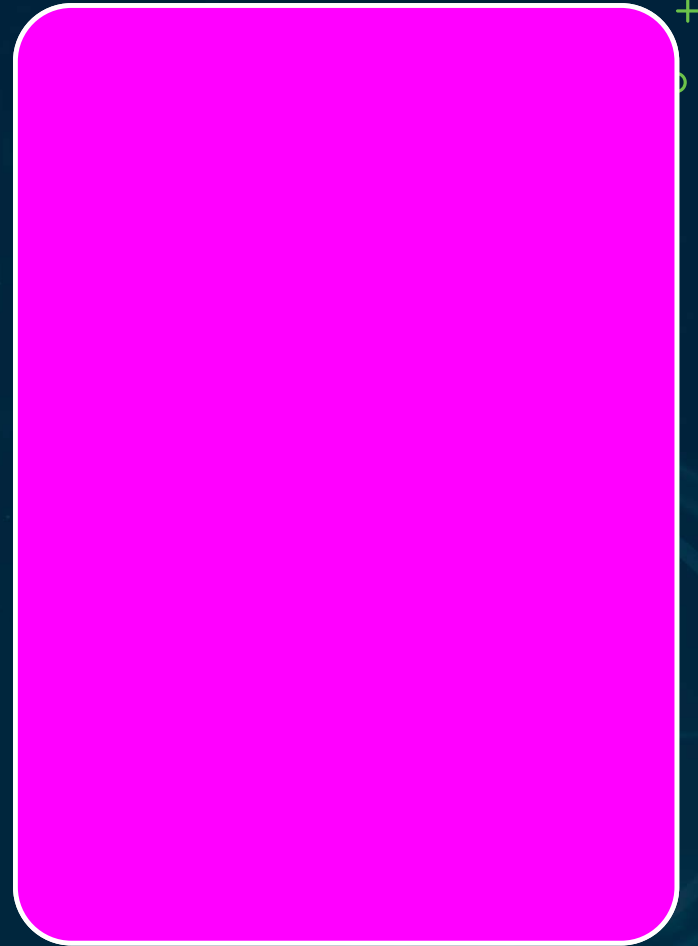
Complete failover to the recovery environment



Full Coverage, Every Layer

Annual full test for tier-1; component test minimum for tier 2/3

Inference-only restoration $\neq$ fully tested

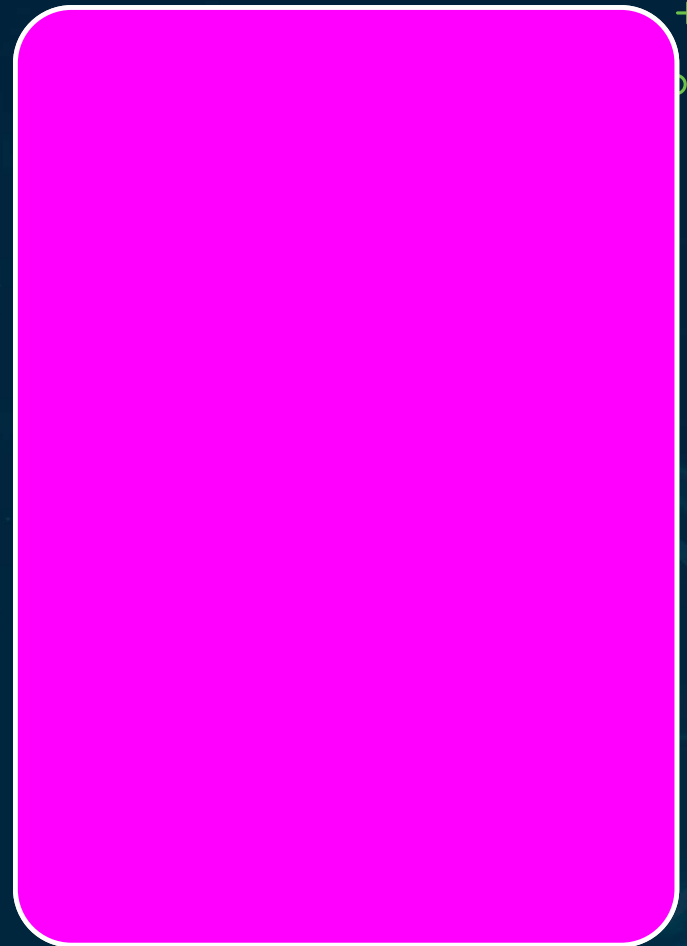


V&V Is the Recovery Gate

DR test isn't complete until the recovered system passes V&V

Document expected vs. actual RTO/RPO per layer

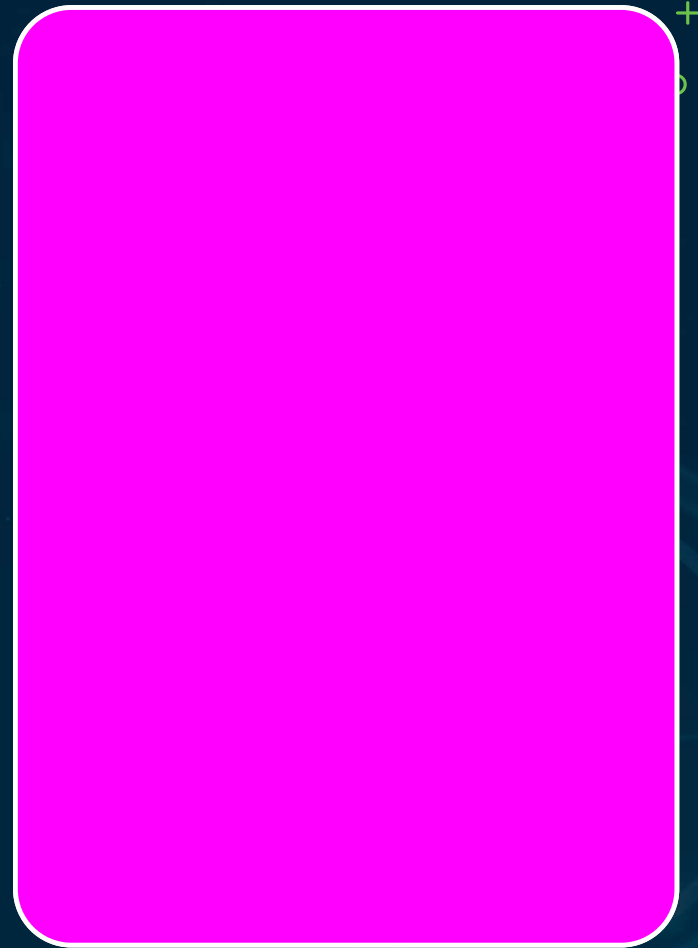
Test records = regulatory evidence



Four DR Failure Patterns

1 DR plan covers infrastructure only

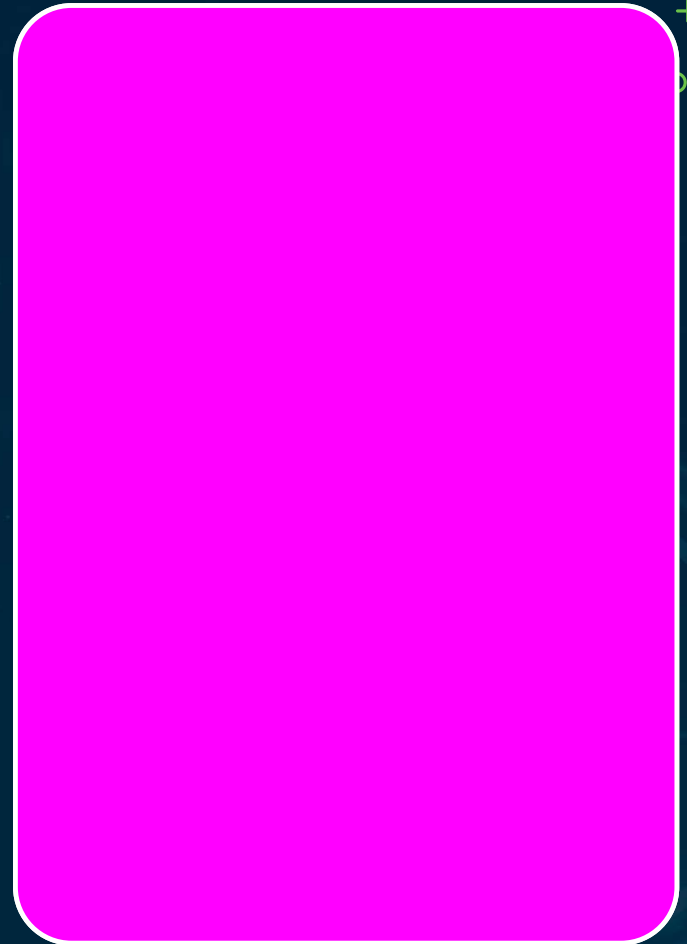
3 of the 4 AI asset layers have no DR coverage



Failures 2–3

2 RTO not achievable with the architecture — e.g., 2-hr RTO on cold standby (needs 4–8 hrs)

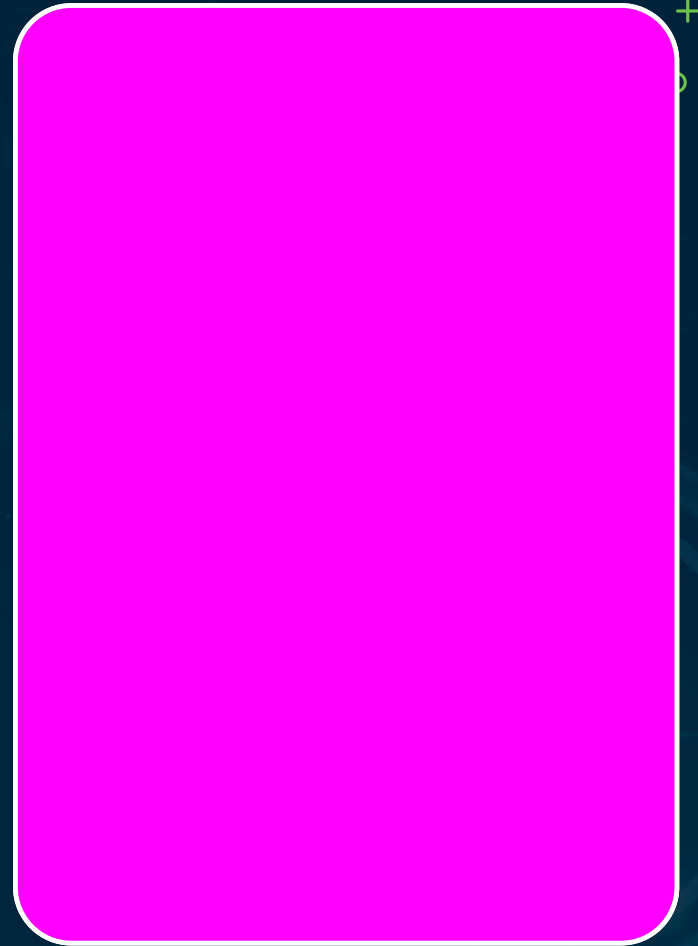
3 DR never tested — stale credentials found mid-event



Failure 4 + The Fix

4 V&V not included in recovery — returned to production unverified

Fix: cover all 4 layers · validate RTO/architecture fit · test annually · V&V gate before production



Know Cold for the Exam

3 architecture tiers

V&V required after recovery, before production

RTO must match the DR architecture

Recap · Module Close

BCP vs. DR distinction

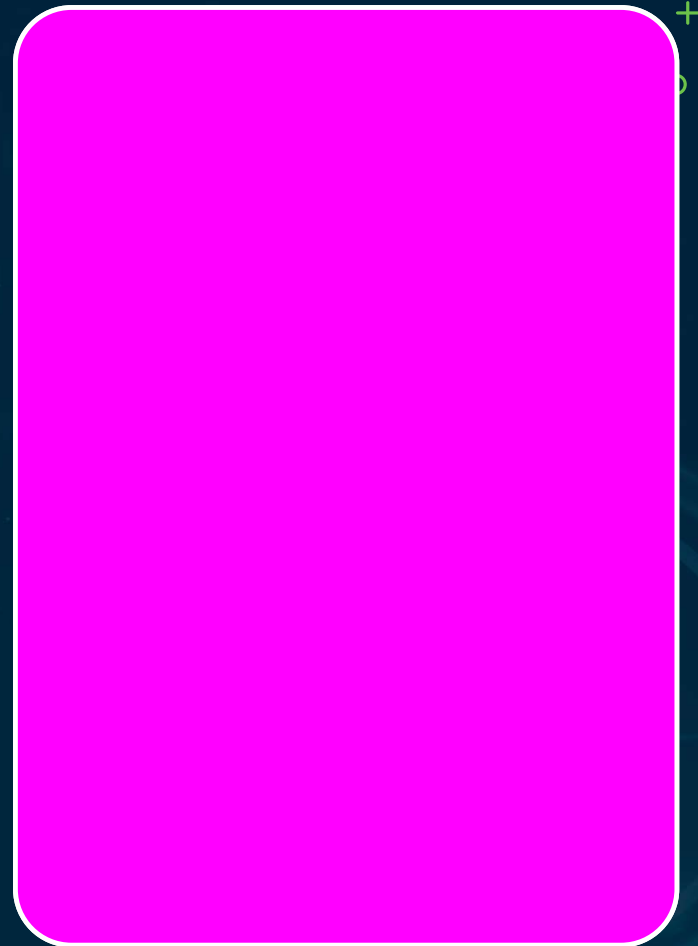
3 architecture tiers

5-section runbook

Testing obligations

V&V as the recovery gate

4 failure patterns



AI Risk Assessment & Impact Analysis

Chapter 04 · Episode 5 — Dr. Michael Solomon

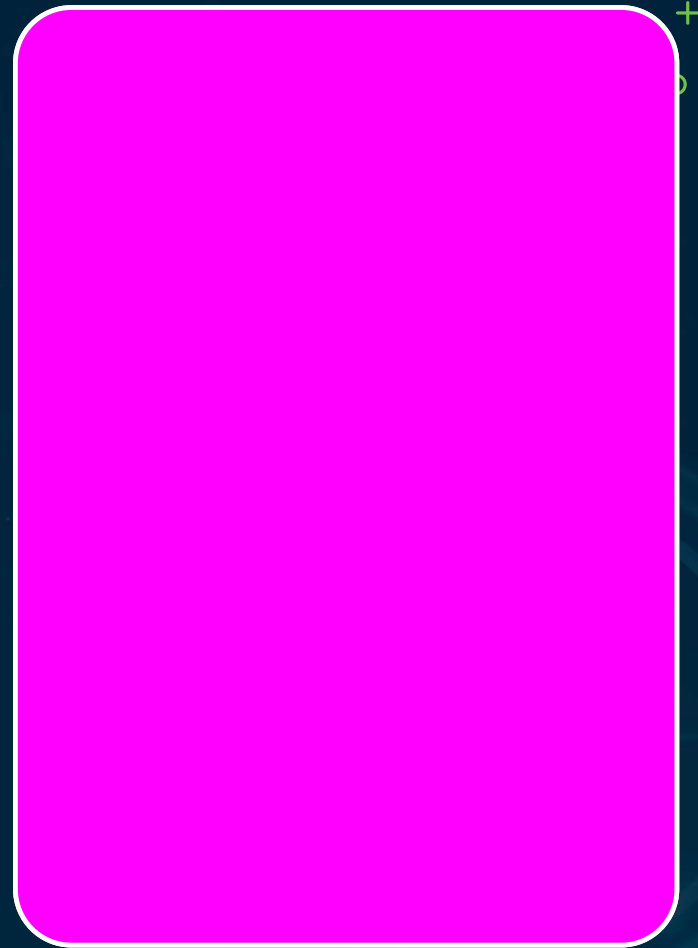


Extends IT Risk Assessment

Adds four AI-specific dimensions

Feeds the risk register

Register → treatment · controls · reporting



Four AI Risk Dimensions



DATA INTEGRITY

Compromised · biased ·
unlicensed?



INFERENCE

Attack surface at the
endpoint?



MODEL BEHAVIOR

Harmful/unfair outputs at
scale?



GOV ADEQUACY

Controls proportionate to
risk?



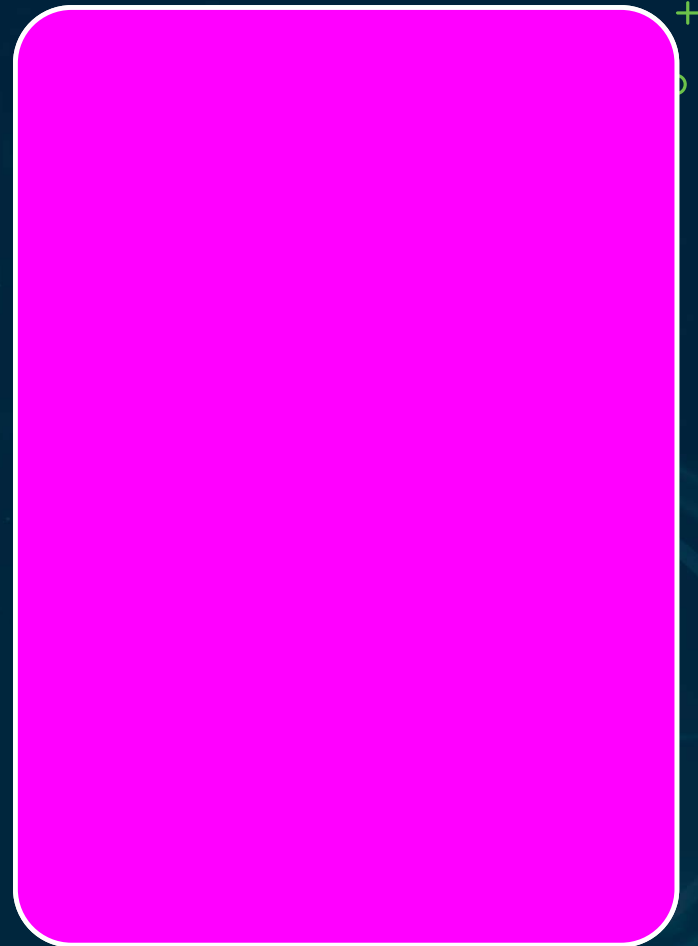
Assessment Triggers

New intake · material change · annual

Incident · new threat intel

Five triggers — not optional

The record = evidence of response



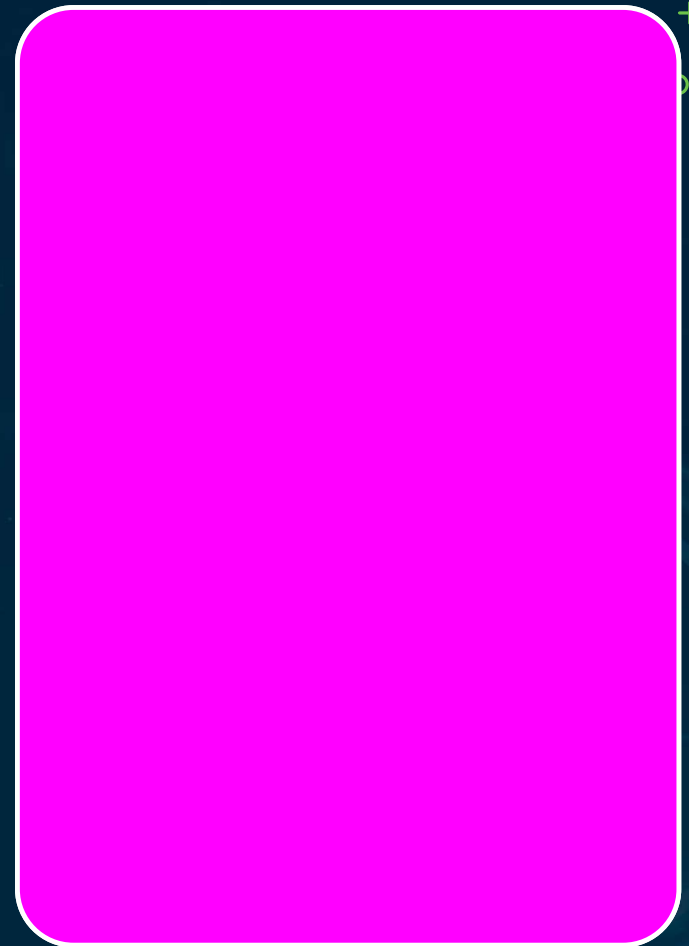
Impact Analysis

Financial · regulatory · reputational · ops

High-risk: EU AI Act + Liability Directive

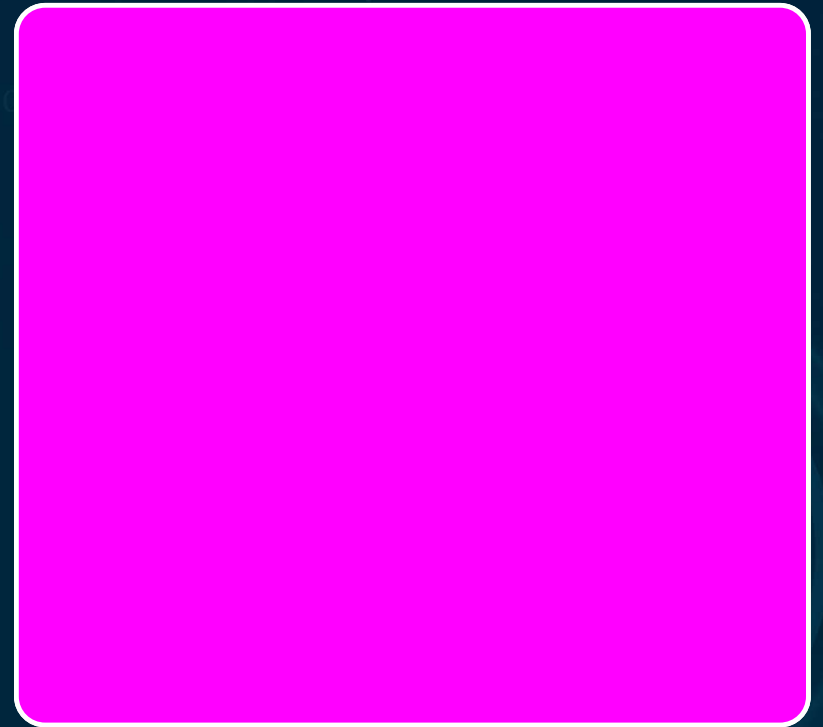
Rebuttable presumption raises exposure

Known + untreated = stronger liability



US Liability Context

No US federal rebuttable presumption
Flows via negligence + products liability
Documented assessment = your defense
Negligence doctrine increasingly used



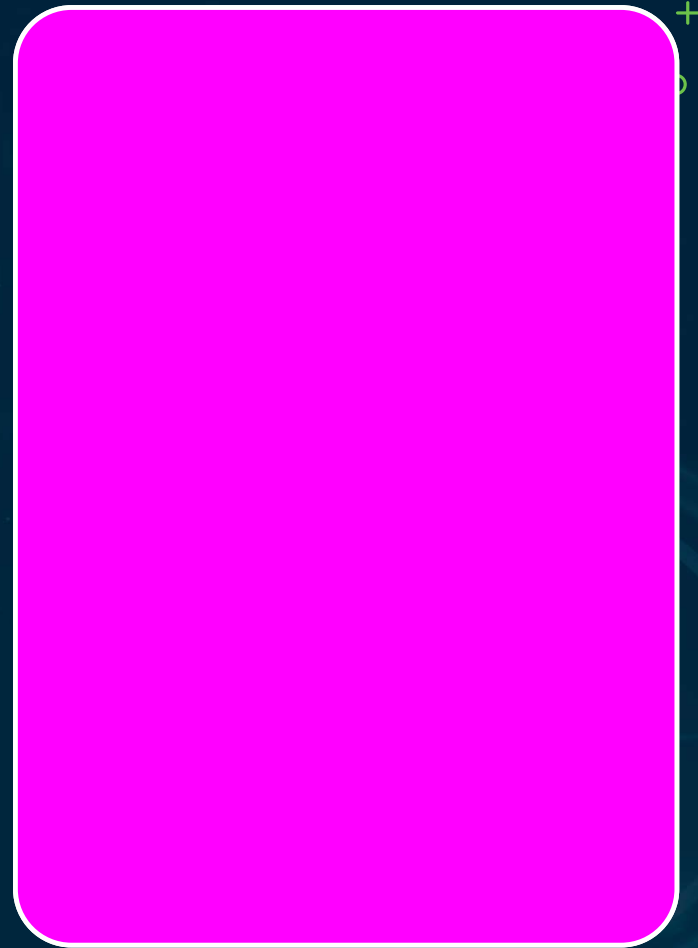
Risk Scoring

Likelihood × impact + AI modifiers

Drift risk (no monitoring) raises it

Supply-chain risk (multi-vendor) raises it

Above appetite → treat; accept = board



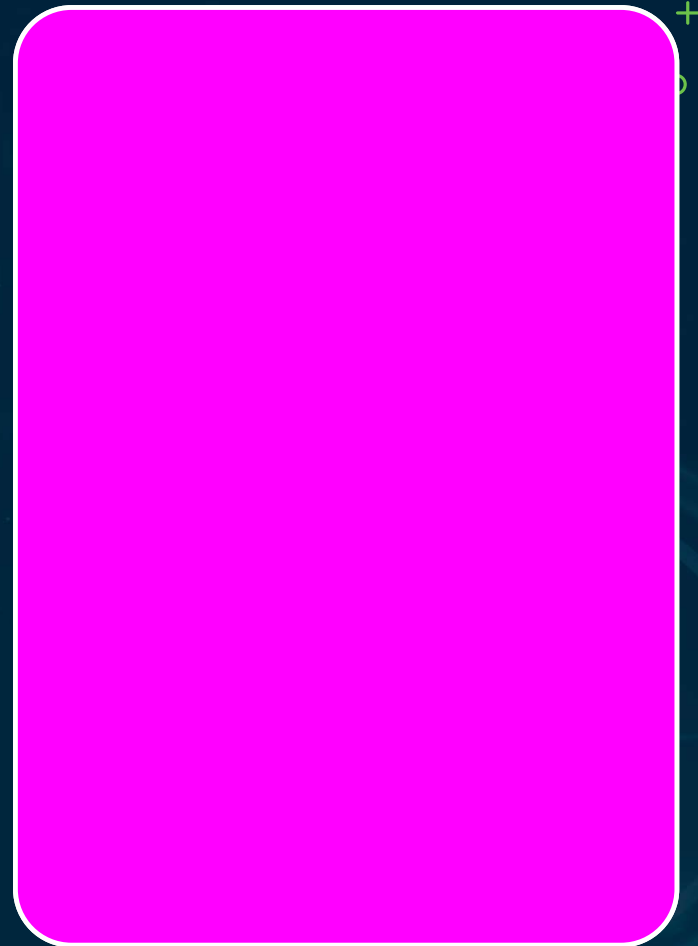
Risk Register Entry

ID · description · system · score

Treatment · owner · review date

Mitigate · transfer · accept · avoid

Every open risk: owner + review date



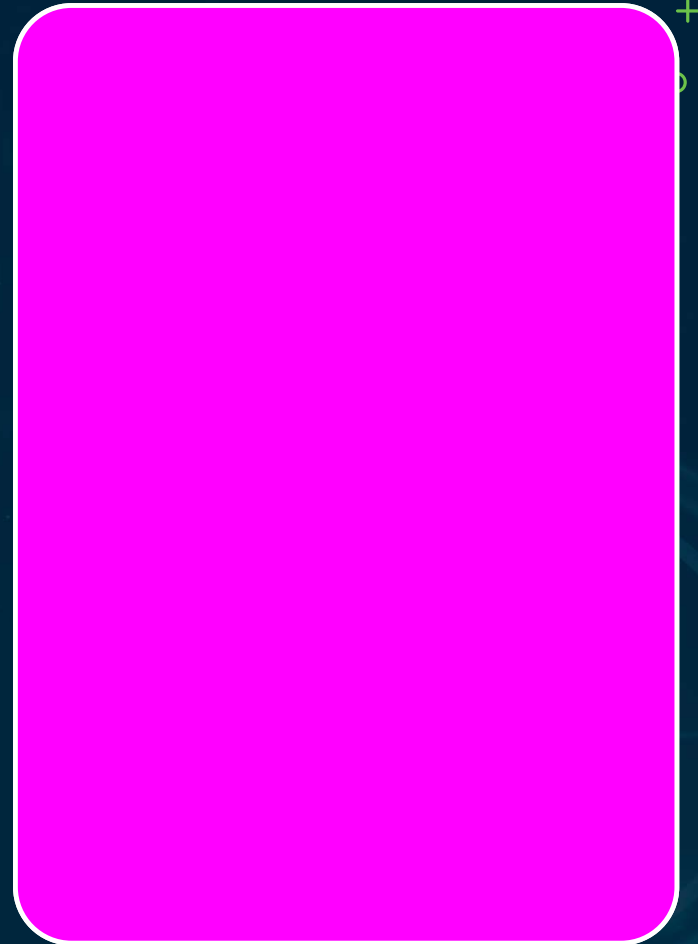
EU AI Act Gate

Impact assessment for Annex III candidates

High-risk → FRIA + conformity activate

Classification change → escalation

A governance gate, not just planning



Four Assessment Failures



NO TRIGGER

Material change, no assessment



NO SIGN-OFF

Above-appetite risk self-accepted



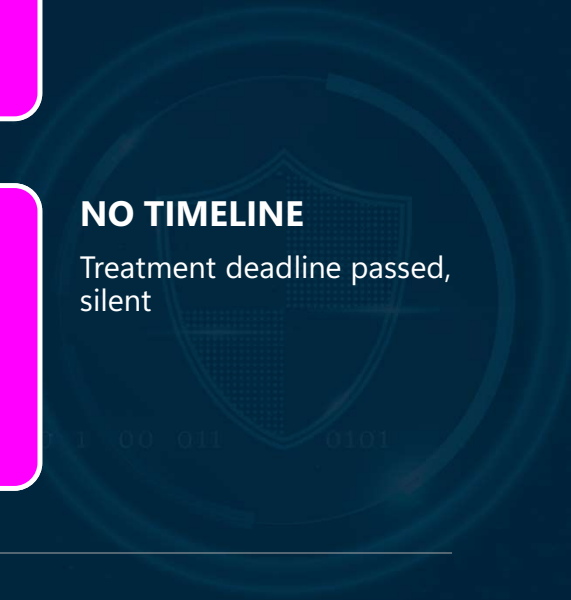
NO REG DIMENSION

EU AI Act impact not assessed



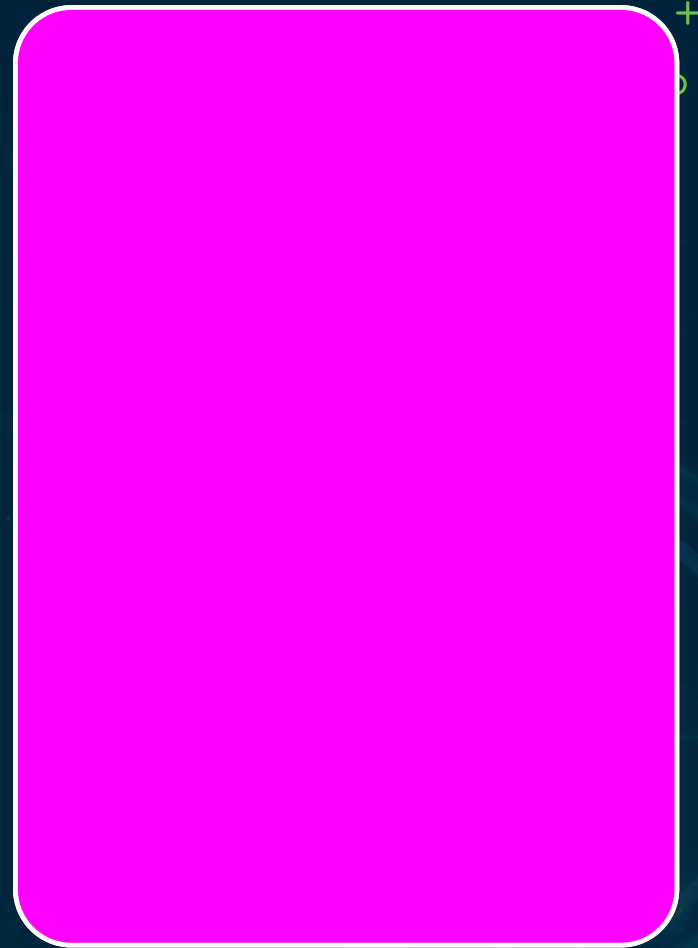
NO TIMELINE

Treatment deadline passed, silent



The Fixes

Triggered assessment for all five events
Impact analysis includes EU AI Act class
Above appetite → board sign-off
Treatment timelines tracked as a KPI



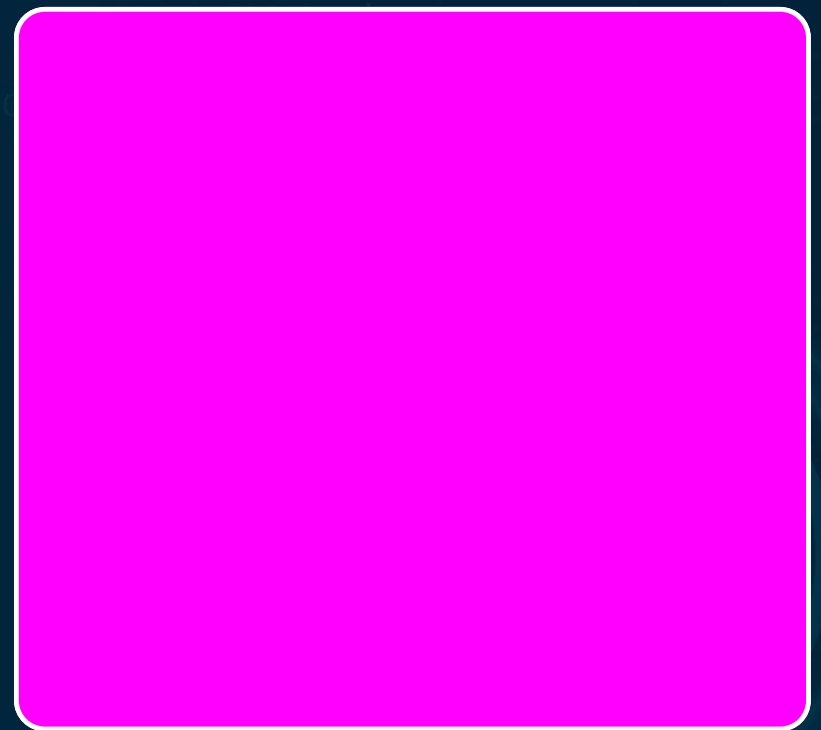
Register = Living Evidence

Five triggers mandatory; class is an output

Risk assessments = regulator evidence

Updated after every assessment + action

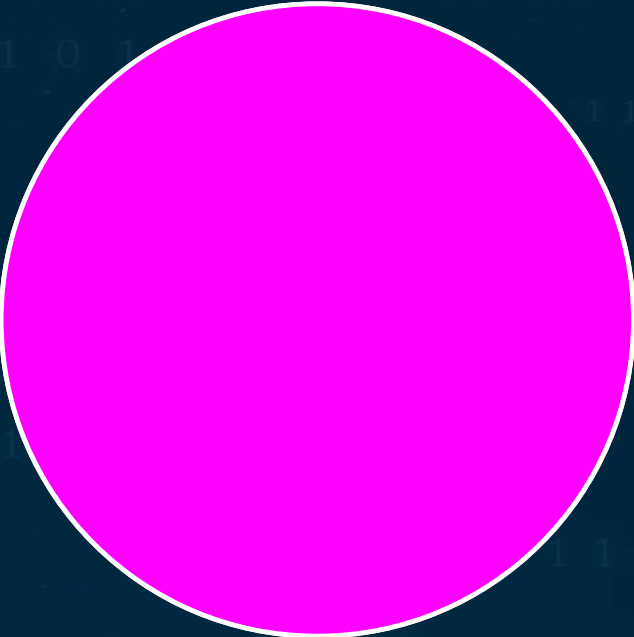
Annual register-adequacy review



Risk Documentation & Treatment

Chapter 04 · Episode 6 — Dr. Michael Solomon





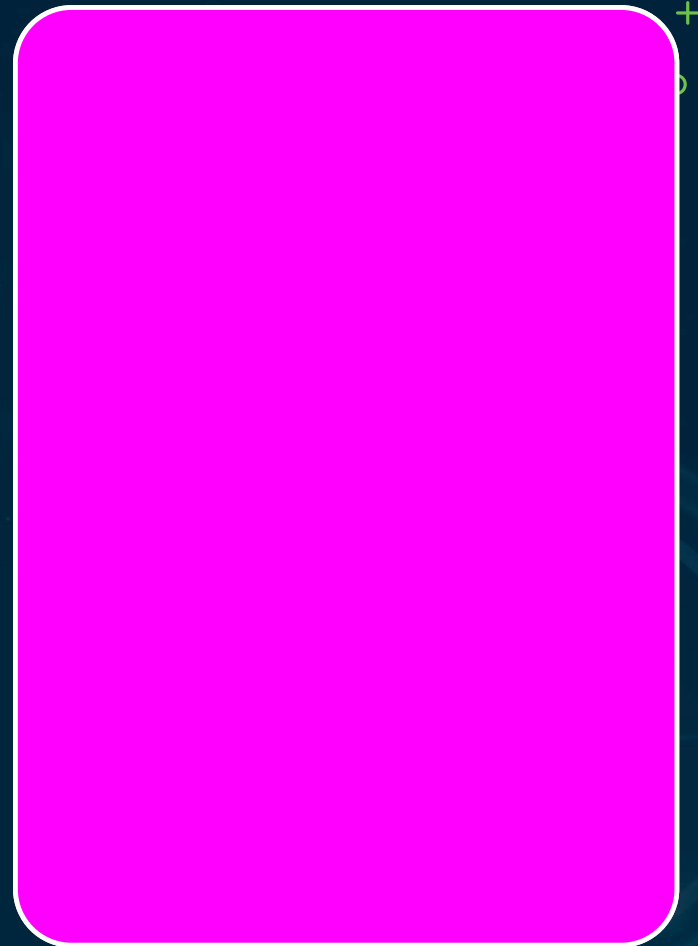
What This Episode Covers

1. 10-field risk register
 2. Register governance
 3. 6-step treatment planning
 4. Risk acceptance & authority levels
 5. 5 governance integrations
 6. Treatment tracking & escalation
 7. 4 documentation failure patterns
- 

The Risk Register Is Central

10 required fields — ID, description, system, category, likelihood, impact, score, decision, owner, review date

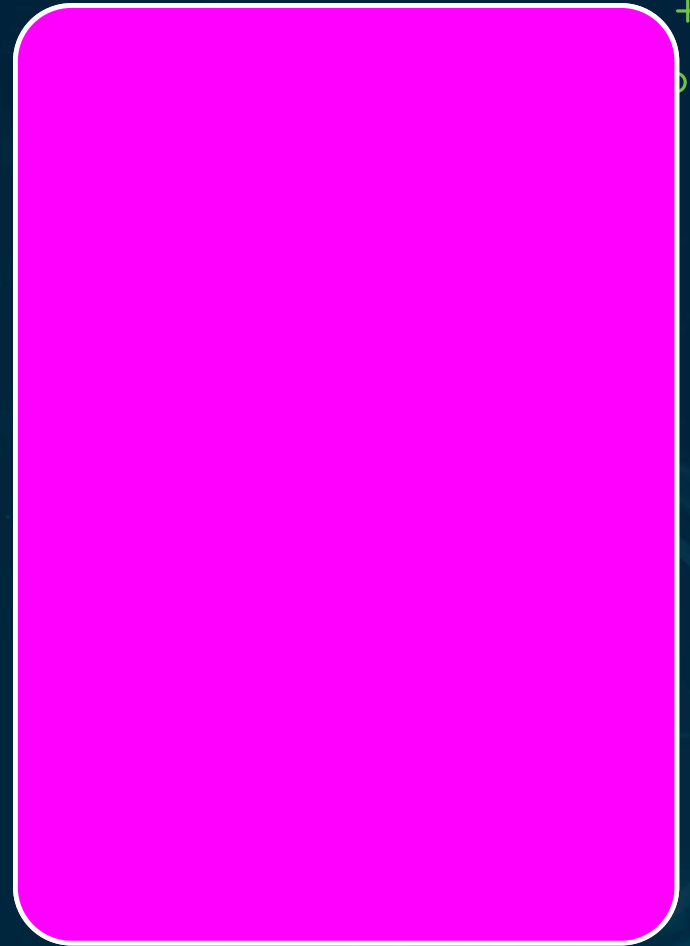
Above-appetite risk can't sit "accepted" without board sign-off



Every Entry Needs an Owner

Risks without owners are documented concerns, not governance risks

A living document — updated after every assessment, treatment, review



Register Governance

Ownership

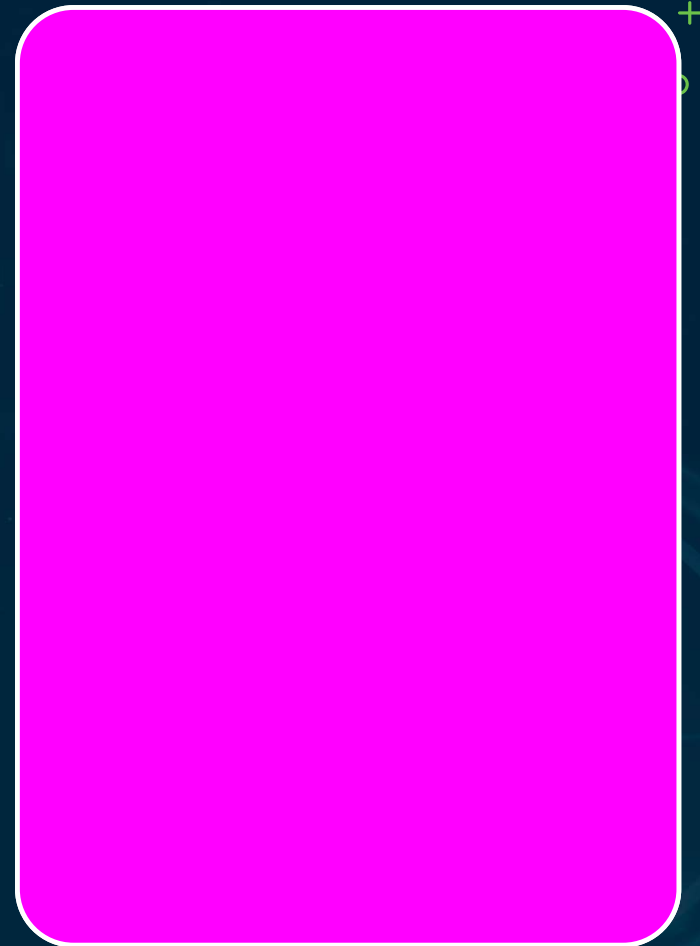
AI risk analyst maintains; AI security lead approves entries

Cadence

New assessment, treatment completion, material change, incident, periodic review

Reporting

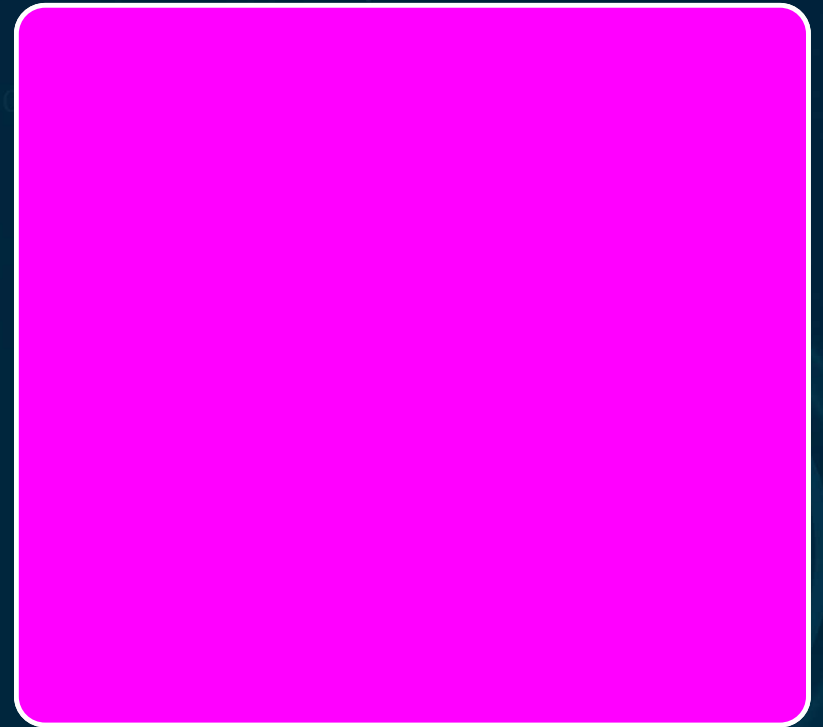
Monthly ops dashboard; quarterly steering summary



ESCALATION

Above-appetite risk open >90 days → steering committee notified

Critical risks → immediate CSO notification



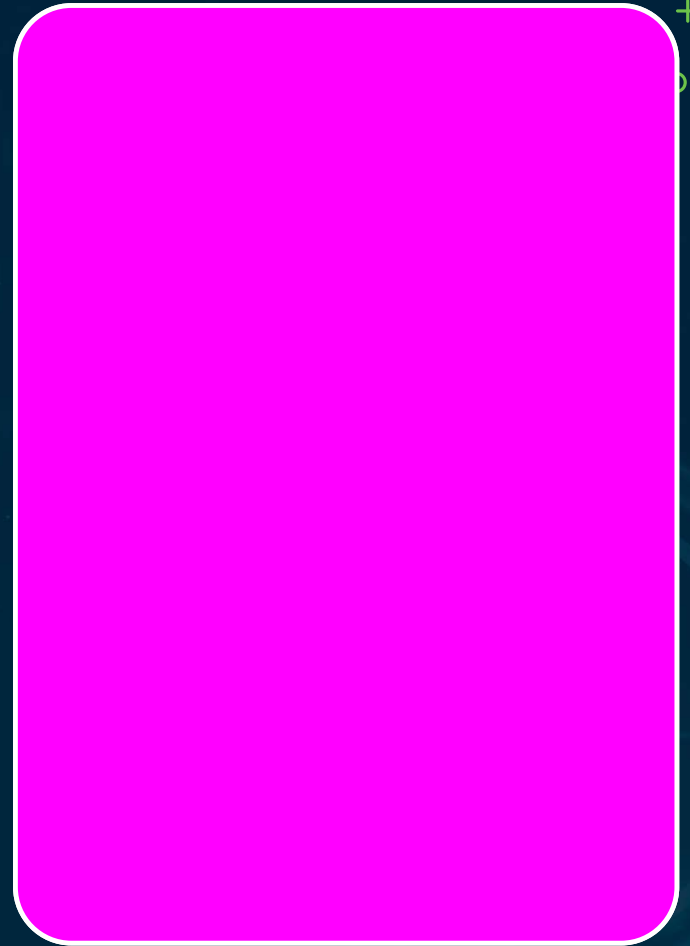
Four Treatment Options

Mitigate — reduce likelihood/impact

Transfer — insurance/contract

Accept — document residual risk

Avoid — decommission



Treatment Plan Elements



1

Option selected +
specific actions

2

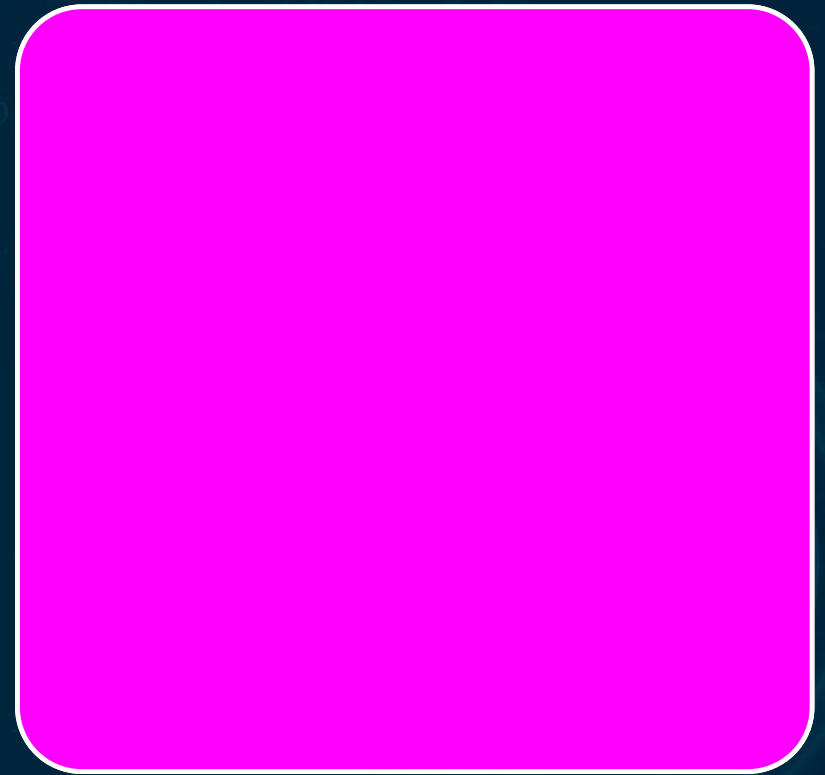
Named owner +
milestone dates

3

Success criteria

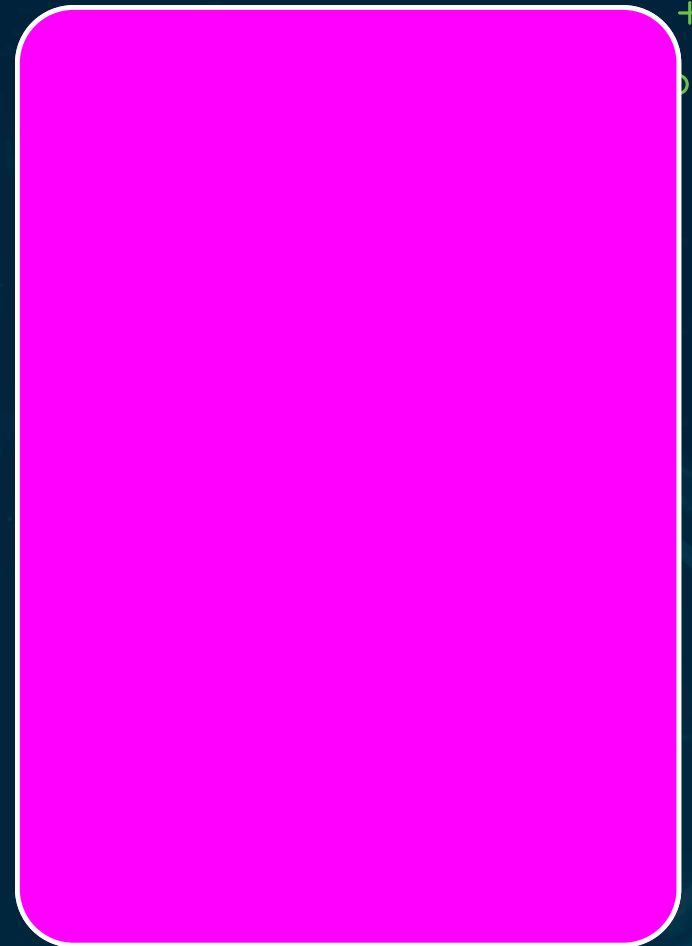
4

Residual risk after
treatment

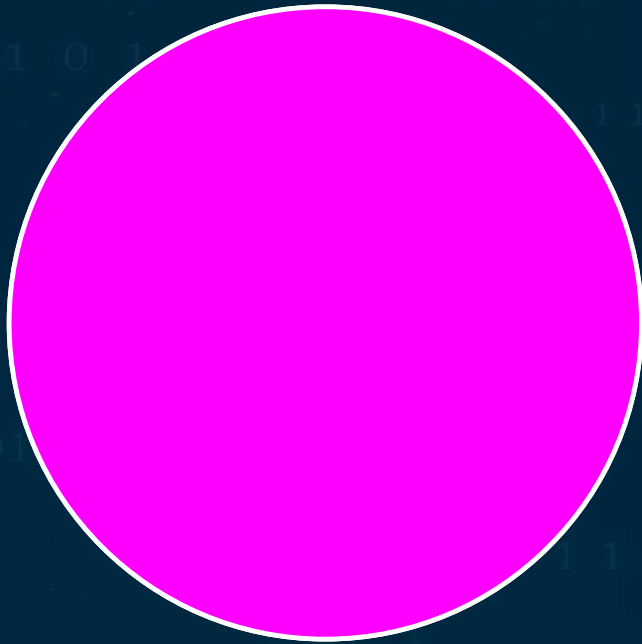


Acceptance Is Not a Default

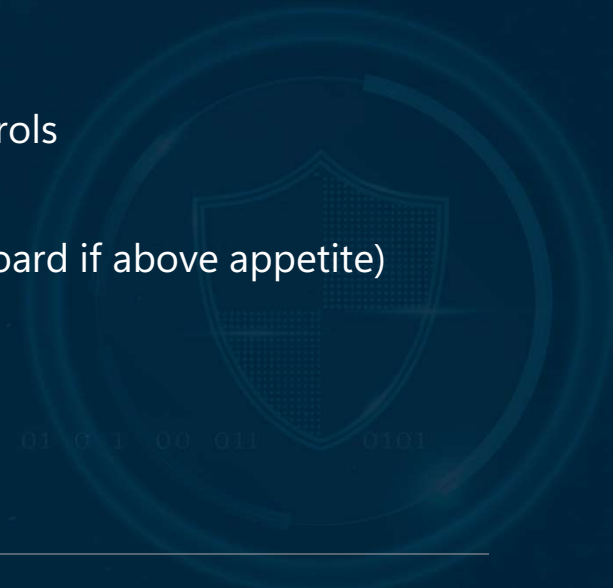
Risk acceptance is a governance decision
Requires a formal acceptance record



Acceptance Record

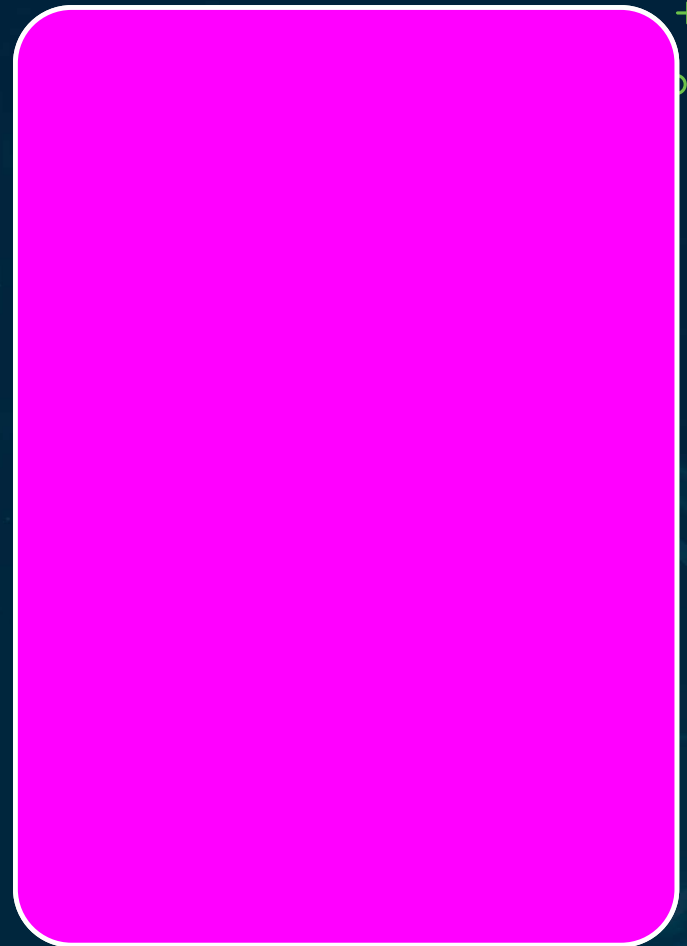


1. Risk ID
2. Current risk score
3. Residual risk after controls
4. Business justification
5. Accepting authority (board if above appetite)
6. Acceptance date
7. Review date



Acceptance Isn't Permanent

- Every accepted risk has a scheduled review date
- Material changes trigger immediate reassessment
- Above-appetite acceptance without board sign-off = governance failure



Five Governance Integrations



1

Asset inventory — every entry references a system ID

2

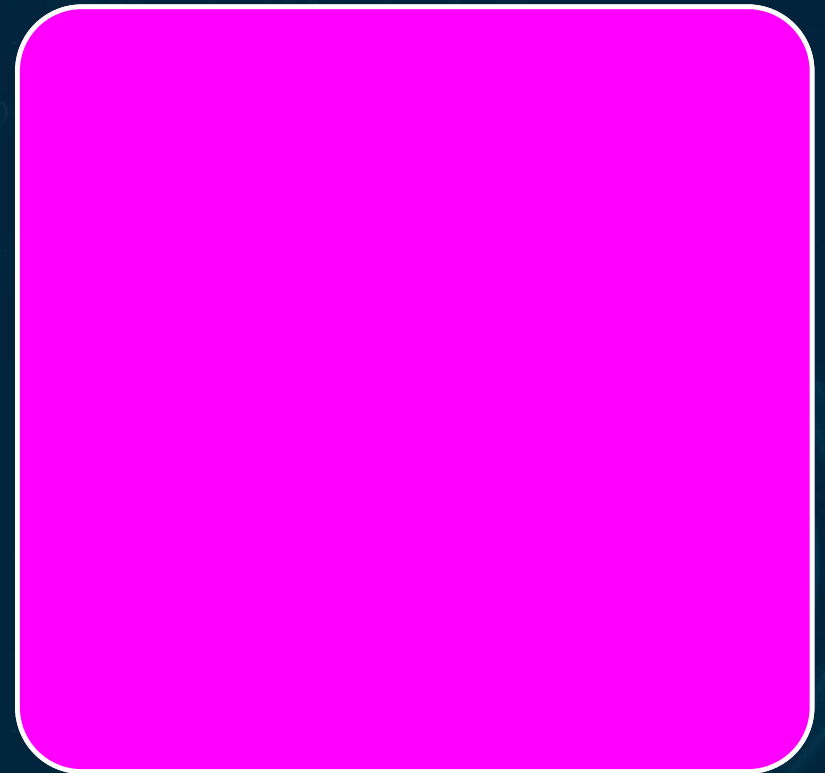
DPIA — privacy risks trigger/update the DPA

3

Control framework — entries drive control selection

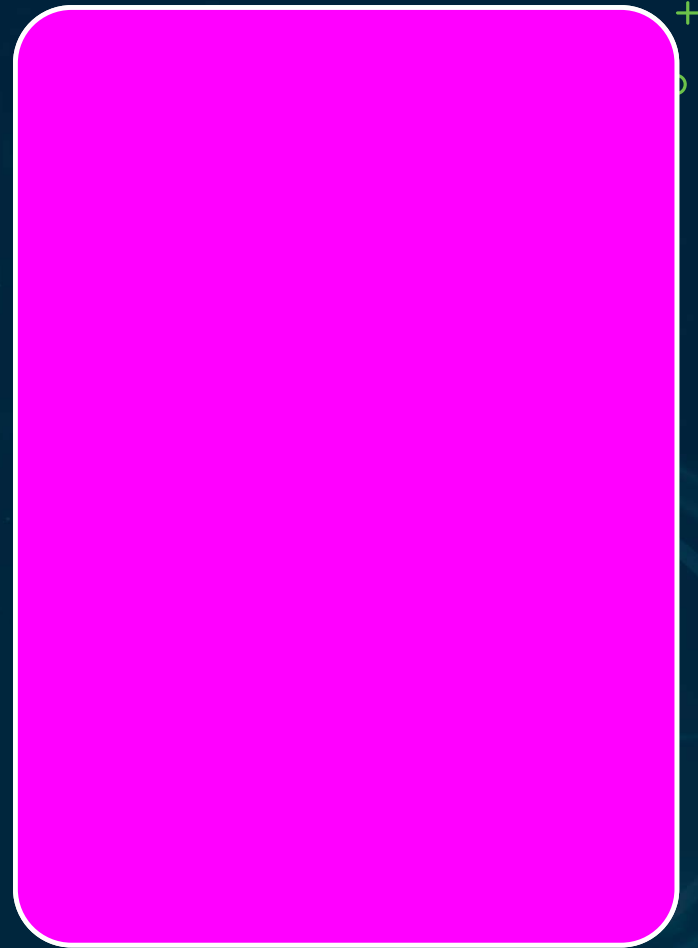
4

Incident register — confirmed incidents update entries



...And the Monitoring Dashboard

5 Above-appetite risks feed the CRE dashboard
The risk register is the connective tissue of the whole program

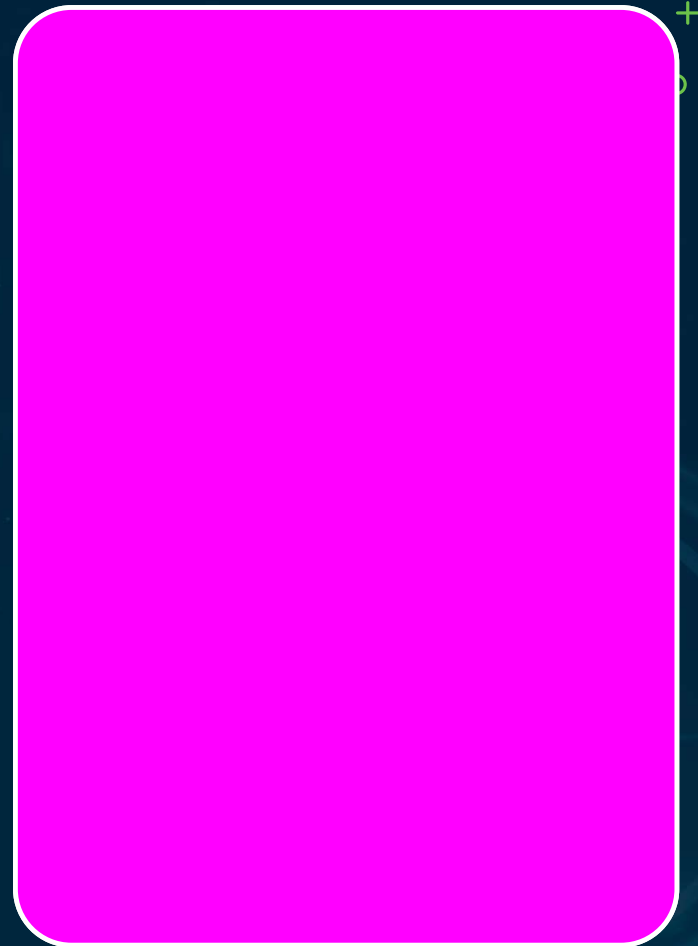


Treatment Plan Tracking

Unique action ID, parent risk ID, owner, completion date, status

Monthly ops report: overdue actions

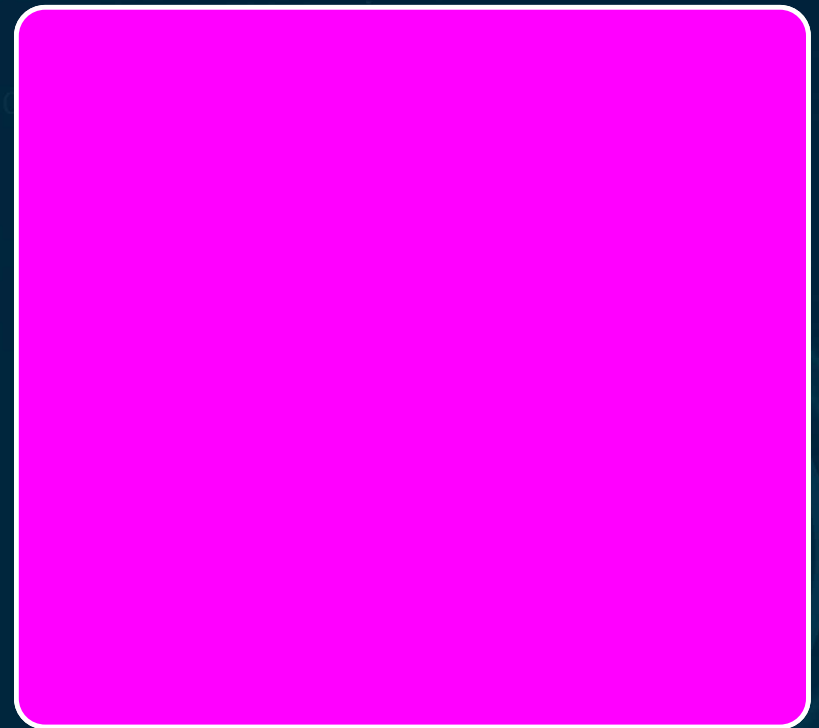
Quarterly steering report: summary by risk tier



MILESTONE SLIP



AI security lead notified at milestone slip
Steering committee notified if overdue + above
appetite

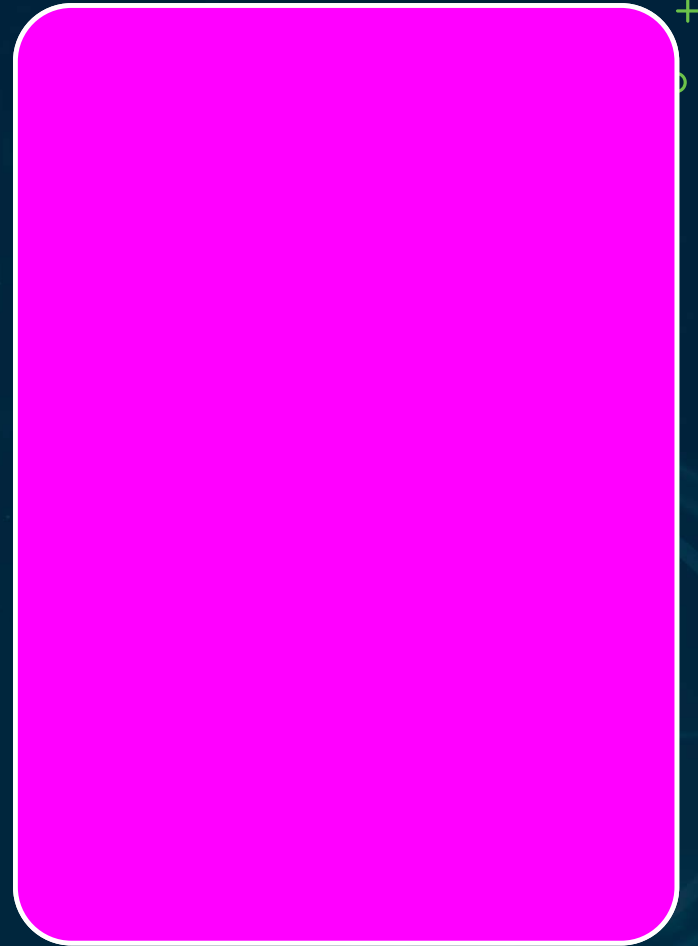


Treatment Closure

Residual risk reassessed against new controls

Within appetite → moves to "treated"

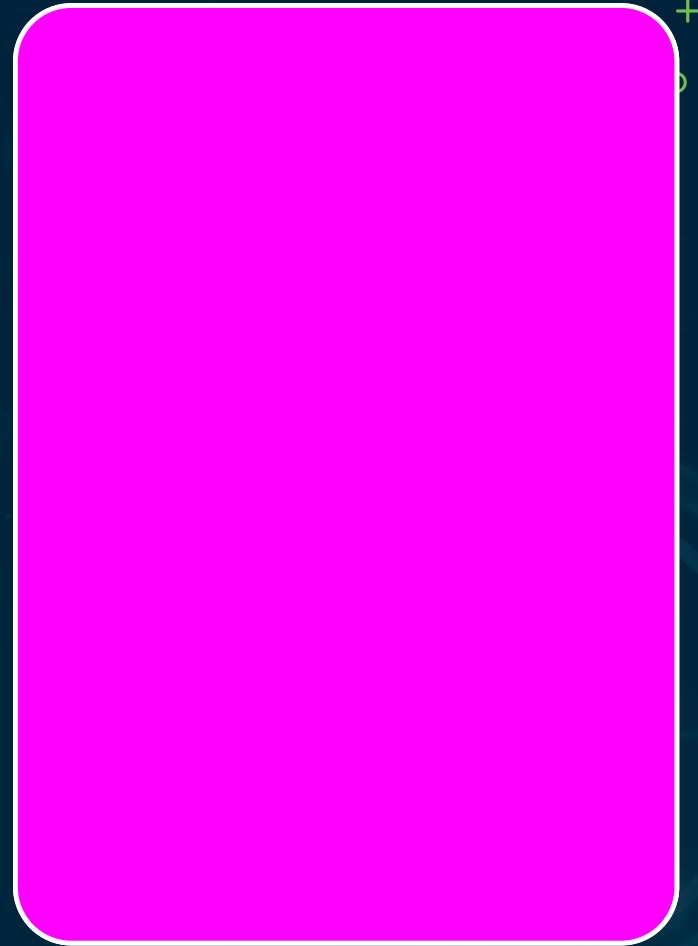
Not within appetite → new treatment cycle begins



Four Regulatory Failures

1 Compliance obligation map not maintained

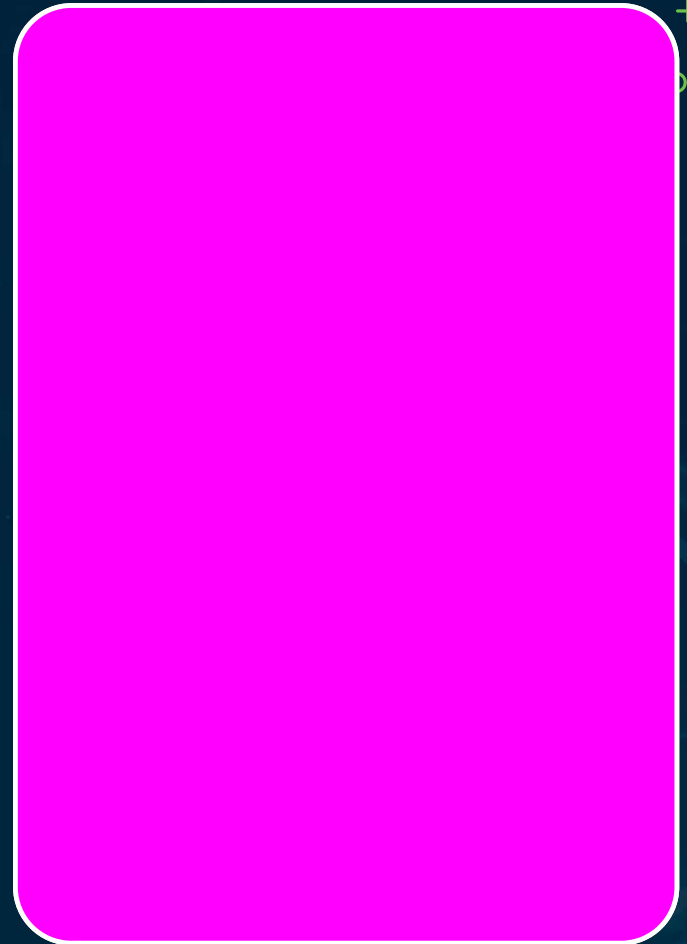
e.g., EU AI Act prohibited-practices list updated, map wasn't



Failures 2–3

2 Deployer obligations assumed transferred by vendor warranty — FRIA/oversight left out of the plan

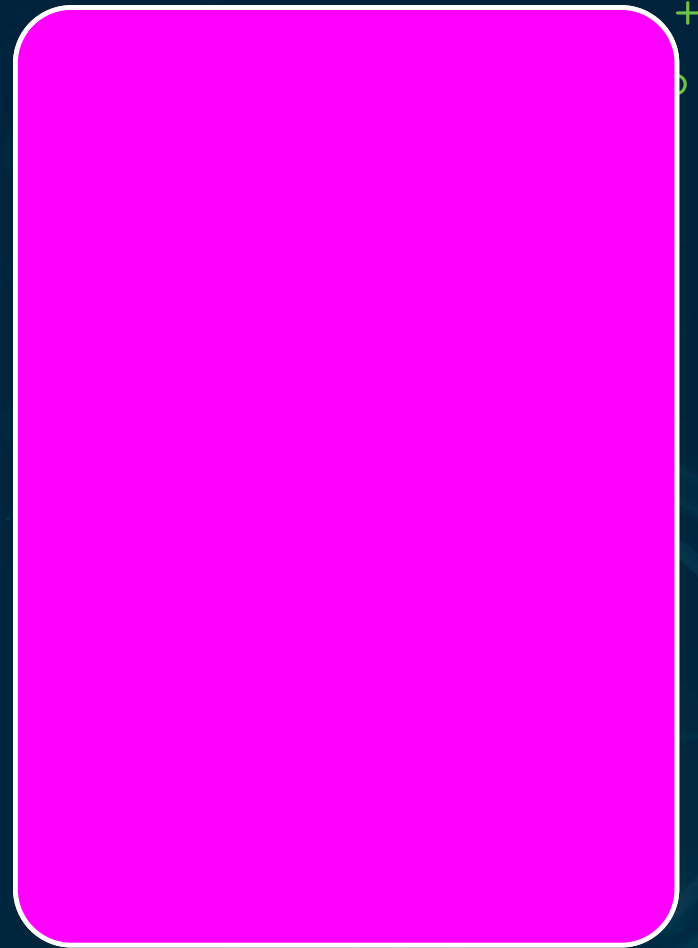
3 GDPR Article 22 not mapped — explanation mechanisms missing from model cards



Failure 4 + The Fix

4 Sector-specific regulation out of scope entirely

Fix: review compliance map annually · document
deployer obligations regardless of warranty · map
Article 22 · include sector regulation

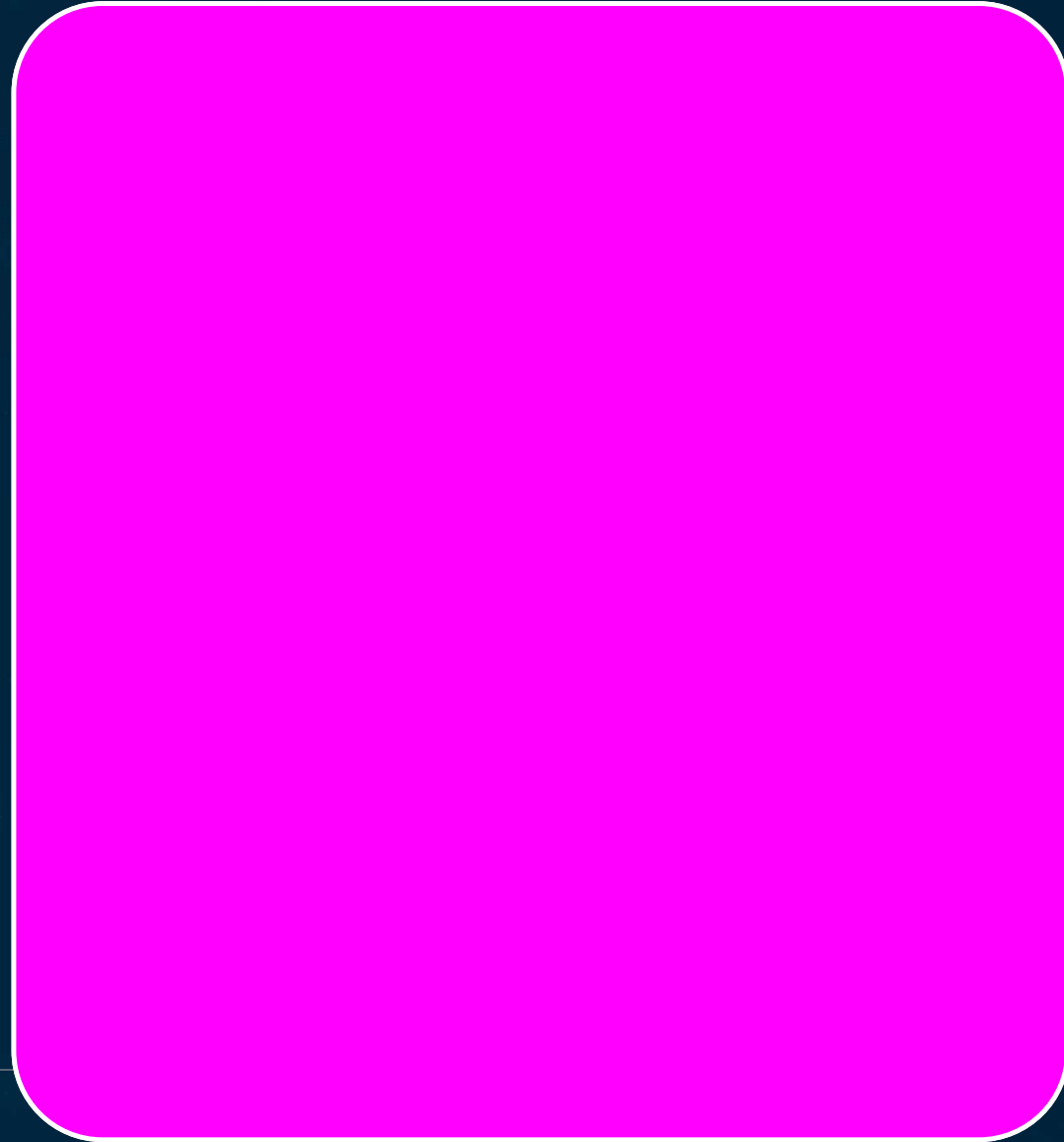


Know Cold for the Exam

Deployer obligations are nontransferable

Article 22 applies to all automated-decision systems

Compliance map must include sector-specific regulation



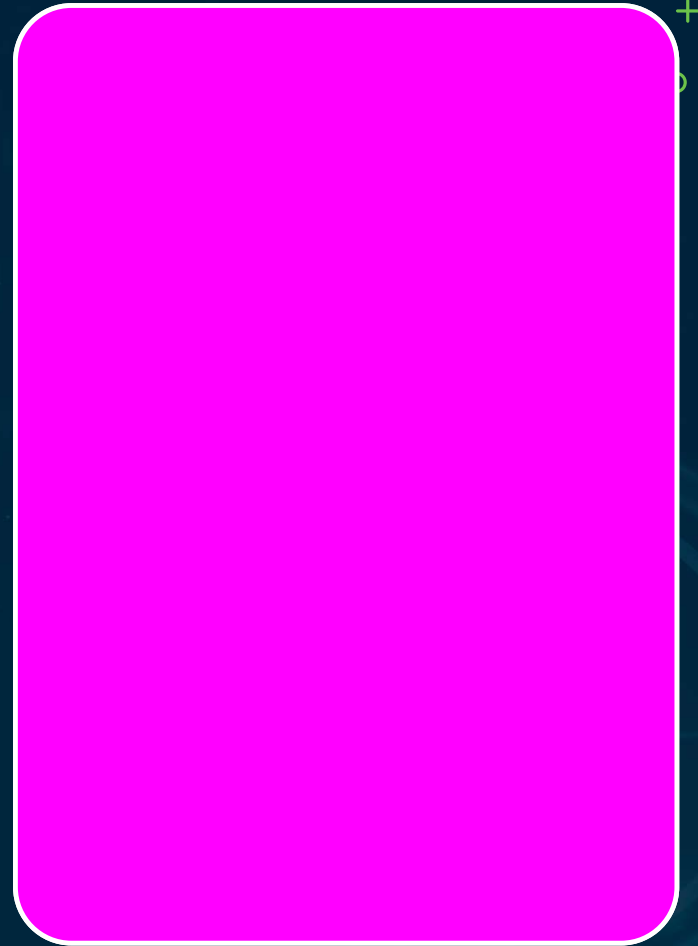
Recap · Module Close

Deployer obligations nontransferable

4 deemed-provider scenarios

Rebuttable presumption needs documented governance

Article 22 applies to automated decisions



Penetration Testing & Vulnerability Testing

Chapter 04 · Episode 7 — Dr. Michael Solomon

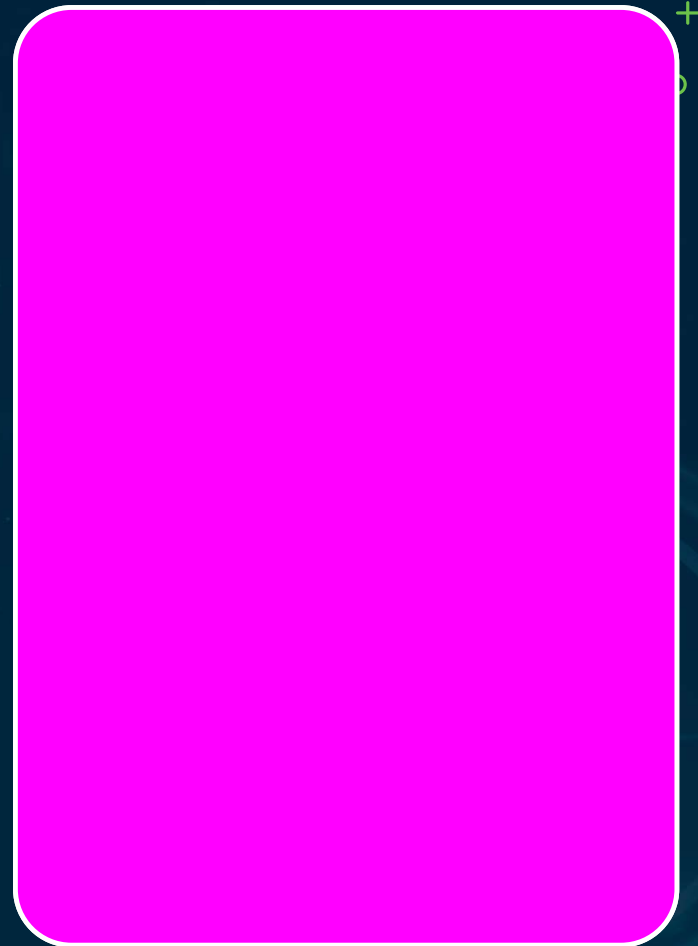


Automated Penetration Testing (CART)

Traditional pen testing is time-constrained

AI = continuous automated red teaming

Probes attack surface as infrastructure changes

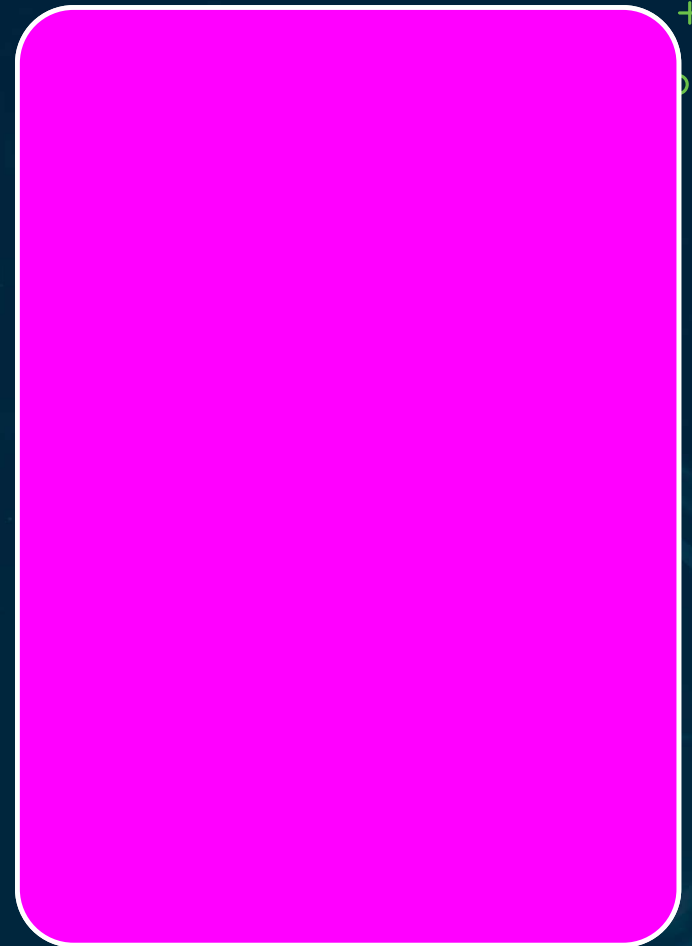


AI-Assisted Reconnaissance

Enumerate attack surface at scale

OSINT: DNS, cert logs, GitHub, job posts, social

Flags external assets not in your inventory

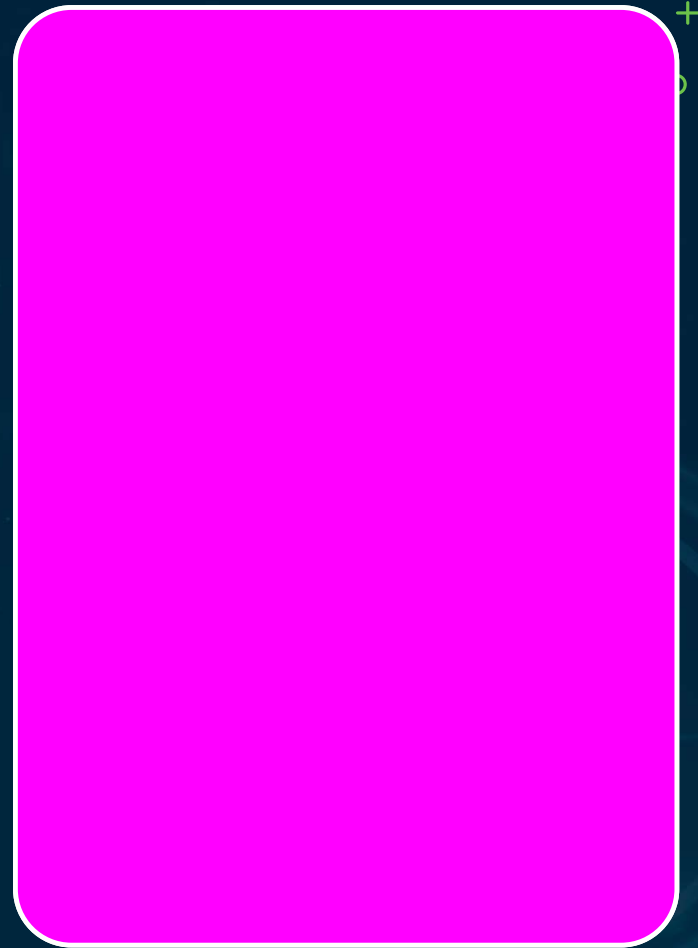


Exploit Discovery & Fuzzing

Analyze services against exploit databases

Intelligent fuzzing — learned input structure

Exploit chaining — low-severity → high-severity path

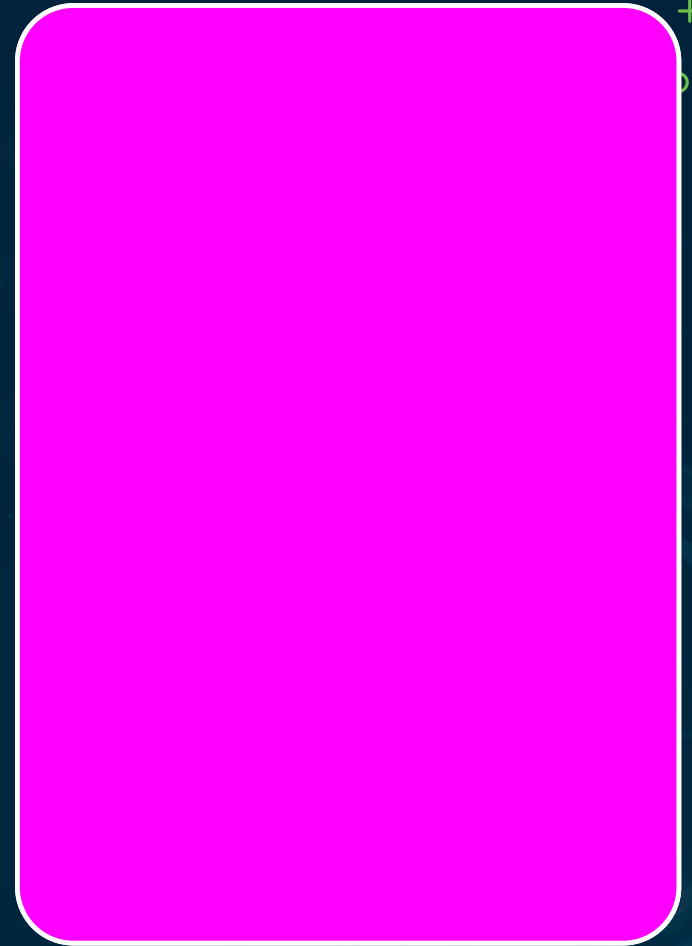


AI-Augmented & Purple Teaming

AI handles volume; humans bring creativity

Broader coverage + deeper quality

Purple teaming validates detection at scale



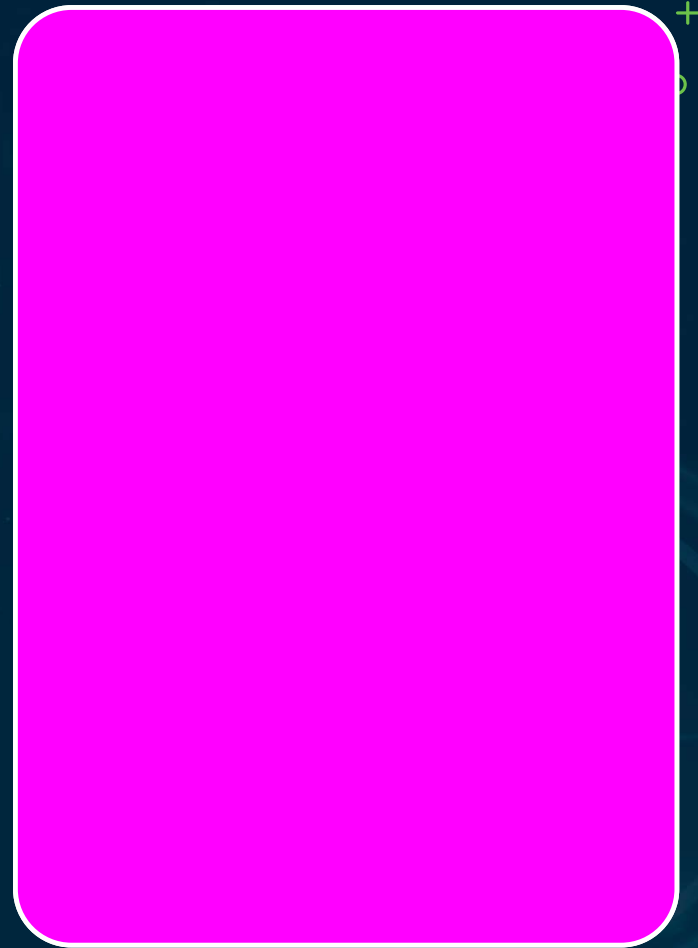
Governance: Scope Authorization

Explicit scope — or it's unauthorized access

Safe harbor + rules of engagement first

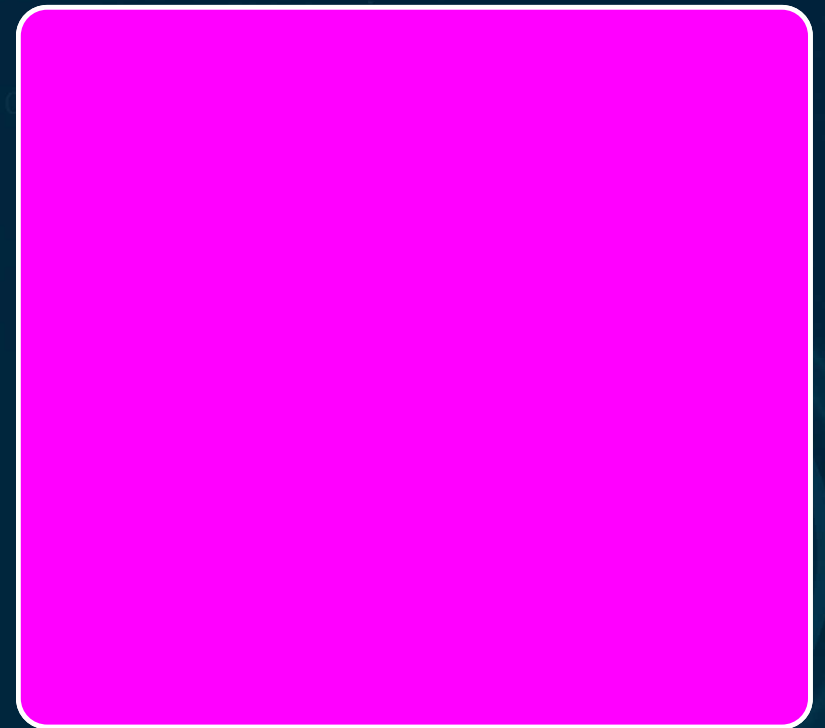
Scoped, time-limited, revoked credentials

Structured findings + human validation



PEN-TEST CADENCE

Tier-1 AI: annual pen test minimum + triggered retest
Reports retained as governance evidence for regulators
A program-plan obligation, not ad hoc

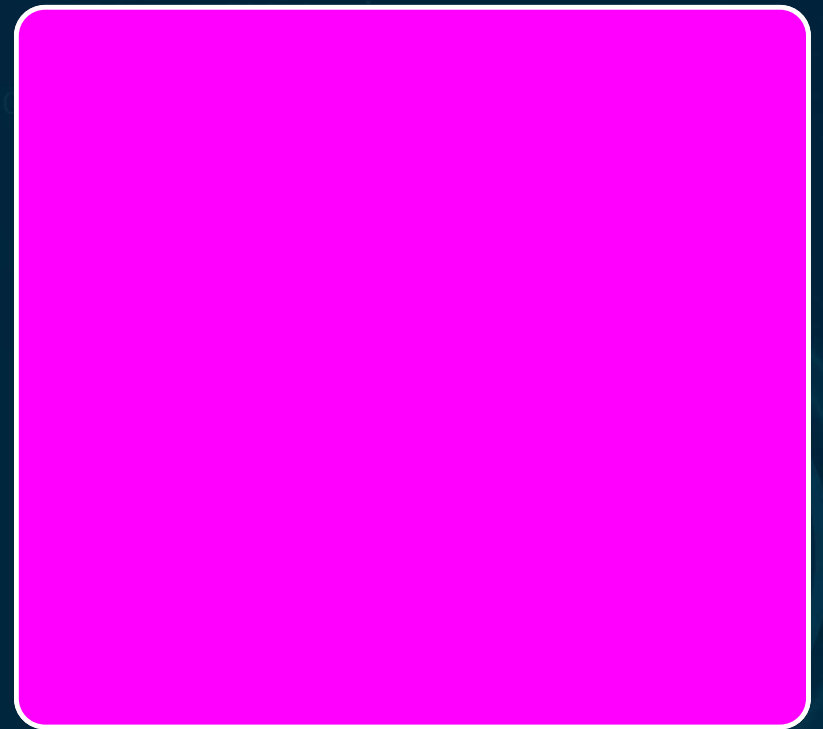


ACCURATE $\neq$ SECURE

Accuracy = average performance on the test distribution

Security = resilience under adversarial pressure

A 97%-accurate IDS can still be evaded

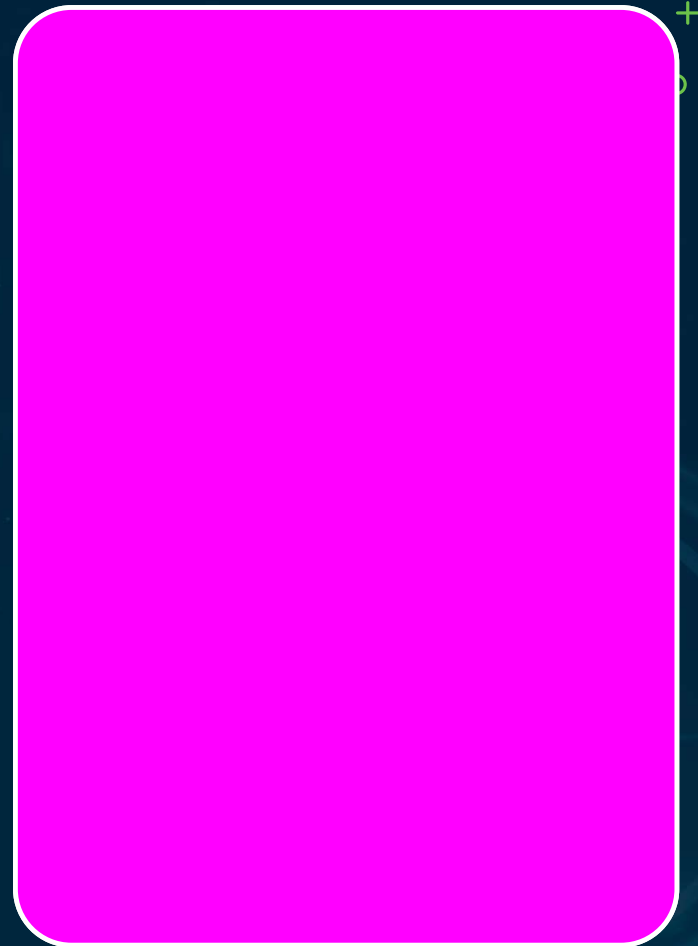


Metrics Must Reflect Asymmetry

A false positive inconveniences; a false negative breaches

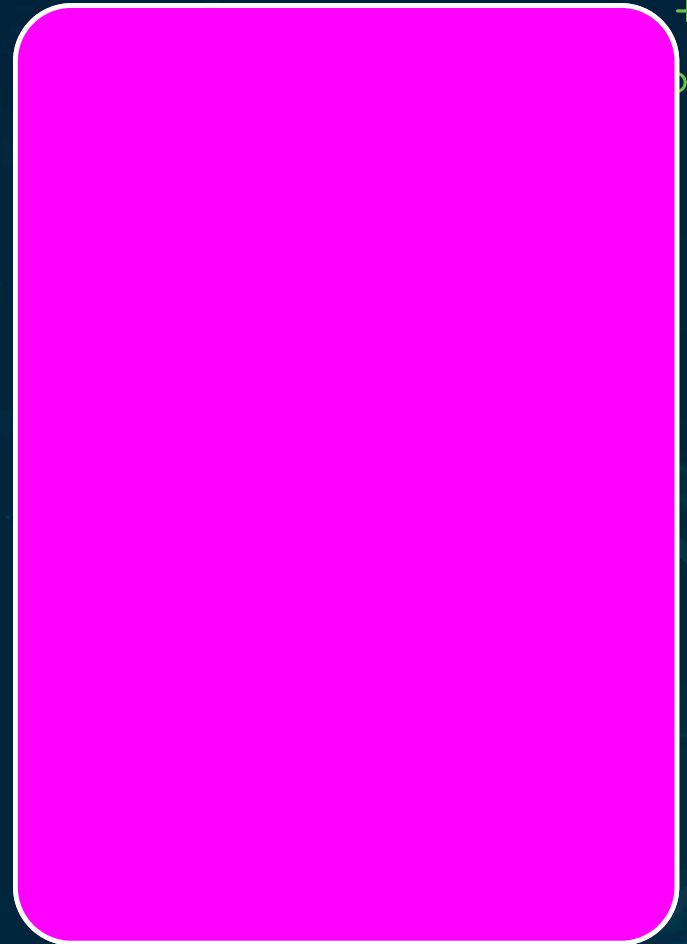
Precision & recall over overall accuracy

FN rate on highest-severity threats = posture



Independent Evaluation Data

- Holdout sets are the only honest baseline
- Cross-validation catches overfitting
- Evaluation bias: clean lab data fails in production



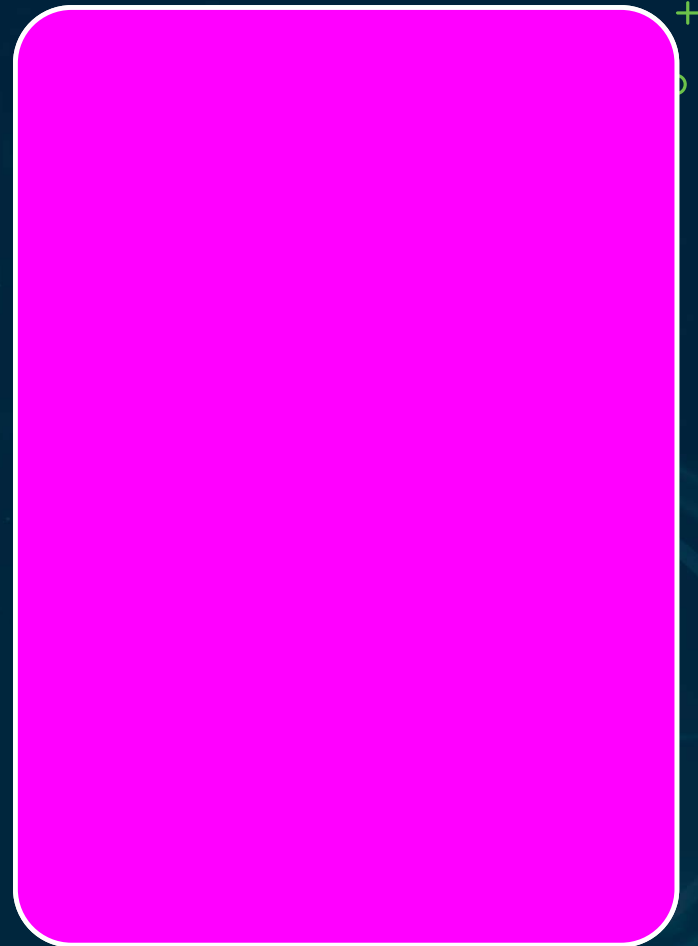
Adversarial Robustness Testing

Adversarial-example testing probes decision boundaries

Stress testing — unusual/extreme/ambiguous inputs

Red teaming — injection, extraction, jailbreak, leakage

Guardrail validation under adversarial pressure

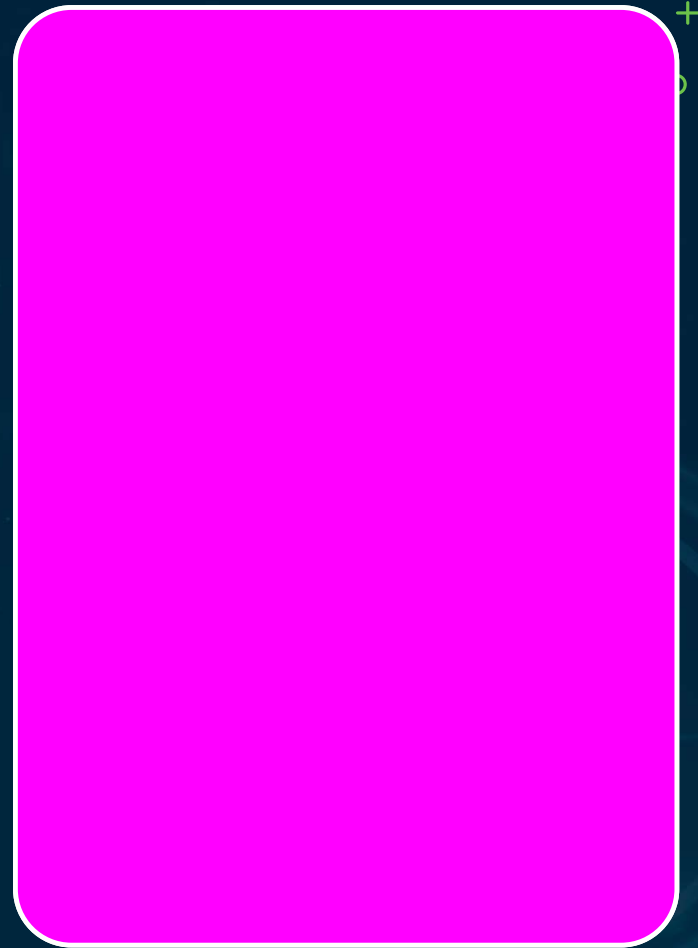


Bias, Fairness & Explainability

Bias is a security vulnerability — an evasion path

Inconsistent fairness is what attackers look for

Explainability enables root-cause analysis

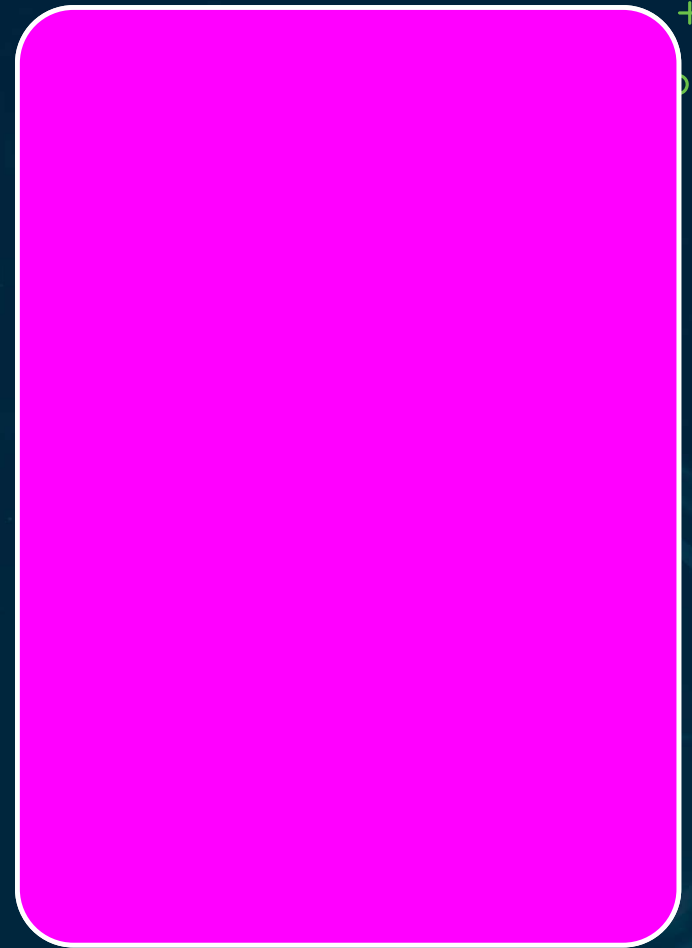


Evaluation Is Continuous

Not a pre-deployment gate — a continuous control

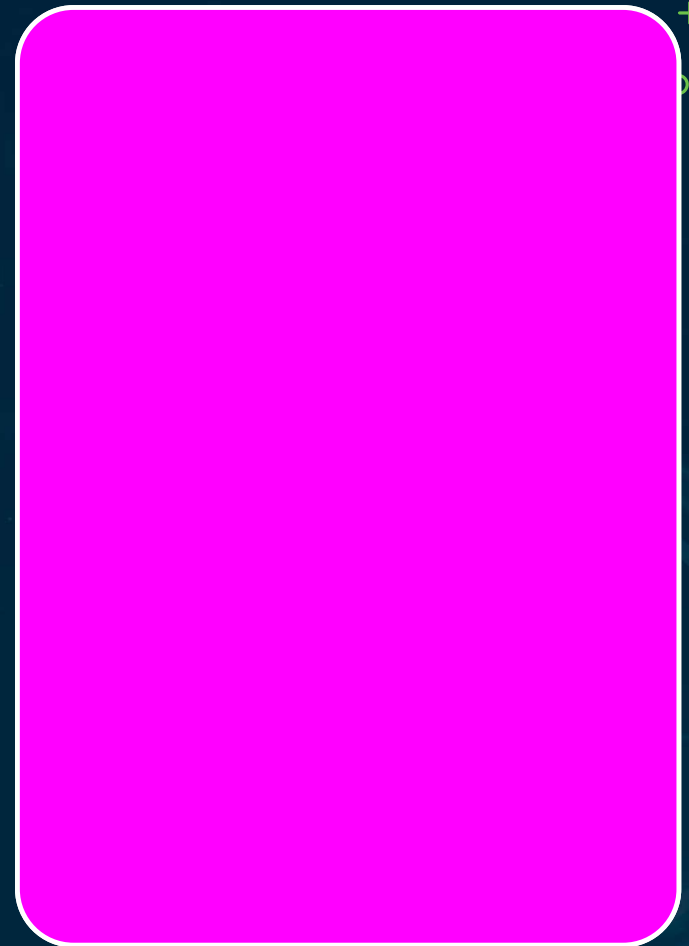
Post-deploy monitoring: drift, confidence, anomalies

Regression test after every optimization



AI Pen Test Covers Four Layers

- Extends standard pen-test methodology to AI
- Must cover all four architectural layers
- Inference-only coverage is incomplete governance
- Results feed the risk register + the TEVV cycle



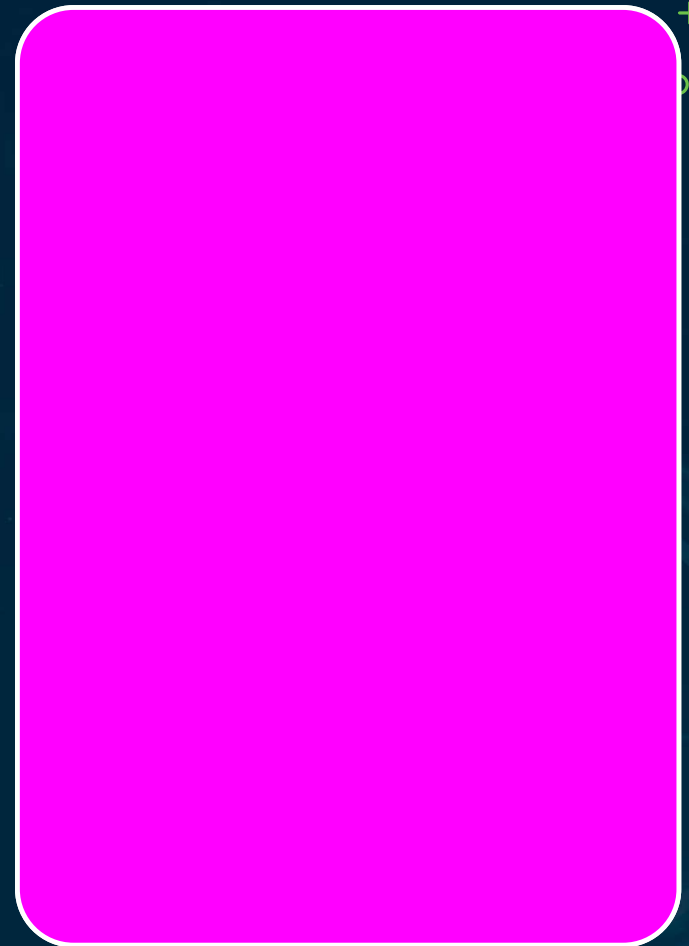
Red Teaming & Adversarial Threats

Chapter 04 · Episode 8 — Dr. Michael Solomon



Threat Modeling for AI

Tells you what to secure, in what order, and why
STRIDE, attack trees, DFDs are the foundation
But AI breaks their deterministic assumptions



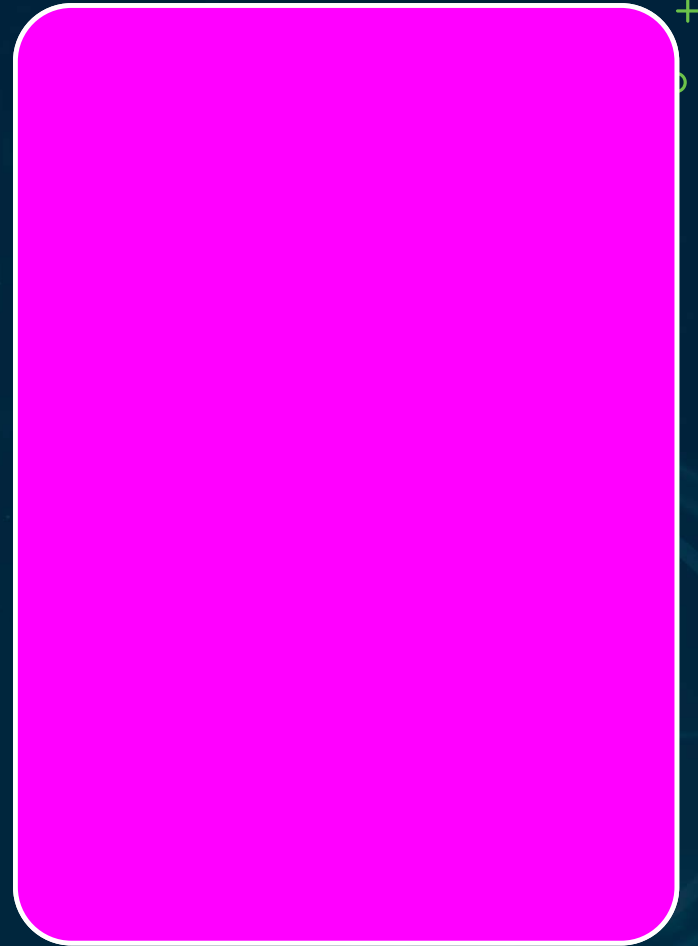
Why AI Threat Modeling Differs

Non-deterministic — same input, different output

Attack surface includes data, not just code

Training-time attacks surface later at inference

The model itself is an IP asset



Four AI Attack Surfaces

1 Data

Poisoning, label manipulation, supply chain

2 Model

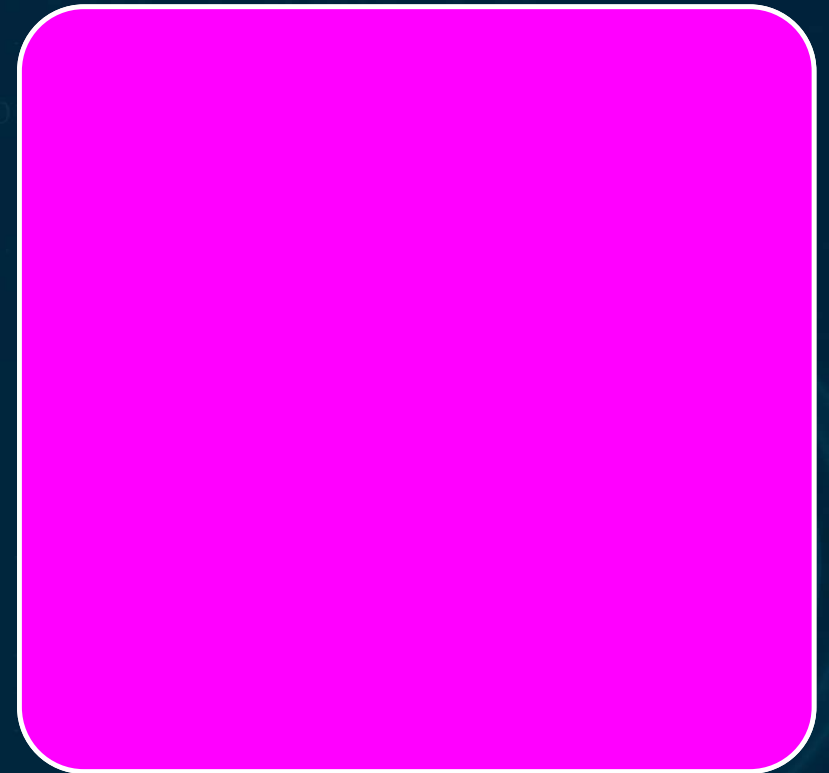
Inversion, membership inference, extraction

3 Inference

Prompt injection, jailbreaking, context

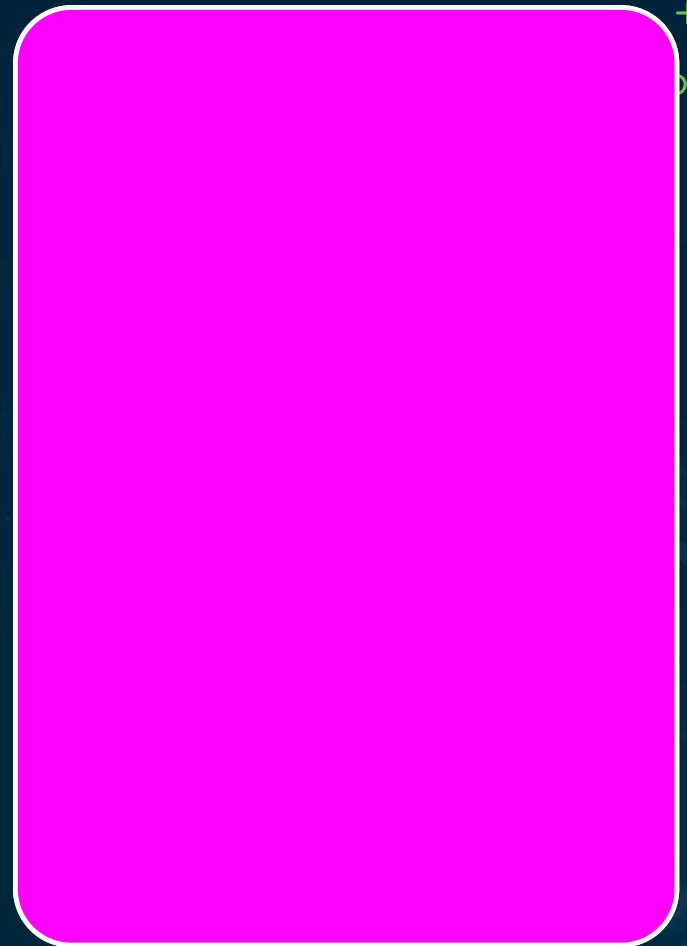
4 Integration

Excessive agency, indirect injection



Six-Step Process · 1–3

- 1 Scope — function, data, connections, consequences
- 2 Decompose — map data flows across all surfaces
- 3 Identify threats per surface (OWASP LLM / ATLAS)

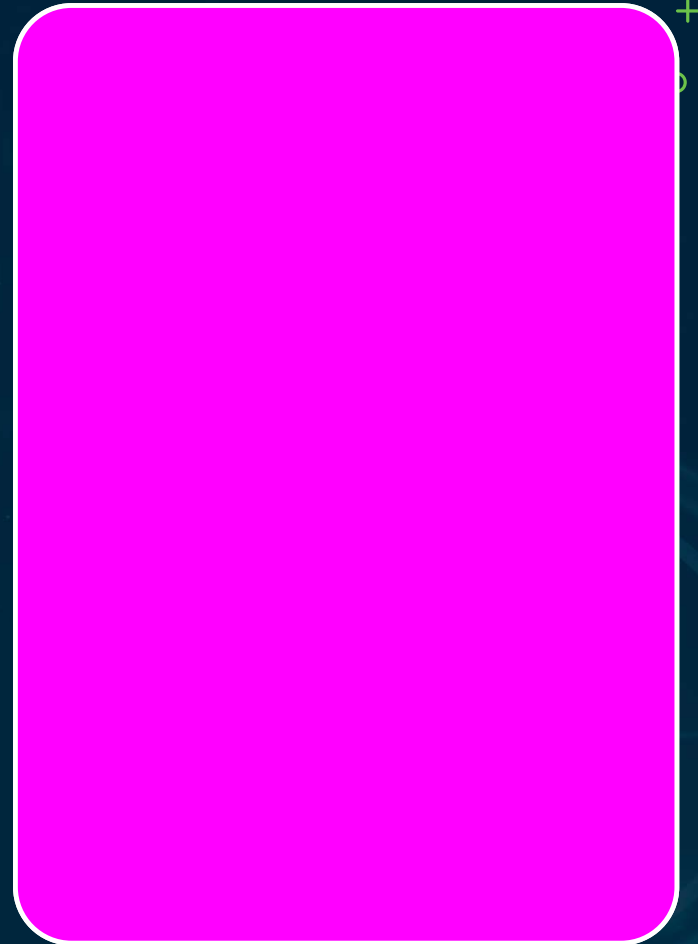


Six-Step Process • 4–6

4 Assess likelihood + impact; prioritize

5 Select controls — each maps to a threat

6 Document + review — a living artifact



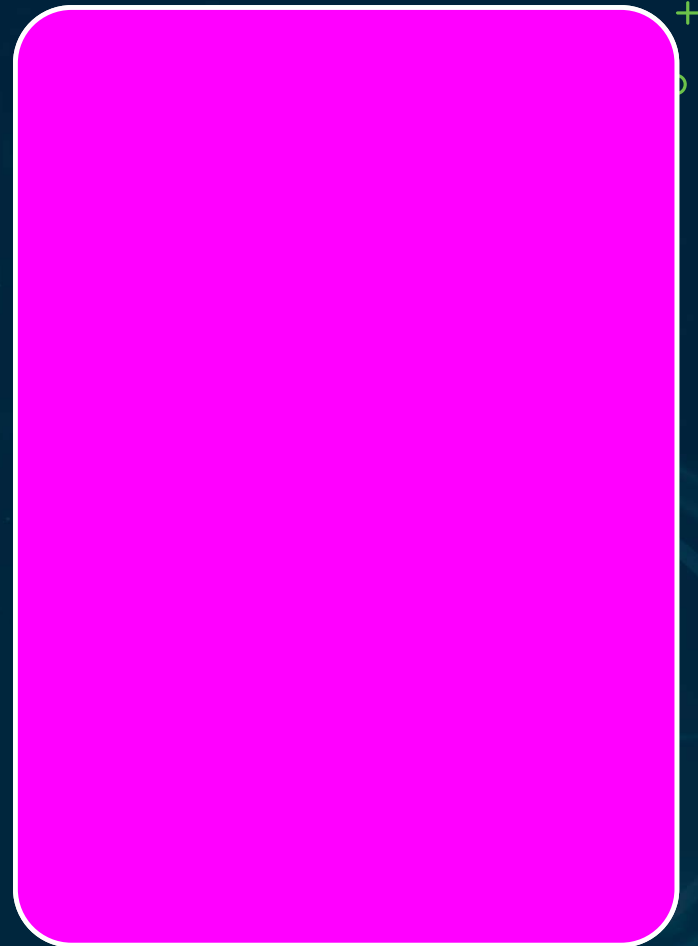
Trust Boundaries

Training/inference — no runtime check for training-time attacks

System-prompt boundary — prompt injection exploits it

Tool-invocation boundary — crosses into real-world action

Identify which boundary was crossed

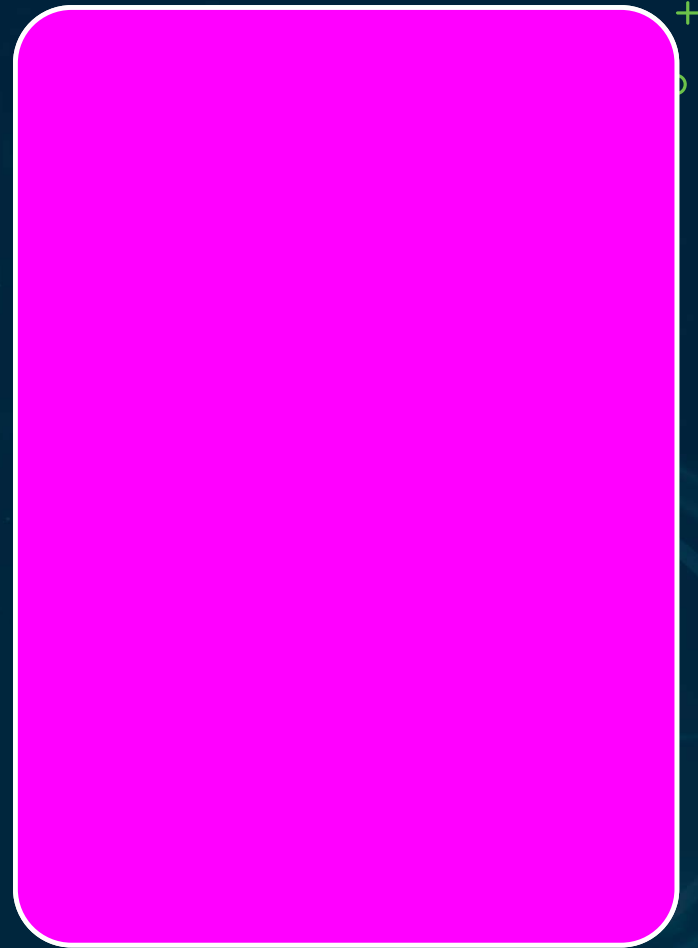


The Model Drives Every Control

A prioritized list of exposures drives control decisions

Guardrails, access, encryption, monitoring map to surfaces

Without it, controls are just a checklist



Four Concentration Types

Single Vendor

All AI from one provider

Same Model

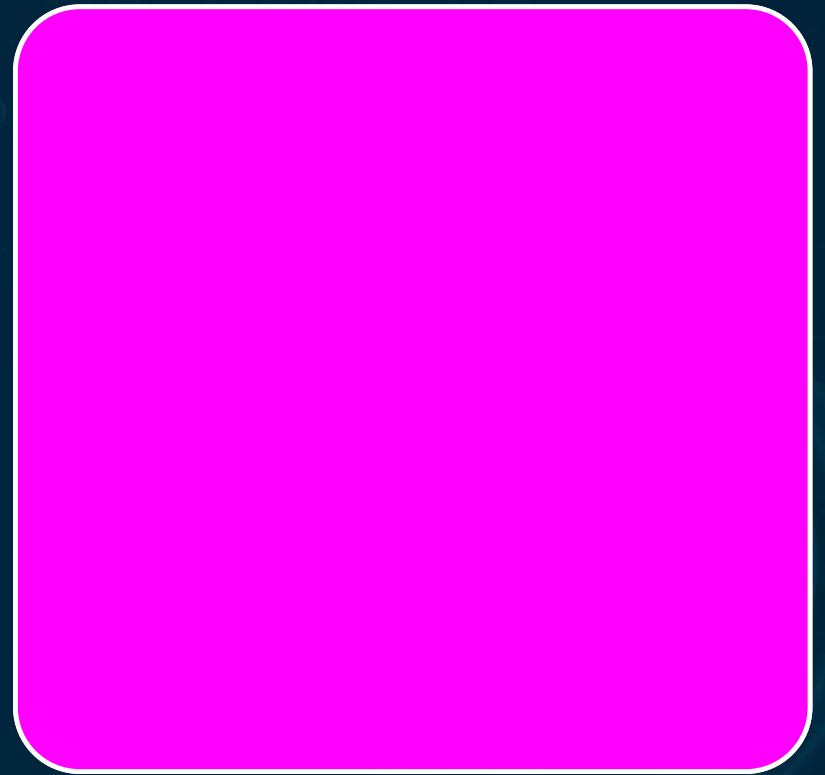
All systems on one
foundation model

Same Infrastructure

Shared hosting /
compute dependency

Geographic

Jurisdictional / regulatory
concentration



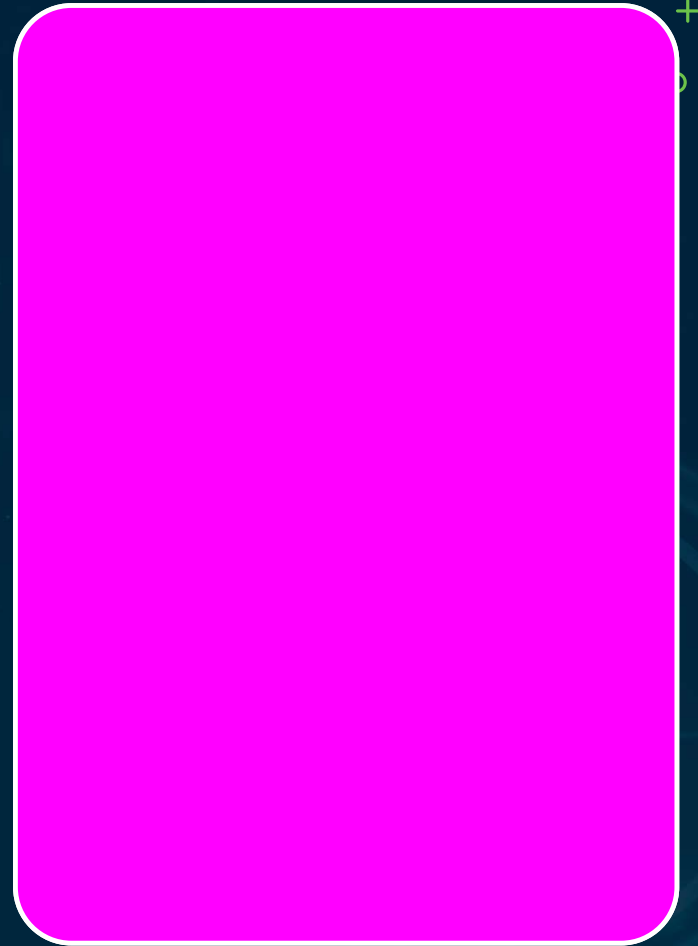
MITRE ATLAS

The AI-specific counterpart to ATT&CK

Tactic → technique hierarchy

Exploits the mathematical properties of ML

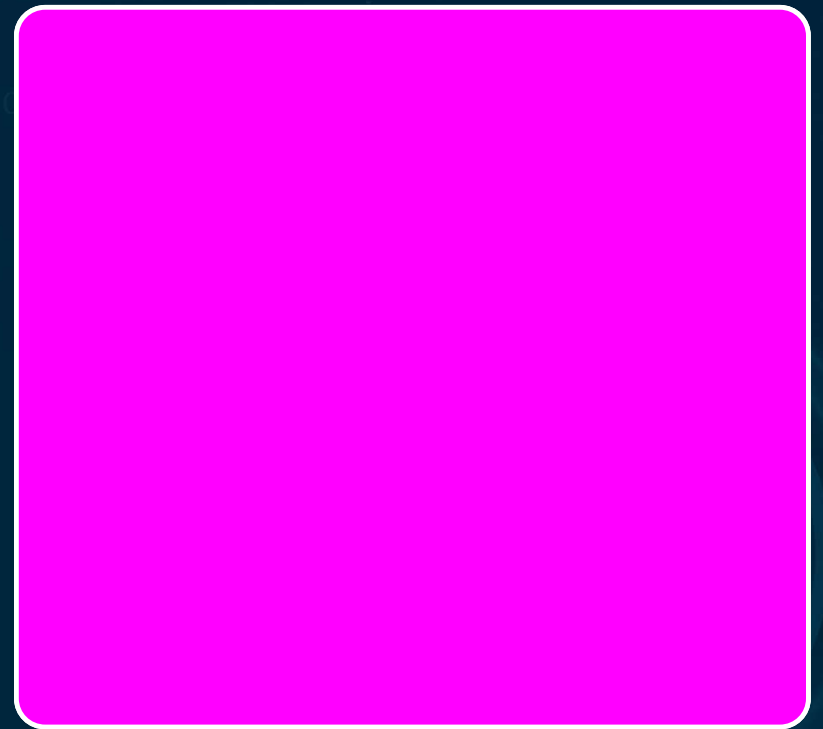
Some techniques have no ATT&CK equivalent



ATLAS vs OWASP

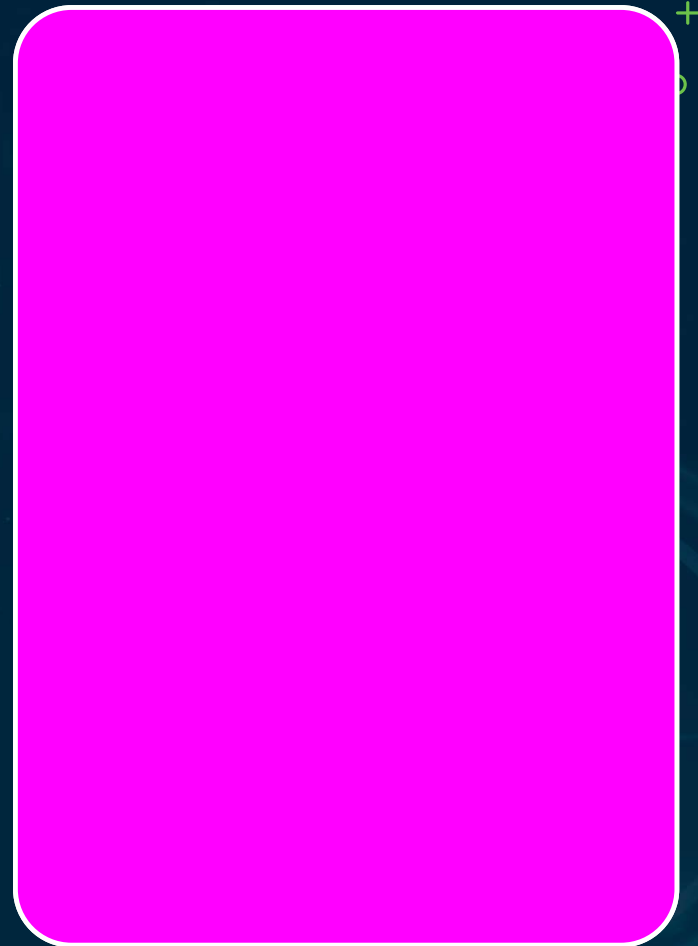
ATLAS — how adversaries attack AI

OWASP Top 10 — what vulnerabilities exist



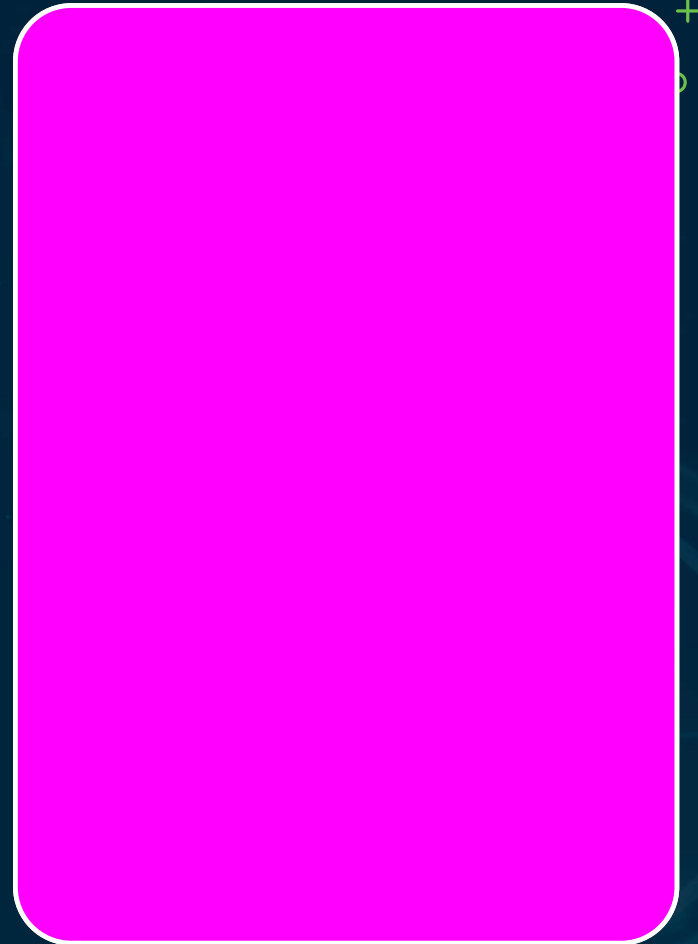
ATLAS · Data-Layer Techniques

- Data poisoning — attacker-influenced outputs
- Label manipulation — wrong decision boundaries
- Backdoor insertion — trigger-only, passes testing
- Control window is before training



ATLAS · Model-Layer Techniques

- Model inversion — reconstruct training data
- Membership inference — was this record trained on?
- Model extraction — IP theft via API querying
- Adversarial examples — evasion via perturbation



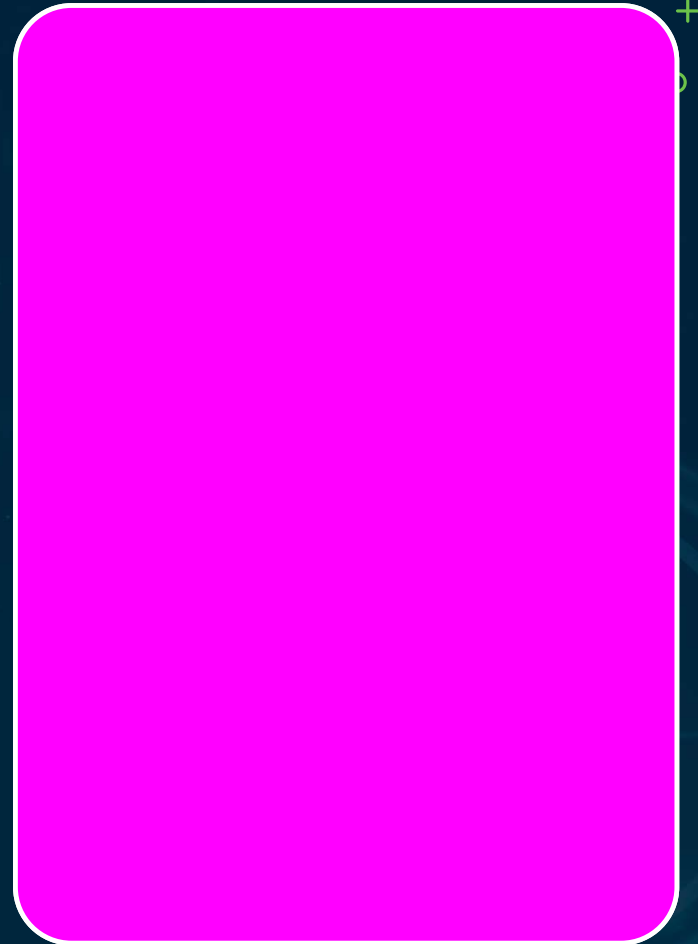
ATLAS · Interface/Integration

Prompt injection — direct + indirect

Jailbreaking — removes guardrails voluntarily

API abuse — token flooding, extraction querying

Privilege escalation via tool integration



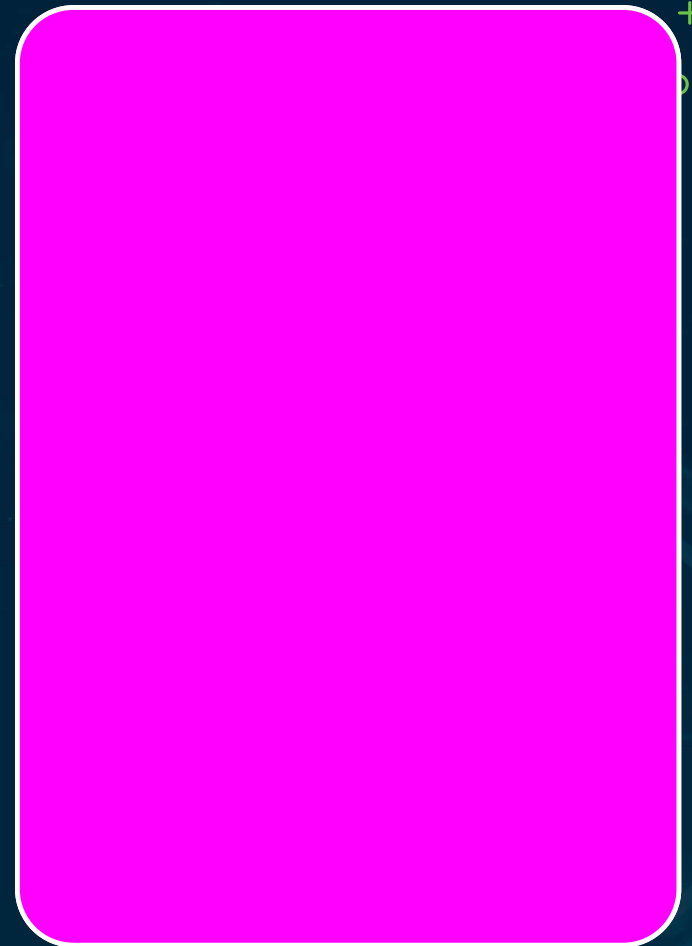
Attack-Chain Mapping

Techniques sequence across lifecycle stages

Recon → extraction → adversarial → evasion

Supply-chain backdoor → trigger in production

Control gaps appear at stage transitions



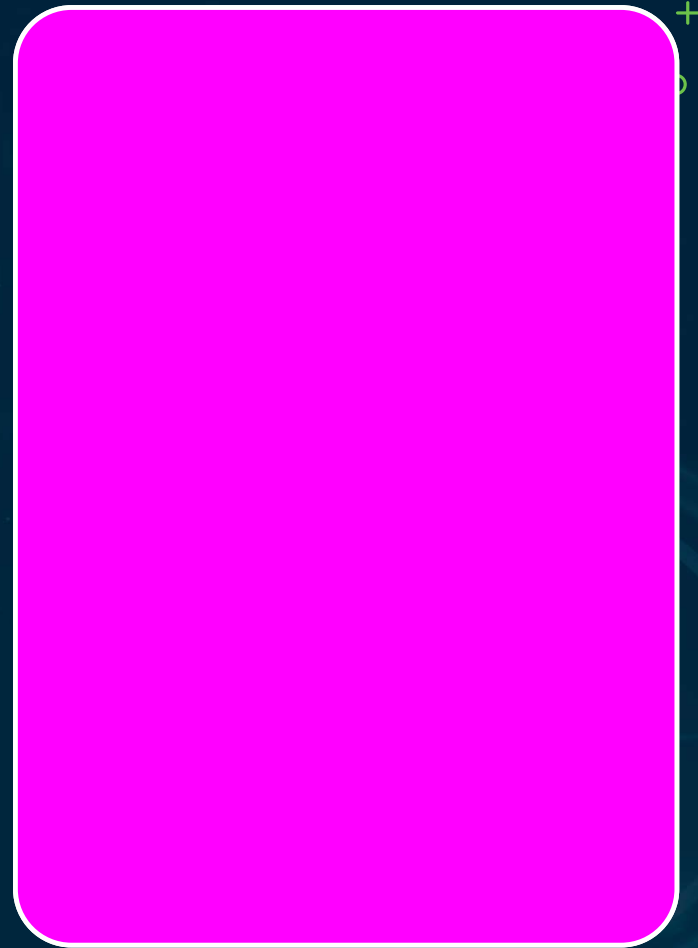
Vendor Risk = Incident Trigger

Vendor risk feeds the dashboard KRI

Distress / acquisition → out-of-cycle DD review

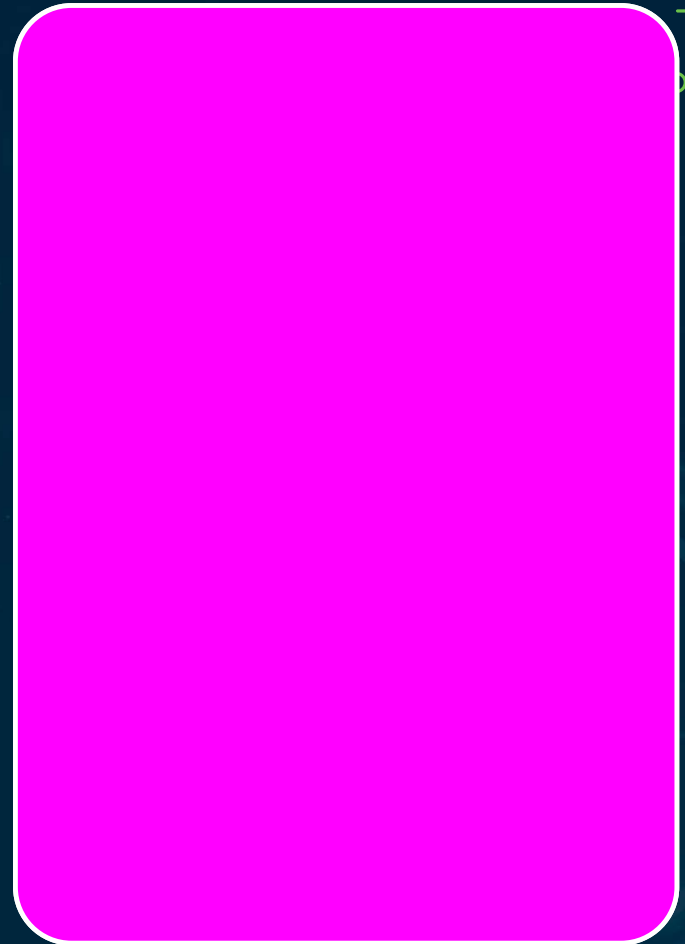
Vendor incidents → immediate classification

Treat as if internal



Document Five Things First

- 1 Function + consequences of wrong decisions
- 2 Data touched (sources, inputs, stores, outputs)
- 3 Integrations + tool permissions
- 4 Deployment context (who can reach it)
- 5 Consequence of failure — the impact ceiling



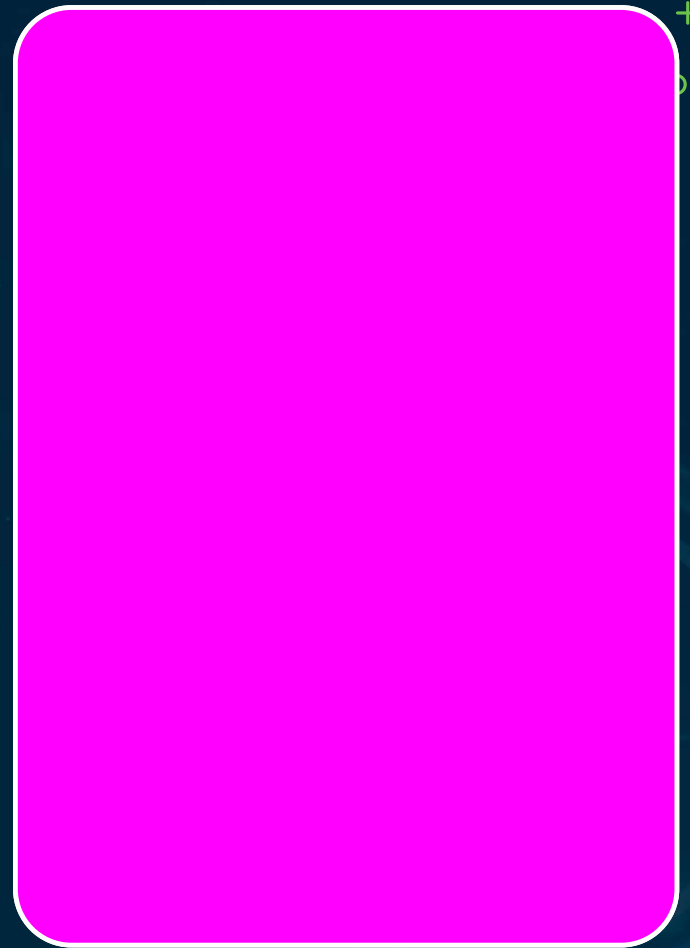
Systematic Threat Identification

Walk all four surfaces with OWASP +
ATLAS checklists

Data: external training → poisoning (LLM03
/ AML.T0020)

Model: public API → extraction (LLM10 / AML.T0005)

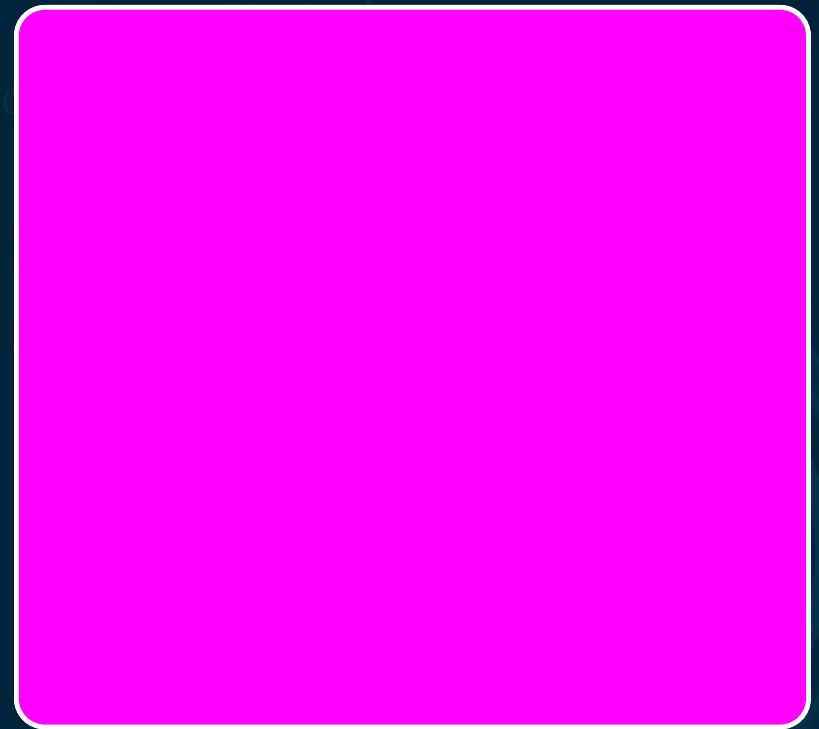
Interface: free text → injection (LLM01)



RISK-STATEMENT FORMAT



If condition, then consequence, affecting asset
Each maps directly to a compensating control
Vague threats can't be prioritized or mitigated



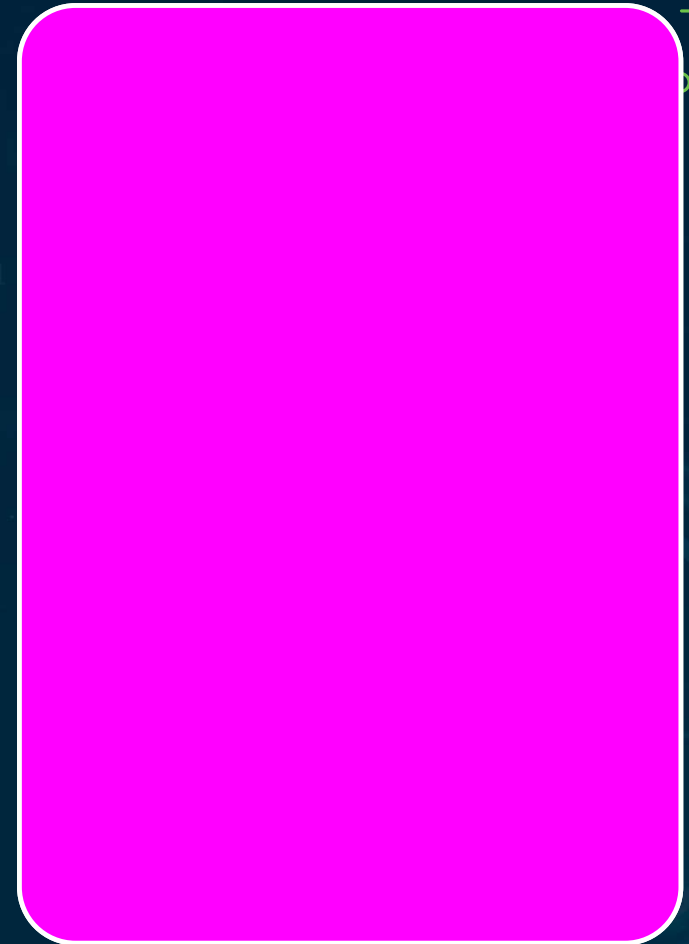
Score Likelihood & Impact

Likelihood: exposure, auth, guardrails, sophistication

Impact: confidentiality, integrity, availability

Regulatory + reputational dimensions

Matrix (H/M/L) → risk tier drives prioritization



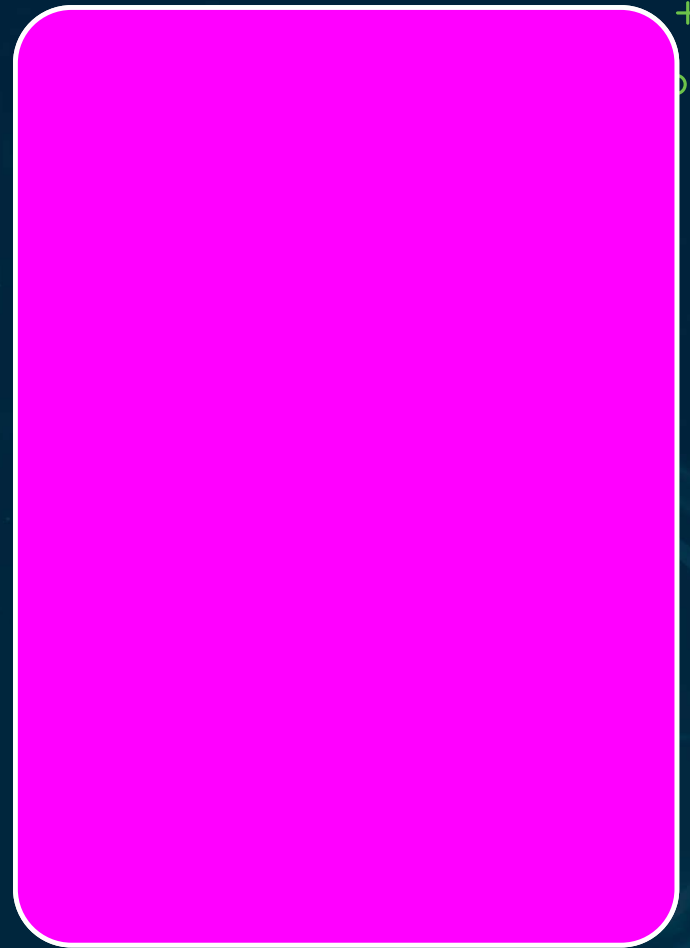
Risk-Appetite Thresholds

Automation boundary — human approval for writes

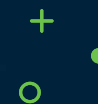
Confidence < 80% routes to a human (LLM09)

F1 drift > 5% → pause + retraining review

Quarterly review + after every change



Four Documentation Artifacts



Risk Register

Threat, score, tier, owner, mitigation, review



Dataset Docs

Sources, preprocessing, licensing, biases



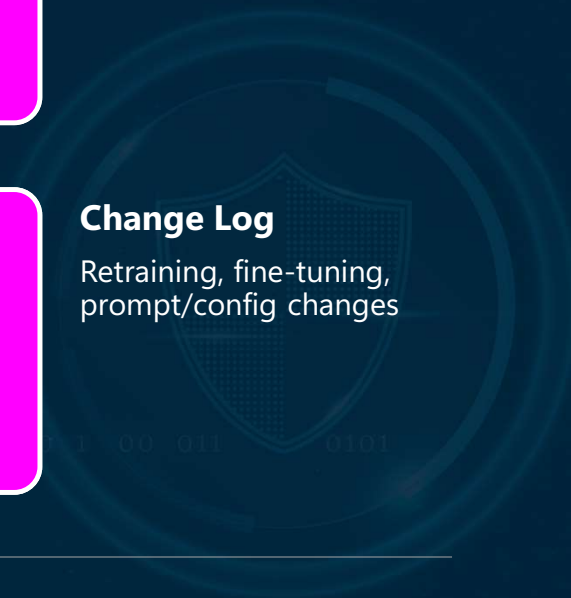
Model Card

Function, limits, metrics, failure modes



Change Log

Retraining, fine-tuning, prompt/config changes



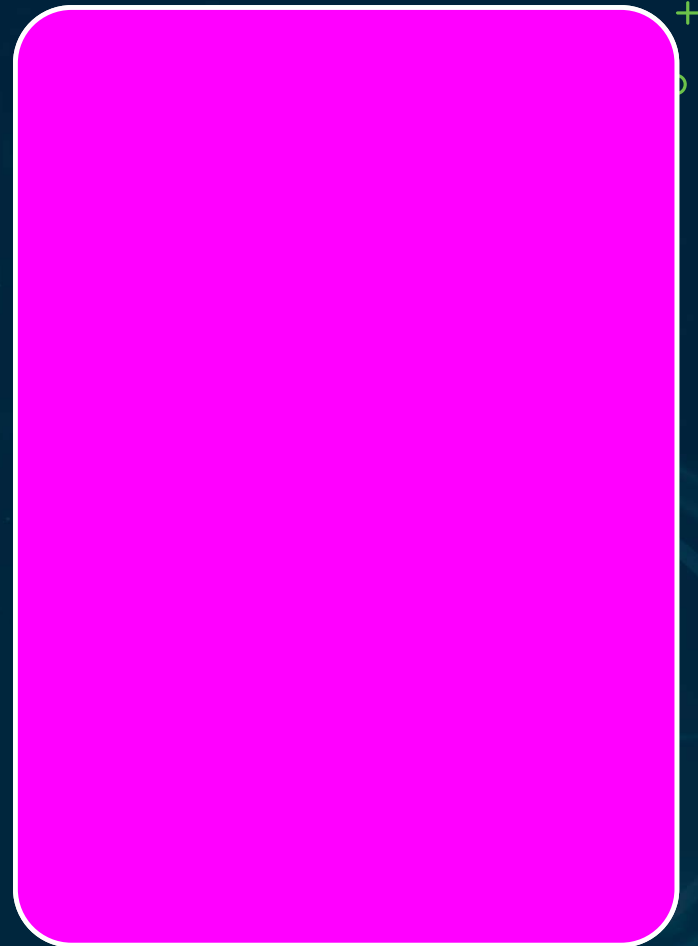
Third-Party AI Risk

Extends beyond standard vendor risk to model supply chain

AI provider (model / API)

Data supplier (training data)

AI tool vendor (security tooling)



Recap · Threat Modeling & Vendor Risk

Three vendor types + tier assignment

Four concentration types

Vendor incidents = internal incident triggers

